

EOP / Microsoft Defender for Office 365

Best Practice Guide und Hardening-Standard

Wiederverwendbare Kundenmethodik · Recherchestand August 2026

Inhalt

Über dieses Dokument

Woher es kommt

Wie es benutzt wird

Was die Kürzel bedeuten

Was verifiziert ist – und was nicht

Die zehn wichtigsten Änderungen seit 2023

Wie EOP und Defender zusammenspielen

Es greift immer nur eine Policy

Es gewinnt immer nur ein Verdict

Ausnahmen sind nicht gleich Ausnahmen

Preset Security Policies und Governance

PRE-01 Preset oder Custom?

PRE-02 Built-in protection

PRE-03 Präzedenz dokumentieren

PRE-04 Configuration Analyzer

PRE-05 Policy-Inventar: verwaiste und stillgelegte Richtlinien

Anti-Spam eingehend

Die Werte im Überblick

ASI-01 Bulk-Schwellwert

ASI-02 bis ASI-06 Die vier Aktionen

ASI-07 Safety Tips

ASI-08 Zero-hour Auto Purge

ASI-09 Quarantäne-Aufbewahrung

ASI-10 Allow-Listen in der Anti-Spam-Policy

ASI-11 Sprach- und Länderfilter

ASI-12 Interne Nachrichten filtern

Advanced Spam Filter (ASF)

Der Gesamtbefund

ASF-01 und ASF-02 Die Score- und Klassifizierungsfeatures

ASF-03 SPF Hard Fail – die offene Frage von 2023

ASF-04 Sender ID und Backscatter

ASF-05 Test-Modus

Connection Filter

CF-01 IP Allow List

CF-02 IP Block List

CF-03 Safe List

Anti-Spam ausgehend

ASO-01 Default-Policy oder eigene Policy?

ASO-02 Empfänger-Limits

ASO-03 Aktion bei Limitüberschreitung

ASO-04 Automatische externe Weiterleitungen

ASO-05 Benachrichtigungen – ein dokumentierter Zielkonflikt

ASO-06 Tenant External Recipient Rate Limit

Anti-Phishing und Spoof-Schutz

Was EOP kann und was Defender braucht

APH-01 Spoof Intelligence

APH-02 Aktion bei Spoof-Erkennung

APH-03 bis APH-05 DMARC-Durchsetzung

APH-06 und APH-07 Absender-Indikatoren

APH-08 Phishing-Schwellwert

Impersonation-Schutz (Defender)

Der Befund aus dem Ursprungsdokument

IMP-01 und IMP-02 Geschützte Domänen

IMP-03 Geschützte Benutzer

IMP-04 Die Aktionen

IMP-05 Mailbox Intelligence

IMP-06 Safety Tips für Impersonation

IMP-07 Ausnahmen

IMP-08 Priority Account Protection

Tenant Allow/Block List

Warum dieses Kapitel wichtiger geworden ist

TABL-01 Der empfohlene Allow-Weg

TABL-02 Blocks

TABL-03 Spoof-Freigaben

TABL-04 bis TABL-06 URLs, Dateien, IP-Adressen

Anti-Malware

AMW-01 Common Attachment Filter

AMW-02 ZAP für Malware

AMW-03 Aktion des Typfilters

AMW-04 Quarantäne-Policy

AMW-05 Admin-Benachrichtigungen

Safe Attachments und Safe Links (Defender)

SA-01 Safe Attachments: Aktion

SA-02 Redirect und der verschwundene Fehlerfall

SA-03 und SA-04 Globale Einstellungen

SA-05 Dynamic Delivery

SL-01 bis SL-05 Safe Links: die Kernschalter

SL-06 „Do not rewrite the following URLs”

SL-07 Warnseite und Benachrichtigungstext

Quarantäne-Policies

Wie das Modell funktioniert

QUA-01 Die Zuordnung je Verdict

QUA-02 Eine eigene Policy bauen
QUA-03 Benachrichtigungsfrequenz
QUA-04 Branding und Absenderadresse

Advanced Delivery

ADV-01 SecOps-Postfach
ADV-02 Phishing-Simulationen
ADV-03 Filter-Bypässe im Bestand

E-Mail-Authentifizierung

AUTH-01 bis AUTH-03 SPF
AUTH-04 und AUTH-05 DKIM
AUTH-06 und AUTH-07 DMARC
AUTH-08 ARC
AUTH-09 und AUTH-10 Transportverschlüsselung
AUTH-11 Microsoft Sender Requirements

Enhanced Filtering for Connectors

EF-01 Bedarf richtig bewerten
EF-02 Fallstricke

Kennzeichnung externer E-Mails

EXT-01 Das native External-Tag
EXT-02 Die drei Varianten im Vergleich
EXT-03 Wenn der Transportregel-Banner gewählt wird

Reporting und Alerting

REP-01 Berichte
REP-02 Alert Policies
REP-03 Meldeweg für Nutzer
REP-04 Message Trace

Hybrid und On-Premises

HYB-01 Exchange Server im Support
HYB-02 Dedizierte Exchange-Hybrid-App
HYB-03 Receive Connector
HYB-04 Ausgehende Firewall-Regeln
HYB-05 und HYB-06 Legacy-Protokolle
HYB-07 Nachrichtengrößen
HYB-08 und HYB-09 Connectors
Ein Hinweis zum Mailfluss

Betrieb und Voraussetzungen

OPS-01 Rollen
OPS-02 PowerShell-Voraussetzungen
OPS-03 Ausgangszustand sichern
OPS-04 Nachkontrolle

Ergänzungen: Teams, Weiterleitungen, Domänenkonfiguration

TEAMS-01 Teams Protection
ASO-07 Der zweite Weg für automatische Weiterleitungen
ASO-08 Versand aus der onmicrosoft.com-Domäne
HYB-10 Accepted-Domain-Typ und Directory Based Edge Blocking
AUTH-12 BIMI

Wirksamkeit nachweisen

VER-01 Malware und Anhangsfilter

VER-02 Header lesen

VER-03 Spoof- und Linkschutz

GOV-01 Datenschutz und Mitbestimmung

P2-01 Wenn der Kunde Defender Plan 2 hat

Anhang A: Prüfpunkt-Index

Preset Security Policies

Anti-Spam inbound

Advanced Spam Filter (ASF)

Connection Filter

Anti-Spam outbound

Anti-Phishing / Spoof

Impersonation (MDO)

Tenant Allow/Block List

Anti-Malware

Safe Attachments (MDO)

Safe Links (MDO)

Quarantäne-Policies

Advanced Delivery

E-Mail-Authentifizierung

Enhanced Filtering

Kennzeichnung externer E-Mails

Reporting & Alerting

Hybrid & On-Premises

Betrieb & Voraussetzungen

Microsoft Teams Protection

Anti-Spam outbound

Hybrid & On-Premises

Wirksamkeitsnachweis

Governance & Datenschutz

E-Mail-Authentifizierung

Defender P2 (falls lizenziert)

Anhang E: Wo die Einstellung im Portal sitzt

Preset Security Policies

Anti-Spam inbound

Advanced Spam Filter (ASF)

Connection Filter

Anti-Spam outbound

Anti-Phishing / Spoof

Impersonation (MDO)

Tenant Allow/Block List

Anti-Malware

Safe Attachments (MDO)

Safe Links (MDO)

Quarantäne-Policies

Advanced Delivery
E-Mail-Authentifizierung
Enhanced Filtering
Kennzeichnung externer E-Mails
Reporting & Alerting
Hybrid & On-Premises
Betrieb & Voraussetzungen
Microsoft Teams Protection
Anti-Spam outbound
Hybrid & On-Premises
Wirksamkeitsnachweis
Governance & Datenschutz
E-Mail-Authentifizierung
Defender P2 (falls lizenziert)
Was an diesen Links unsicher ist

Anhang B: Was aus dem Ursprungsdokument korrigiert wurde

Sachliche Korrekturen
Bestätigte Punkte
Lücken, die geschlossen wurden
Nicht belegbare Punkte

Anhang C: Ablaufplan für einen Kundentermin

Vorbereitung (vor dem Termin)
Vormittag: Aufnahme
Nachmittag: Besprechung und Umsetzung
Die Punkte, die eine Kundenentscheidung brauchen
Was sich für ein Folgeprojekt anbietet

Anhang D: Quellen

Konzept- und Konfigurationsartikel
Cmdlet-Referenzen
Microsoft-Blogs

Über dieses Dokument

Woher es kommt

Grundlage dieses Guides ist ein internes Basisdokument von 2023, das seither in Kundenprojekten im Einsatz ist. Es enthält Konfigurationsentscheidungen, die sich in der Praxis bewährt haben. Dieser Guide ersetzt sie nicht durch generische Microsoft-Empfehlungen, sondern prüft jede einzelne davon gegen den Stand von 2026:

- Existiert die Funktion überhaupt noch?
- Sitzt sie noch an derselben Stelle im Portal?
- Wurde sie umbenannt oder durch etwas anderes ersetzt?
- Ist die ursprüngliche Empfehlung heute noch sinnvoll?
- Gibt es ein aktuelles PowerShell-Cmdlet dafür?
- Gilt sie für EOP, oder braucht sie Defender P1 bzw. P2?

Wo die Prüfung ergeben hat, dass die Empfehlung von 2023 heute anders ausfallen würde, steht das ausdrücklich da – mit Begründung. Wo sie unverändert richtig ist, steht auch das da. Beides ist ein Ergebnis.

Wie es benutzt wird

Der Guide ist das Begleitdokument zur **Assessment-Checkliste** (EOP-MDO_Assessment-Checkliste.xlsx). Beide verwenden dieselben IDs: Wenn in der Checkliste ASI-01 steht, findet sich hier unter derselben Nummer die ausführliche Begründung. Die Checkliste ist das Arbeitsmittel vor Ort, dieser Guide ist die Argumentationsgrundlage im Gespräch mit dem Kunden und die Nachlese danach.

Neben den Prüfpunkten aus dem Ursprungsdokument enthält der Guide zwei Kapitel, die aus der Projektpraxis kommen: **Wirksamkeit nachweisen** (VER-01 bis VER-03) beschreibt, wie sich am Ende eines Termins zeigen lässt, dass die Einstellungen greifen – und **Datenschutz und Mitbestimmung** (GOV-01) den Punkt, an dem ein Hardening bei deutschen Kunden am häufigsten hängen bleibt.

Dazu kommen zwei PowerShell-Skripte:

Datei	Zweck
Invoke-EopAudit.ps1	Liest den Ist-Zustand aus. Rein lesend, keine Änderung am Tenant. Liefert CSV und HTML-Report.
Invoke-EopHardening.ps1	Setzt die Baseline. -WhatIf ist der Standardmodus – ohne -Execute wird nichts geändert.

Empfohlene Reihenfolge beim Kunden:

1. Invoke-EopAudit.ps1 laufen lassen, CSV in die Checkliste übernehmen.

2. Checkliste durchgehen, Bewertungen setzen, Abweichungen mit dem Kunden besprechen.
3. `Invoke-EopHardening.ps1` ohne `-Execute` laufen lassen und die geplanten Änderungen zeigen.
4. Nach Freigabe mit `-Execute` umsetzen.
5. Termin für die Nachkontrolle nach 7 bis 14 Tagen vereinbaren.

Was die Kürzel bedeuten

Jede ID besteht aus einem Präfix und einer laufenden Nummer und ist über Checkliste, Guide, Audit-Report und Hardening-Skript identisch. Das Präfix benennt den **fachlichen Bereich** – nicht zwingend die Portal-Richtlinie, in der die Einstellung sitzt. Das fällt an drei Stellen auseinander und ist genau dort auch gewollt:

- **APH und IMP** stehen beide in derselben Anti-Phishing-Richtlinie. Getrennt sind sie, weil APH mit jeder Lizenz funktioniert und IMP eine Defender-Lizenz braucht. Wer bei einem EOP-only-Kunden arbeitet, kann alle IMP-Punkte in einem Zug auf *n.a.* setzen – das ist der praktische Nutzen der Trennung.
- **ASF** sitzt innerhalb der Anti-Spam-Richtlinie, ist aber ein eigenes, historisch gewachsenes Regelwerk mit eigener Bewertungslogik und verdient deshalb eine eigene Betrachtung.
- **CF** – der Verbindungsfilter – erscheint im Portal als Zeile *in der Liste der Anti-Spam-Richtlinien*, ist technisch aber eine eigene Richtlinie mit eigenen Cmdlets und greift vor allen anderen.

Kürzel	Bereich	Punkte	Was dahintersteckt
PRE	Preset Security Policies und Governance	5	Voreingestellte Sicherheitsrichtlinien, Praezedenz, Configuration Analyzer
ASI	Anti-Spam inbound	12	Anti-Spam-Richtlinie, eingehend
ASF	Advanced Spam Filter	5	Die ASF-Schalter innerhalb der Anti-Spam-Richtlinie
CF	Connection Filter	3	Verbindungsfilterrichtlinie - liegt als eigene Zeile in der Liste der Anti-Spam-Richtlinien
ASO	Anti-Spam outbound	8	Ausgehende Anti-Spam-Richtlinie plus Weiterleitungswege

Kürzel	Bereich	Punkte	Was dahintersteckt
APH	Anti-Phishing (EOP-Teil)	8	Spoof-Intelligence, DMARC- Behandlung, Sicherheitstipps - ohne Defender- Lizenz verfuegbar
IMP	Impersonation (Defender-Teil)	8	Identitaetswechsels chutz - sitzt in derselben Anti- Phishing-Richtlinie, ist aber lizenzpflichtig
TABL	Tenant Allow/Block List	6	Mandanten- Zulassungs-/ Sperrliste
AMW	Anti-Malware	5	Anti-Malware- Richtlinie und Anlagenfilter
SA	Safe Attachments	5	Sichere Anlagen (Defender)
SL	Safe Links	7	Sichere Links (Defender)
QUA	Quarantaene- Richtlinien	4	Zugriffsrechte und Benachrichtigungen fuer die Quarantaene
ADV	Advanced Delivery	3	Erweiterte Zustellung: SecOps-Postfach und Phishing- Simulation
AUTH	E-Mail- Authentifizierung	12	SPF, DKIM, DMARC, ARC, MTA-STS, DANE - ueberwiegend im oeffentlichen DNS
EF	Enhanced Filtering	2	Erweiterte Filterung am Inbound- Connector (Skip Listing)
EXT	Externe Kennzeichnung	3	External-Tag, First- Contact-Tipp,

Kürzel	Bereich	Punkte	Was dahintersteckt
REP	Reporting und Alerting	4	Banner per Transportregel Berichte, Warnungsrichtlinien , Meldeweg fuer Nutzer
HYB	Hybrid und On-Premises	10	Exchange Server, Connectors, akzeptierte Domaenen, Legacy-Protokolle
OPS	Betrieb und Voraussetzungen	4	Rollen, PowerShell- Arbeitsplatz, Baseline, Nachkontrolle
TEAMS	Microsoft Teams Protection	1	ZAP fuer Teams- Nachrichten
VER	Wirksamkeitsnachweis	3	Belegen, dass der Schutz greift - Quarantaene, Header, Explorer
G0V	Governance und Datenschutz	1	DSGVO und Mitbestimmung rund um Quarantaene- Einsicht
P2	Defender Plan 2	1	Nur mit MDO P2: automatisierte Untersuchung (AIR)

Anhang E nennt zu jedem Prüfpunkt den Klickpfad im Portal und den passenden Microsoft-Learn-Abschnitt.

Was verifiziert ist – und was nicht

Alle Cmdlets, Parameternamen, gültigen Werte, Default-Werte sowie die Werte der Standard- und Strict-Presets wurden gegen die Microsoft-Learn-Referenz und die zugehörigen Quell-Repositories geprüft. Wo eine Aussage sich nicht belegen ließ, ist sie im Text als **nicht verifiziert** oder als **eigene Empfehlung** gekennzeichnet – ein Unterschied, der beim Kunden zählt.

Nicht geprüft wurde gegen einen Produktivtenant. Die Skripte sind syntaktisch validiert und PowerShell-5.1-kompatibel, aber der erste Lauf beim Kunden gehört in den Lesemodus.

Die zehn wichtigsten Änderungen seit 2023

Wer wenig Zeit hat, liest diese Tabelle. Sie fasst zusammen, was sich gegenüber dem Ursprungsdokument bewegt hat.

#	Was sich geändert hat	Betrifft
1	DMARC-Durchsetzung in der Anti-Phish-Policy ist neu. HonorDmarcPolicy, DmarcQuarantineAction und DmarcRejectAction setzen die veröffentlichte DMARC-Policy fremder Absender tatsächlich durch. EOP-Feature, keine Defender-Lizenz nötig.	APH-03 bis APH-05
2	„DMARC: optional“ ist nicht mehr haltbar. Seit Mai 2025 verlangt Microsoft SPF, DKIM und DMARC von Absendern mit mehr als 5.000 Nachrichten pro Tag an outlook.com und Co. Reject mit 550 5.7.515.	AUTH-06, AUTH-11
3	ZapEnabled gibt es in der Anti-Spam-Policy nicht mehr. Aufgeteilt in SpamZapEnabled und PhishZapEnabled. Altskripte brechen still.	ASI-08
4	Der Phishing-Schwellwert 2 liegt unter dem Microsoft-Standard. Standard-Preset verwendet 3, Strict 4.	APH-08
5	MarkAsSpamSenderIdHardFail existiert nicht. Der korrekte Parametername lautet MarkAsSpamFromAddressAuthFail.	ASF-04
6	Die Frage aus dem Ursprungsdokument zu SPF-Hardfail ist beantwortet. Microsoft:	ASF-03

#	Was sich geändert hat	Betrifft
7	„No. This ASF setting is no longer required.” Safe Attachments Replace ist entfernt. Nur noch Allow, Block und DynamicDelivery. Ebenso verschwunden: ActionOnError.	SA-01, SA-02
8	Die Safe-Links-Global-Block-List ist abgeschafft, URL-Blocks laufen über die Tenant Allow/Block List.	TABL-04, SL-06
9	Eine Quarantäne-Policy AdminOnlyAccessWithNotifyPolicy existiert nicht. Es gibt NUR AdminOnlyAccessPolicy, DefaultFullAccessPolicy und DefaultFullAccessWithNotificationPolicy.	QUA-01
10	Advanced Delivery ist kein E5-Feature. Microsoft nennt ausdrücklich Plan 1 und Plan 2. Verwechslung mit Attack Simulation Training.	ADV-02

Dazu kommen vier Themen, die 2023 noch gar nicht existierten und heute in jedes Hardening gehören: die **dedizierte Exchange-Hybrid-App** (CVE-2025-53786, seit 31.10.2025 erzwungen), das **Tenant External Recipient Rate Limit**, das **Support-Ende von Exchange 2016 und 2019** am 14. Oktober 2025 und **Microsoft Teams Protection** – seit Anfang 2026 auch in Plan 1 (TEAMS-01).

Und eine Lücke, die im Ursprungsdokument schlicht fehlte: **automatische externe Weiterleitungen**. Das ist der Standard-Exfiltrationsweg nach einer Kontokompromittierung – und es gibt dafür zwei unabhängige Schalter, AutoForwardingMode in der Outbound-Spam-Policy (ASO-04) und AutoForwardEnabled in der Remote Domain (ASO-07).

Wie EOP und Defender zusammenspielen

Bevor es an einzelne Schalter geht, drei Zusammenhänge, ohne die viele Einstellungen nicht erklärbar sind. Sie kommen im Kundengespräch regelmäßig vor.

Es greift immer nur eine Policy

Für jeden Empfänger und jeden Policy-Typ wird genau **eine** Richtlinie angewendet – die erste passende in dieser Reihenfolge:

1. Strict Preset Security Policy
2. Standard Preset Security Policy
3. Defender-for-Office-365-Evaluationsrichtlinien
4. Custom-Policies, nach ihrer Priorität (0 ist die höchste)
5. gleichrangig: Built-in-protection-Preset (nur Safe Links und Safe Attachments) und die Default-Policies für Anti-Malware, Anti-Spam und Anti-Phishing

Entscheidend ist der Satz aus der Microsoft-Dokumentation: „*There's never a merging or combining of the settings in multiple policies for the recipient.*“ Wer in Policy A den Impersonation-Schutz einschaltet und in Policy B das Anti-Spoofing, und beide Policies denselben Empfänger erfassen, bekommt für diesen Empfänger nur Policy A – Anti-Spoofing bleibt aus.

Praktische Konsequenz: Ein Empfänger, der einem Preset zugewiesen ist, ignoriert **alle** Custom-Policy-Einstellungen. Wer also ASF-Settings oder Länderfilter braucht (beides ist in Presets nicht enthalten), kann für diese Empfänger keine Presets verwenden.

Es gewinnt immer nur ein Verdict

Wenn eine Nachricht mehrere Erkennungen auslöst, setzt sich die oberste durch:

Rang	Verdict	Header-Kategorie	Gesteuert in
1	Malware	CAT: MALW	Anti-Malware-Policy
2	High confidence phishing	CAT: HPHSH	Anti-Spam-Policy
3	Phishing	CAT: PSHH	Anti-Spam-Policy
4	High confidence spam	CAT: HSPM	Anti-Spam-Policy
5	Spoofing	CAT: SP00F	Anti-Phishing-Policy
6	User impersonation (MDO)	CAT: UIMP	Anti-Phishing-Policy

Rang	Verdict	Header-Kategorie	Gesteuert in
7	Domain impersonation (MDO)	CAT:DIMP	Anti-Phishing-Policy
8	Mailbox intelligence (MDO)	CAT:GIMP	Anti-Phishing-Policy
9	Spam	CAT:SPM	Anti-Spam-Policy
10	Bulk	CAT:BULK	Anti-Spam-Policy

Das erklärt eine häufige Rückfrage: „Wir haben Impersonation-Schutz aktiviert, aber die Aktion greift nie.“ Sobald dieselbe Nachricht als High confidence phishing eingestuft wird, gewinnt Rang 2 – die Impersonation-Aktion kommt gar nicht mehr zum Zug.

Ausnahmen sind nicht gleich Ausnahmen

Microsoft hat eine ausdrückliche Rangfolge veröffentlicht, welcher Weg zum Freigeben eines Absenders vorzuziehen ist:

1. **Tenant Allow/Block List** – der empfohlene Weg
2. Exchange-Transportregeln
3. Outlook-Safe-Senders der Nutzer
4. IP Allow List im Connection Filter
5. Allow-Listen in Anti-Spam-Policies

Microsoft wörtlich: „*Our number one recommended option for allowing mail from senders or domains is the Tenant Allow/Block List.*“ Alle anderen nur, „*if you can't use allow entries in the Tenant Allow/Block List for some reason.*“

Der technische Grund dahinter ist wichtiger als die Rangfolge selbst. Ein TABL-Allow ist ein **verdict-spezifischer Bypass mit Ablaufdatum**: Die Nachricht durchläuft weiterhin den übrigen Filterstack, nur das eine überschriebene Verdict wird ignoriert. Eine Transportregel mit SCL -1, ein Eintrag in AllowedSenderDomains oder eine IP auf der Allow List sind dagegen **pauschale Filter-Skips**: Spam-, Phishing-, Bulk- und Spoof-Prüfung entfallen komplett und dauerhaft. Wer die eigene Domäne dort einträgt und ein Angreifer spooft sie, geht die Mail ungefiltert in den Posteingang.

Deshalb ist in diesem Standard die Allow-Liste der Anti-Spam-Policy leer und die TABL der einzige reguläre Ausnahmeweg.

Preset Security Policies und Governance

PRE-01 Preset oder Custom?

Was zur Wahl steht. Microsoft bietet drei vorgefertigte Richtlinienätze: *Built-in protection* (nur Safe Links und Safe Attachments, allen Empfängern zugewiesen), *Standard protection* und *Strict protection*. Standard und Strict sind ab Werk **niemandem** zugewiesen – Microsoft schreibt selbst: „*During your first visit to the Preset security policies page, it's likely that Standard protection and Strict protection are turned off.*“

Was das Ursprungsdokument sagt. Es empfiehlt, mit Default- beziehungsweise Custom-Policies zu arbeiten, „da hier die meisten Einstellungen von Hand vorgegeben werden können“. Standard wird nur empfohlen, „wenn keine Zeit“. Ausdrücklich vermerkt ist der Vorbehalt, dass Microsoft sich bei Standard und Strict Anpassungen vorbehält.

Warum das damals so entschieden wurde. Der Vorbehalt ist real und bis heute gültig: Microsoft kann die Werte hinter Standard und Strict jederzeit ändern, ohne dass der Kunde etwas davon merkt. Für einen Consultant, der einen definierten Zustand übergeben und dokumentieren will, ist das ein Problem. Dazu kam 2023, dass die Presets weniger konfigurierbar waren – Impersonation-Listen ließen sich damals nicht sinnvoll pflegen.

Wie das 2026 zu bewerten ist. Der Vorbehalt bleibt, aber die Abwägung hat sich verschoben. Presets bekommen neue Schutzfunktionen automatisch mit; Custom-Policies bekommen sie nur, wenn jemand sie nachpflegt. Bei einem Kunden ohne eigenes Security-Team altert eine Custom-Policy still vor sich hin. Umgekehrt gibt es weiterhin Einstellungen, die in Presets schlicht nicht vorkommen: **ASF-Settings, Sprach- und Länderfilter und IntraOrgFilterState sind nur in Custom-Policies erreichbar.** Und ein Empfänger im Preset ignoriert Custom-Policies vollständig.

Empfehlung für diesen Standard. Custom-Policies auf Standard-Preset-Niveau, mit den in diesem Guide dokumentierten bewussten Abweichungen. Das ist der Weg, der Kontrolle und Dokumentierbarkeit erhält – also genau die Begründung des Ursprungsdokuments, nur mit heutigen Zielwerten. Wo ein Kunde kein Interesse an Feinsteuerung hat und niemanden hat, der die Policies pflegt, ist das Standard-Preset die ehrlichere Empfehlung.

Fallstrick. Der EOP-Teil und der MDO-Teil eines Presets werden über **getrennte Cmdlets** ein- und ausgeschaltet. Ein Preset kann halb aktiv sein – Anti-Spam und Anti-Malware laufen, Safe Links und Safe Attachments nicht. Beim Audit immer beide prüfen.

Get-EOPProtectionPolicyRule | [Format-Table](#) Name,State
Get-ATPPProtectionPolicyRule | [Format-Table](#) Name,State

Lizenz. Der EOP-Teil der Presets läuft mit EOP, der MDO-Teil erfordert Defender for Office 365 P1 oder P2.

Was passiert mit bestehenden Custom-Policies, wenn ein Preset dazukommt?

Die Frage stellt sich in jedem Projekt, in dem erst Custom-Policies gebaut und später Presets aktiviert werden. Die Antwort ist eindeutig: **Für Empfänger im Scope des Presets wird die Custom-Policy nicht ergänzt, sondern vollständig ignoriert.**

Microsoft formuliert es so:

„the anti-spam policy settings from the Standard preset security policy are applied to the users instead of the settings in the custom anti-spam policy or the default anti-spam policy.“

Drei Konsequenzen, die man kennen muss:

Eine Custom-Policy kann ein Preset nicht überstimmen. Custom-Policies rangieren *unter* Standard und Strict — unabhängig von ihrer Priorität. Wer für eine Gruppe abweichende Werte braucht, muss diese Gruppe im **Preset ausschließen** (Exceptions in der Preset-Rule). Eine Custom-Policy mit Priorität 0 daneben zu stellen bewirkt nichts.

Der Bereich der Presets ist begrenzt. Nicht alles, was in einer Anti-Spam-Policy steht, hat im Preset ein Gegenstück:

Vom Preset überschrieben	Bleibt davon unberührt
Anti-Spam (inbound)	Outbound-Spam-Policy — <i>„Outbound spam policies aren't part of preset security policies“</i>
Anti-Malware	Connection Filter (IP Allow/Block)
Anti-Phishing inkl. Spoof und DMARC	Tenant Allow/Block List
Impersonation und Phishing-Schwellwert (MDO)	Quarantäne-Global-Settings
Safe Links, Safe Attachments (MDO)	Teams Protection, Transportregeln, Remote Domain, External-Tag

Was beim Umstieg still verloren geht. Alles, was in der Custom-Anti-Spam-Policy gepflegt war und im Preset nicht vorgesehen ist, wirkt für Preset-Empfänger ab sofort nicht mehr: die Einträge in `AllowedSenders` und `AllowedSenderDomains`, sämtliche ASF-Settings, Sprach- und Länderfilter, `IntraOrgFilterState`, die eigenen Quarantäne-Policy-Zuordnungen und `QuarantineRetentionPeriod` (das Preset fixiert 30 Tage).

Der praktische Fall: Ein Lieferant stand in der Allow-Liste, das Standard-Preset wird aktiviert, und am nächsten Tag landet dessen Post wieder in der Filterung. Vor der Aktivierung eines Presets gehört deshalb die bestehende Custom-Policy Zeile für Zeile durchgesehen — und alles, was erhalten bleiben soll, in die Tenant Allow/Block List überführt.

Getrennte Scopes für EOP und Defender. Ein Preset lässt sich für den EOP-Teil und den Defender-Teil unterschiedlichen Empfängerkreisen zuweisen: *„You can apply the built-in security features for all cloud mailboxes to different users than Defender for*

Office 365 protections.” Man kann also den EOP-Teil auf alle legen und den MDO-Teil nur auf die Geschäftsführung — dann behalten die übrigen Empfänger ihre Custom-Safe-Links- und Anti-Phish-Policy. Das erklärt auch, warum beim Audit beide Regelsätze getrennt zu prüfen sind.

```
Get-EOPProtectionPolicyRule | Format-List
Name,State,SentTo,SentToMemberOf,RecipientDomainIs,ExceptIfSentTo,ExceptIfRecipientDomainIs
Get-ATPPProtectionPolicyRule | Format-List
Name,State,SentTo,SentToMemberOf,RecipientDomainIs,ExceptIfSentTo,ExceptIfRecipientDomainIs
Get-HostedContentFilterRule | Format-Table Name,Priority,State,SentTo,RecipientDomainIs
```

Überschneiden sich die Empfängermengen von Preset-Rule und Custom-Rule, ist die Custom-Rule für die Schnittmenge wirkungslos.

Was nicht stimmt. Es gibt keinen Beleg dafür, dass Microsoft die Standard- oder Strict-Presets automatisch für bestehende Tenants aktiviert. Verwechslungsgefahr besteht mit dem seit Ende 2025 existierenden **Baseline security mode** im Microsoft-365-Admin-Center – der ist ebenfalls nicht automatisch aktiv und enthält keine EOP- oder MDO-Threat-Policies.

PRE-02 Built-in protection

Das Built-in-protection-Preset ist ab Werk allen Empfängern zugewiesen und deckt ausschließlich Safe Links und Safe Attachments ab. Microsoft begründet das so: *„Because Built-in protection is enabled by default, customers don’t need to worry about violating product licensing terms.”*

Wichtig zu wissen: **Built-in ist schwächer als Standard und Strict.** Konkret setzt es AllowClickThrough auf \$true (Nutzer dürfen sich über die Safe-Links-Warnseite hinwegsetzen) und EnableForInternalSenders auf \$false (interne Nachrichten werden nicht geprüft). Ein Tenant, der nur auf Built-in setzt, hat beide Lücken offen.

Der zu prüfende Punkt ist ein Anti-Pattern, das in der Praxis vorkommt: Der Rule lassen sich Ausnahmen mitgeben, und Microsoft dokumentiert selbst das Muster, mit dem man **alle** Empfänger ausschließt:

```
# Ist-Zustand prüfen
Get-ATPBuiltInProtectionRule | Format-List
Name,State,ExceptIfRecipientDomainIs,ExceptIfSentTo,ExceptIfSentToMemberOf

# Ausnahmen zurücksetzen
Set-ATPBuiltInProtectionRule -Identity "ATP Built-In Protection Rule" `
-ExceptIfRecipientDomainIs $null -ExceptIfSentTo $null -ExceptIfSentToMemberOf $null
```

Steht dort (Get-AcceptedDomain).Name, ist der Schutz für die gesamte Organisation abgeschaltet. Das ist ein legitimer Migrationsschritt beim Umstieg auf eigene Policies – bleibt es dabei stehen, ist es eine offene Flanke.

PRE-03 Präzedenz dokumentieren

Kein technischer Schalter, sondern eine Aufnahmeaufgabe: Für jeden Policy-Typ festhalten, welche Regeln existieren, in welcher Priorität und mit welchem

Empfängerbereich. Ohne diese Übersicht ist bei jeder späteren Störung unklar, welche Richtlinie überhaupt gegriffen hat.

Get-HostedContentFilterRule		Format-Table	Name,Priority,State,SentTo,RecipientDomainIs
Get-AntiPhishRule		Format-Table	Name,Priority,State,SentTo,RecipientDomainIs
Get-MalwareFilterRule		Format-Table	Name,Priority,State,SentTo,RecipientDomainIs
Get-SafeLinksRule		Format-Table	Name,Priority,State
Get-SafeAttachmentRule		Format-Table	Name,Priority,State

Ein häufiger Befund: Policies, die per PowerShell angelegt wurden und keine Rule haben. Die sind im Defender-Portal **unsichtbar** und wirken auf niemanden – sehen im Cmdlet-Output aber vorhanden aus.

PRE-04 Configuration Analyzer

Der Configuration Analyzer vergleicht die vorhandenen Richtlinien gegen die Standard- und Strict-Empfehlungen und listet jede Abweichung auf. Er deckt Anti-Spam, Anti-Malware, Anti-Phishing, Safe Links, Safe Attachments, DKIM und die Outlook-External-Sender-Kennzeichnung ab.

```
Get-ConfigAnalyzerPolicyRecommendation -RecommendedPolicyType Standard
Get-ConfigAnalyzerPolicyRecommendation -RecommendedPolicyType Strict
```

Der Parameter `-RecommendedPolicyType` ist Pflicht, gültige Werte sind ausschließlich `Standard` und `Strict`. Einen Parameter `-PolicyName` gibt es nicht.

Zwei Dinge machen das Werkzeug für die Projektarbeit wertvoll. Erstens der Schalter `-IsAppliedToDisabled`, der Policies findet, die niemandem zugewiesen sind – also Karteileichen. Zweitens der Portal-Tab **Configuration drift analysis and history**: Er zeigt bis zu 90 Tage rückwirkend, wer wann welchen Wert geändert hat und ob die Änderung das Sicherheitsniveau angehoben oder gesenkt hat. Voraussetzung ist aktiviertes Unified Auditing. Für den Nachkontrolltermin nach zwei Wochen ist das genau der richtige Einstieg.

PRE-05 Policy-Inventar: verwaiste und stillgelegte Richtlinien

PRE-03 nimmt auf, welche Regeln es gibt. PRE-05 zieht daraus die Konsequenz und ist der Prüfpunkt, an dem sich in fast jedem Assessment etwas findet.

Der Grund liegt in der Bauweise von EOP. Eine Schutzrichtlinie besteht immer aus **zwei** Objekten: der *Policy* mit den eigentlichen Werten und der *Rule*, die festlegt, für wen sie gilt und in welcher Priorität. Das Defender-Portal zeigt beides zusammen als eine Einheit und legt beides gemeinsam an. Über PowerShell lassen sich die Objekte dagegen einzeln erzeugen – und genau daraus entstehen zwei Zustände, die von außen wie funktionierende Richtlinien aussehen, es aber nicht sind:

Zustand	Wie es entsteht	Wirkung
Policy ohne Rule	New-SafeLinksPolicy ausgeführt, New-SafeLinksRule vergessen	Die Policy erscheint im Cmdlet-Output, ist im Portal aber unsichtbar und gilt für niemanden

Zustand	Wie es entsteht	Wirkung
Policy mit deaktivierter Rule	Regel testweise mit Disable-...Rule abgeschaltet und nie wieder eingeschaltet	Policy ist im Portal sichtbar, greift aber auf keinen Empfänger

Beide Fälle sind praktisch relevant. Der erste tritt regelmäßig nach Skript-Rollouts und nach Migrationen zwischen Tenants auf. Der zweite ist der Rest eines Pilotbetriebs, den niemand abgeräumt hat.

Die Prüfung besteht darin, jede Policy gegen ihre Regel zu halten – hier am Beispiel Safe Links, für die übrigen Typen identisch mit Get-HostedContentFilterRule, Get-AntiPhishRule, Get-MalwareFilterRule, Get-SafeAttachmentRule und Get-HostedOutboundSpamFilterRule:

```
Get-SafeLinksPolicy | ForEach-Object {
    $n = $_.Name
    $r = Get-SafeLinksRule | Where-Object { $_.SafeLinksPolicy -eq $n }
    [pscustomobject]@{
        Policy = $n
        Regel  = $r.Name
        Status = $r.State
        Prio   = $r.Priority
    }
} | Format-Table -AutoSize
```

Eine leere Spalte Regel bedeutet: verwaiste Policy. Status = Disabled bedeutet: stillgelegt.

Für die Bewertung folgt daraus eine wichtige Regel, die auch das Audit-Skript anwendet: **Eine Richtlinie, die auf niemanden angewendet wird, kann keinen Mangel darstellen.** Ihre Werte gegen die Baseline zu prüfen, erzeugt nur Rauschen – im schlimmsten Fall zwanzig kritische Befunde für eine Policy, die seit zwei Jahren nichts tut. Das Skript weist solche Objekte deshalb im Abschnitt **Policy-Inventar** (INV-*) mit ihrem Status aus und bewertet sie als *Info* statt als Mangel.

Die Entscheidung im Assessment ist dann eine von dreien: reaktivieren (Enable-SafeLinksRule), löschen (Remove-SafeLinksPolicy) oder bewusst stehen lassen und **im Übergabedokument als stillgelegt vermerken**. Nur die dritte Variante darf ohne Änderung bleiben – undokumentiert ist sie beim nächsten Assessment wieder ein Befund.

Der Configuration Analyzer aus PRE-04 findet mit -IsAppliedToDisabled einen Teil dieser Fälle ebenfalls. Er ersetzt die Inventur aber nicht, weil er verwaiste Policies ohne Rule nicht in jedem Fall meldet.

Anti-Spam eingehend

Die Anti-Spam-Policy steuert vier Verdicts – Spam, High confidence spam, Phishing und Bulk – mit vier getrennten Aktionen und vier getrennten Quarantäne-Policies. Sie ist der häufigste Ort für Fehlkonfigurationen, weil die Default-Policy an mehreren Stellen schwächer ist, als man erwarten würde.

Die Werte im Überblick

ID	Einstellung	Parameter	MS Default	MS Standard	MS Strict	Soll hier
ASI-01	Bulk-Schwellwert	BulkThreshold	7	6	5	6
ASI-02	Spam	SpamAction	MoveToJmf	MoveToJmf	Quarantine	MoveToJmf
ASI-03	High confidence spam	HighConfidenceSpamAction	MoveToJmf	Quarantine	Quarantine	Quarantine
ASI-04	Phishing	PhishSpamAction	MoveToJmf	Quarantine	Quarantine	Quarantine
ASI-05	High confidence phishing	HighConfidencePhishAction	Quarantine	Quarantine	Quarantine	Quarantine
ASI-06	Bulk	BulkSpamAction	MoveToJmf	MoveToJmf	Quarantine	MoveToJmf
ASI-07	Safety Tips	InlineSafetyTipsEnabled	\$true	\$true	true**	
ASI-08	ZAP	SpamZapEnabled / PhishZapEnabled	\$true	\$true	\$true	beide \$true
ASI-09	Quarantäne-Aufbewahrung	QuarantineRetentionPeriod	15	30	30	30

ASI-01 Bulk-Schwellwert

Was der Wert bedeutet. Der Bulk Complaint Level beschreibt, wie viele Beschwerden ein Massenversender auf sich zieht. 0 heißt: kein Bulk-Sender. 1 bis 3 heißt: wenige Beschwerden. 4 bis 7 heißt: gemischtes Bild. 8 und 9 heißt: viele Beschwerden. Der Schwellwert legt fest, ab welchem BCL die konfigurierte Bulk-Aktion greift – und zwar nach der Regel „größer oder gleich“.

Die Empfehlung von 2023: 6 statt 7. Sie deckt sich exakt mit dem, was Microsoft heute im Standard-Preset vorgibt. Die Herleitung ist unverändert schlüssig: Der Default 7 lässt die untere Hälfte des Bereichs „gemischte Beschwerdezahl“ durch. Genau dort sitzen die Newsletter, die niemand bewusst abonniert hat, die Fachverlags-Mailings und die Kongresseinladungen – Nachrichten, die technisch legitim, aber praktisch unerwünscht sind.

Bewertung 2026: weiterhin empfehlenswert, unverändert. Der Schritt auf 5 (Strict) ist möglich, sollte aber gemessen und nicht geraten werden. Vor der Umstellung im Threat Explorer prüfen, wie viel Volumen zwischen BCL 5 und 6 liegt.

```
Get-HostedContentFilterPolicy | Format-Table Name,BulkThreshold,MarkAsSpamBulkMail
Set-HostedContentFilterPolicy -Identity "Default" -BulkThreshold 6
```

Fallstrick. Der Parameter `MarkAsSpamBulkMail` (nur per PowerShell erreichbar, kein UI) muss auf `on` stehen. Steht er auf `off`, ist die Bulk-Behandlung faktisch abgeschaltet und der Schwellwert wirkungslos.

Neu und optional: `BulkMovesEnabled`. Seit 2026 gibt es in der Vorschau die Möglichkeit, Bulk-Mail **unterhalb** der Schwelle in den Ordner *Promotions* zu leiten statt in den Posteingang. Voraussetzung ist eine Transportregel, die den Header `X-MS-Exchange-Organization-BulkStamping: 1` setzt. Werte: `On`, `Off`, `NotSet` (Default). Interessant für Kunden, die über Newsletter-Flut klagen, aber Preview – im Kundenprojekt entsprechend kennzeichnen.

ASI-02 bis ASI-06 Die vier Aktionen

Die gültigen Werte. `SpamAction`, `HighConfidenceSpamAction` und `PhishSpamAction` akzeptieren `AddXHeader`, `Delete`, `ModifySubject`, `MoveToJmf`, `Quarantine` und `Redirect`. `BulkSpamAction` zusätzlich `NoAction`. `HighConfidencePhishAction` ist der Sonderfall: Es kennt **nur** `Quarantine` und `Redirect` – die Option „in den Junk-Ordner“ wurde für High confidence phishing entfernt.

`Delete` löscht ohne Benachrichtigung an den Absender. In einem Hardening-Standard hat der Wert nichts verloren – ein False Positive ist damit unwiederbringlich weg, ohne dass irgendjemand davon erfährt.

Der wichtigste Befund beim Kunden. Die Default-Policy steht bei `PhishSpamAction` auf `MoveToJmf`. Als Phishing erkannte Nachrichten landen also im Junk-Ordner des Nutzers, wo er sie öffnen und die Links anklicken kann. Beide Presets setzen hier `Quarantine`. Das ist regelmäßig der größte Einzelgewinn eines Hardenings und sollte in der Checkliste, wenn er vorgefunden wird, als **kritisch** bewertet werden.

Zur Empfehlung von 2023 „High confidence Spam in Admin-Quarantäne, keine Benachrichtigung“. Technisch umsetzbar über `-HighConfidenceSpamQuarantineTag` `AdminOnlyAccessPolicy`. Sie ist strenger als der Microsoft-Standard, der `DefaultFullAccessWithNotificationPolicy` vorsieht – also Quarantäne mit Benachrichtigung und Selbstfreigabe durch den Nutzer.

Die Abwägung ist keine Sicherheitsfrage, sondern eine Betriebsfrage: Bei Admin-only landet **jeder** False Positive beim Administrator. Je nach Branche und Mailvolumen sind das regelmäßige Freigabeanfragen. Wo eine besetzte IT das leisten kann und will, ist die strengere Variante die sicherere. Wo nicht, ist sie der Grund, warum das Hardening nach vier Wochen zurückgedreht wird. Das gehört mit dem Kunden besprochen und in der Checkliste unter „Notizen“ dokumentiert.

Bei High confidence phishing ist die Frage dagegen entschieden: Dort setzen Default, Standard und Strict übereinstimmend AdminOnlyAccessPolicy. Die Empfehlung von 2023 deckt sich hier vollständig mit Microsoft.

```
Set-HostedContentFilterPolicy -Identity "Default" `
    -SpamAction MoveToJmf `
    -HighConfidenceSpamAction Quarantine -HighConfidenceSpamQuarantineTag
DefaultFullAccessWithNotificationPolicy `
    -PhishSpamAction Quarantine -PhishQuarantineTag
DefaultFullAccessWithNotificationPolicy `
    -HighConfidencePhishAction Quarantine -HighConfidencePhishQuarantineTag
AdminOnlyAccessPolicy `
    -BulkSpamAction MoveToJmf
```

ASI-07 Safety Tips

InlineSafetyTipsEnabled blendet einen farbigen Hinweisbalken über verdächtigen Nachrichten ein. Default, Standard und Strict setzen alle \$true. Es gibt keinen Grund, das abzuschalten. In der Checkliste als reiner Verifikationspunkt.

ASI-08 Zero-hour Auto Purge

Was ZAP macht. Es entfernt Nachrichten nachträglich aus bereits zugestellten Postfächern, wenn sich das Verdict im Nachhinein ändert. Der Angriffsfall, gegen den es hilft: Eine Kampagne wird zugestellt, bevor die Erkennungsmodelle sie kennen, und ist eine Stunde später als Phishing klassifiziert. Ohne ZAP liegt sie weiter im Posteingang.

Die Änderung, die Altskripte bricht. Der Sammelparameter ZapEnabled existiert in Set-HostedContentFilterPolicy nicht mehr. An seine Stelle sind zwei getrennte Parameter getreten:

```
Get-HostedContentFilterPolicy | Format-Table Name,SpamZapEnabled,PhishZapEnabled
Set-HostedContentFilterPolicy -Identity "Default" -SpamZapEnabled $true -PhishZapEnabled $true
```

Malware-ZAP wird nicht hier gesteuert, sondern in der Anti-Malware-Policy (AMW-02) – dort heißt der Parameter weiterhin ZapEnabled.

Grenzen von ZAP, die man kennen sollte. ZAP wirkt nur auf Exchange-Online-Postfächer. Nachrichten, die der Nutzer bereits in einen lokalen PST-Ordner verschoben oder über POP3 abgerufen hat, sind außerhalb der Reichweite. Und Outlook-Safe-Senders-Einträge stören ZAP – ein weiteres Argument gegen diesen Ausnahmeweg.

ASI-09 Quarantäne-Aufbewahrung

Der Default liegt bei 15 Tagen, beide Presets setzen 30. Das Maximum ist 30 Tage – längere Aufbewahrung ist in EOP nicht vorgesehen.

```
Set-HostedContentFilterPolicy -Identity "Default" -QuarantineRetentionPeriod 30
```

Zwei Details, die im Betrieb relevant werden: Der Wert wirkt **auch** auf Nachrichten, die die Anti-Phishing-Policy quarantäniert hat (Spoof, Impersonation). Und er wirkt **nicht** auf Anti-Malware und Safe Attachments – die stehen fix auf 30 Tagen und sind nicht konfigurierbar.

Warum 30 statt 15 sinnvoll ist: Ein Nutzer im dreiwöchigen Urlaub findet bei 15 Tagen nichts mehr vor. Die Quarantäne ist dann nicht nur nutzlos, sondern erzeugt aktiv Misstrauen gegen die Maßnahme.

ASI-10 Allow-Listen in der Anti-Spam-Policy

Empfehlung: leer. Die vier Listen `AllowedSenders`, `AllowedSenderDomains`, `BlockedSenders` und `BlockedSenderDomains` sind das schwächste Glied in der Ausnahmekette (siehe Kapitel „Ausnahmen sind nicht gleich Ausnahmen“).

Was technisch passiert: Ein Treffer in `AllowedSenders` oder `AllowedSenderDomains` stempelt die Nachricht mit `sfv:SKA` und **SCL -1**. Übersprungen werden Spam-, Spoof- und Phishing-Prüfung sowie die Absenderauthentifizierung über SPF, DKIM und DMARC. Nicht übersprungen werden Malware und High confidence phishing. Microsoft schreibt in der Cmdlet-Referenz wörtlich: „*Think very carefully before you add domains here.*“

Der Angriffsweg ist trivial: Steht die Domäne des Steuerberaters auf der Liste, reicht es, den Absender zu spoofen – die Nachricht geht durch, weil die Prüfung, die den Spoof erkannt hätte, gerade übersprungen wurde.

Für die **eigenen** Accepted Domains gilt das seit September 2022 nicht mehr uneingeschränkt. Microsoft wörtlich: „*As of September 2022, allowed senders, domains, or subdomains in your organization's accepted domains must pass email authentication checks to skip spam filtering.*“ Ein Eintrag der eigenen Domäne ist also weniger gefährlich als früher – bei fremden Domänen bleibt die Aussage unverändert gültig.

```
Get-HostedContentFilterPolicy | Format-List  
Name,AllowedSenders,AllowedSenderDomains,BlockedSenders,BlockedSenderDomains  
Set-HostedContentFilterPolicy -Identity "Default" -AllowedSenderDomains @{}
```

Was das Ursprungsdokument dazu sagt. Es führt „Whitelisting: sender based, domain based“ als Anforderung auf und ordnet es korrekt der Anti-Spam-Policy zu. Die Anforderung bleibt richtig – nur der Umsetzungsort hat sich verschoben. Ausnahmen gehören 2026 in die Tenant Allow/Block List (TABL-01).

`BlockedSenderDomains` ist weniger problematisch und hat sogar einen legitimen Einsatzzweck: Ein TABL-Block erzeugt das Verdict *High confidence phishing* und blockiert auch den ausgehenden Verkehr an diese Adresse. Wer nur „diese Domäne soll als Spam behandelt werden“ will, ist mit der Blocked-Senders-Liste besser bedient.

ASI-11 Sprach- und Länderfilter

Das Ursprungsdokument führt „Blacklisting: country based / language based“ als vorhandene Funktion auf, ohne sie zu empfehlen. Das ist die richtige Zurückhaltung.

Microsofts Position ist bemerkenswert neutral: „*We have no specific recommendation for this setting.*“ Keine Warnung, aber auch keine Empfehlung – und in keinem Preset aktiviert.

Die sachlichen Einwände: Die Sprache wird aus dem Nachrichteninhalt geraten, das Land aus der Quell-IP. Beides ist für einen Angreifer trivial zu umgehen, während legitime Kommunikation zuverlässig getroffen wird – der Kunde mit Lieferanten in Polen oder der Tochtergesellschaft in der Türkei merkt das sofort. Der Filter erzeugt also viel Reibung bei geringem Schutzgewinn.

Wo es trotzdem sinnvoll sein kann: als befristete Maßnahme während einer laufenden Kampagne aus einer klar abgegrenzten Region, mit vorheriger Messung im Threat Explorer.

```
Get-HostedContentFilterPolicy | Format-List
Name, EnableLanguageBlockList, LanguageBlockList, EnableRegionBlockList, RegionBlockList
Set-HostedContentFilterPolicy -Identity "Default" -EnableRegionBlockList $false -
EnableLanguageBlockList $false
```

Wichtig: Diese Filter sind **nicht** Teil von ASF, auch wenn sie im Portal daneben stehen. Sie sind aber ebenfalls nur in Custom-Policies erreichbar, nicht in Presets.

ASI-12 Interne Nachrichten filtern

Neu gegenüber dem Ursprungsdokument. `IntraOrgFilterState` legt fest, wie streng Nachrichten zwischen internen Absendern und Empfängern geprüft werden. Gültige Werte: `Default`, `HighConfidencePhish`, `Phish`, `HighConfidenceSpam`, `Spam`, `Disabled`. Der Default entspricht `HighConfidencePhish`.

Der Anwendungsfall ist die laterale Ausbreitung: Ein kompromittiertes internes Konto verschickt Phishing an Kollegen. Diese Nachrichten sind technisch intern und laufen an den meisten externen Prüfungen vorbei.

Soll-Wert in diesem Standard ist `Default`. Eine Verschärfung auf `Phish` ist möglich, gehört aber nicht in die Baseline: interne Serienmails, Ticketsysteme und Monitoring-Benachrichtigungen erzeugen dann schnell Fehlalarme. Als bewusste Abweichung nach vorheriger Messung vertretbar.

Advanced Spam Filter (ASF)

Das Ursprungsdokument listet die ASF-Features vollständig auf – die vier Score-Erhöher und die elf Features, die eine Nachricht direkt als Spam klassifizieren. Es spricht keine Aktivierungsempfehlung aus, stellt aber bei „SPF record: hard fail“ eine Frage, die 2023 offen bleiben musste:

„Hierin eben auch: SPF Hard-Fail als Option ⇒ Klassifizierung als Spam! Aber in Anti-Phishing: Unauthenticated E-Mail is junked! Das Spam-Feature ist also nicht mehr benötigt?“

Diese Frage ist inzwischen von Microsoft selbst beantwortet – und zwar genau so, wie sie im Dokument vermutet wurde.

Der Gesamtbefund

Alle ASF-Settings existieren 2026 noch. Es gibt keine formale Deprecation, weder auf der Feature-Seite noch in der Cmdlet-Referenz. Sie werden lediglich inhaltlich nicht empfohlen.

Zwei Sätze von Microsoft geben die Richtung vor:

„Enabling one or more of the ASF settings is an aggressive approach to spam filtering. You can't report messages that are filtered by ASF as false positives to Microsoft.“

„ASF settings aren't enabled in Standard or Strict preset security policies.“

Der zweite Satz ist das eigentliche Argument. Wer ASF aktiviert, braucht dafür eine Custom-Policy – und schneidet die betroffenen Empfänger damit von den Presets ab. Der erste Satz ist das betriebliche Argument: Ein ASF-Treffer lässt sich nicht als Fehlalarm melden. Damit fehlt der Rückkanal, über den sich die Erkennung sonst verbessert.

ASF-01 und ASF-02 Die Score- und Klassifizierungsfeatures

Kategorie	Parameter	Wirkung bei on
Score erhöhen	IncreaseScoreWithImageLinks	SCL 5/6 (Spam)
Score erhöhen	IncreaseScoreWithNumericIps	SCL 5/6
Score erhöhen	IncreaseScoreWithRedirectToOtherPort	SCL 5/6
Score erhöhen	IncreaseScoreWithBizOrInfoUrls	SCL 5/6
Als Spam markieren	MarkAsSpamEmptyMessages	SCL 9 (High confidence spam)
Als Spam markieren	MarkAsSpamEmbedTagsInHtml	SCL 9
Als Spam markieren	MarkAsSpamJavaScriptInHtml	SCL 9
Als Spam markieren	MarkAsSpamFormTagsInHtml	SCL 9
Als Spam markieren	MarkAsSpamFramesInHtml	SCL 9

Kategorie	Parameter	Wirkung bei on
Als Spam markieren	MarkAsSpamWebBugsInHtml	SCL 9
Als Spam markieren	MarkAsSpamObjectTagsInHtml	SCL 9
Als Spam markieren	MarkAsSpamSensitiveWordList	SCL 9

Alle zwölf akzeptieren off (Default), on und Test. Für die drei Features aus ASF-03 und ASF-04 – SPF-Hardfail, Sender ID und Backscatter – gibt es dagegen **keinen Test-Modus**; sie kennen nur off und on.

Der praktische Einwand gegen die zweite Gruppe: Sie setzt SCL 9 – die härteste Spam-Einstufung. Ein Newsletter mit Tracking-Pixel löst MarkAsSpamWebBugsInHtml aus, ein eingebettetes Umfrageformular MarkAsSpamFormTagsInHtml. Beides ist in kommerzieller E-Mail vollkommen üblich. Das Ergebnis ist eine hohe Zahl von Fehlalarmen bei Nachrichten, die der Kunde bewusst abonniert hat – und die man nicht melden kann.

Ein weiterer Fallstrick, der beim Troubleshooting Zeit kostet: ASF stempelt die x-CustomSpam:-Header **nach** der Verarbeitung durch Transportregeln. Eine Transportregel kann einen ASF-Treffer also nicht auswerten. Nur Posteingangsregeln im Client funktionieren.

ASF-03 SPF Hard Fail – die offene Frage von 2023

Microsofts Antwort, wörtlich aus der Anti-Spoofing-FAQ:

„Do I still need to enable the Advanced Spam Filter setting ‘SPF record: hard fail’ if I enable anti-spoofing?“ „No. This ASF setting is no longer required. Anti-spoofing protection considers both SPF hard fails and a wider set of criteria. If you have anti-spoofing enabled and the SPF record: hard fail turned on, you’ll probably get more false positives.“

Und an anderer Stelle noch deutlicher:

„We recommend that you disable this feature as it provides almost no additional benefit for detecting spam or phishing messages, and would instead generate mostly false positives.“

Bewertung. Die Vermutung im Ursprungsdokument war richtig. Der Grund dahinter ist die Composite Authentication: EOP bewertet SPF, DKIM, DMARC, Absenderreputation und Verhaltensmuster gemeinsam. Ein isolierter SPF-Hardfail ist in dieser Gesamtbewertung ein Datenpunkt unter vielen – und für sich genommen ein schlechter, weil er bei jeder Weiterleitung und jeder Mailingliste auftritt.

Set-HostedContentFilterPolicy -Identity "Default" -MarkAsSpamSpfRecordHardFail Off

ASF-04 Sender ID und Backscatter

Namenskorrektur. Das Portal-Label lautet „Conditional Sender ID filtering: hard fail“. Der PowerShell-Parameter heißt MarkAsSpamFromAddressAuthFail. Ein Parameter namens

MarkAsSpamSenderIdHardFail existiert nicht – wer ihn in einem Skript verwendet, bekommt einen Fehler.

Sender ID ist ein von Microsoft entwickeltes Verfahren, das faktisch von SPF und DMARC abgelöst wurde. Für MarkAsSpamNdrBackscatter gilt dasselbe Argument wie für den SPF-Hardfail: Backscatter (Unzustellbarkeitsmeldungen auf gefälschte Absender) wird von der regulären Filterung erkannt.

Anmerkung zur Ehrlichkeit: Für diese beiden Parameter gibt es **keine** so ausdrückliche Microsoft-Aussage wie beim SPF-Hardfail. Die Empfehlung, sie aus zu lassen, ist hier eine Ableitung – begründet, aber nicht zitierbar.

```
Set-HostedContentFilterPolicy -Identity "Default" -MarkAsSpamFromAddressAuthFail Off -  
MarkAsSpamNdrBackscatter Off
```

ASF-05 Test-Modus

Falls ein Kunde ASF trotz allem erproben will, ist das der einzig vertretbare Weg: Die gewünschten Settings auf Test stellen und TestModeAction auf AddXHeader. Der Vorbehalt aus ASF-03 und ASF-04 gilt: Für SPF-Hardfail, Sender ID und Backscatter existiert kein Test-Modus – diese drei lassen sich nur scharf oder gar nicht schalten. Dann wird nichts gefiltert, aber jede Nachricht, die getroffen worden wäre, bekommt einen Header. Nach zwei Wochen lässt sich im Message Trace auszählen, wie viel legitime Post betroffen gewesen wäre.

TestModeAction gilt **global** für alle auf Test gesetzten Settings – unterschiedliche Test-Aktionen je Setting sind nicht möglich. Gültige Werte: None (Default), AddXHeader, BccMessage.

Connection Filter

Der Connection Filter arbeitet auf IP-Ebene, noch vor der Inhaltsfilterung. Es gibt genau **eine** Policy mit dem Identity-Namen `Default`; weitere lassen sich nicht anlegen. Er ist **nicht** Teil der Preset Security Policies – Microsoft veröffentlicht dafür entsprechend keine Standard- oder Strict-Werte.

CF-01 IP Allow List

Die Empfehlung von 2023: „wo benötigt, aber Vorsicht.“ Diese Vorsicht ist vollständig berechtigt und verdient 2026 eine noch deutlichere Formulierung.

Was technisch passiert. Microsoft wörtlich: „*Messages from the IP addresses you specify aren't identified as spam, despite any other spam characteristics of the messages.*“ Die Nachricht bekommt SCL -1. Übersprungen werden: Spam, Phishing, Bulk und Spoof-Erkennung. **Nicht** übersprungen werden Malware und High confidence phishing – „*All incoming messages are scanned for malware and high confidence phishing, regardless of whether the message source is in the IP Allow List.*“

Warum das riskant ist. Der typische Grund für einen Eintrag ist ein Dienstleister oder ein vorgelagertes System, dessen Mails „durchgehen sollen“. Sobald dieser Host kompromittiert oder als offenes Relay missbraucht wird, ist er ein ungefilterter Zustellweg in den Tenant. Und in der Rangfolge der Allow-Methoden steht die IP Allow List bei Microsoft auf Platz vier von fünf.

Zwei dokumentierte Fälle, in denen die Liste gar nicht wirkt – wichtig fürs Troubleshooting:

1. Die IP steht zusätzlich in einem On-Premises-Inbound-Connector und beide Organisationen liegen im selben Microsoft-Datacenter-Forest. Header zeigt `IPV:CAL`, gefiltert wird trotzdem.
2. Die Organisation und der erste erreichte Microsoft-365-Server liegen in unterschiedlichen Forests. Dann fehlt der `IPV:CAL`-Header ganz.

Microsofts eigener Workaround dafür ist eine Transportregel mit „Set SCL to Bypass spam filtering“ – also die noch gröbere Variante. Auch das spricht dafür, den Bedarf lieber anders zu lösen.

Grenzwerte. Maximal 1.273 Einträge. CIDR nur von /24 bis /32; für /1 bis /23 ist eine Transportregel nötig. IPv6 wird nicht unterstützt – dafür gibt es die Tenant Allow/Block List.

```
Get-HostedConnectionFilterPolicy -Identity Default | Format-List
IPAllowList,IPBlockList,EnableSafeList
Set-HostedConnectionFilterPolicy -Identity Default -IPAllowList @{}
```

CF-02 IP Block List

Hier ist der Connection Filter das richtige Werkzeug: **IPv4-Blocks gehören hierher**, nicht in die Tenant Allow/Block List, die für IP-Einträge ausschließlich IPv6 unterstützt.

Nachrichten von blockierten IPs werden abgewiesen, nicht als Spam markiert. Die IP Allow List hat dabei Vorrang – eine IP auf beiden Listen wird nicht blockiert.

Troubleshooting-Falle, die regelmäßig Zeit kostet: Vom Connection Filter blockierte Nachrichten erscheinen **nicht** im Message Trace. Wenn ein Absender meldet „meine Mails kommen nicht an“ und der Message Trace nichts zeigt, ist die IP Block List einer der ersten Orte zum Nachsehen.

```
Set-HostedConnectionFilterPolicy -Identity Default -IPBlockList @{Add="203.0.113.10"}
```

CF-03 Safe List

`EnableSafeList` aktiviert eine von Microsoft gepflegte dynamische Liste vertrauenswürdiger Mailserver, gespeist aus Drittanbieter-Listen. Der Kunde kann sie weder einsehen noch beeinflussen – nur ein- oder ausschalten. Bei aktiviert wird die Spam-Filterung für Nachrichten von diesen Servern übersprungen.

Die Dokumentationslage ist widersprüchlich: Der Konfigurationsartikel beschreibt es als reguläres Feature mit UI-Checkbox, die Cmdlet-Referenz kennzeichnet denselben Parameter als „*reserved for internal Microsoft use*“. Eine Empfehlung dafür oder dagegen gibt Microsoft nicht ab.

Bewertung für diesen Standard: auf `$false` belassen (Default). Ein pauschaler Filter-Skip für eine nicht einsehbare Serverliste ist mit dem Grundsatz, jeden Bypass dokumentieren zu können, nicht vereinbar. Die widersprüchliche Kennzeichnung ist ein zusätzliches Argument.

Anti-Spam ausgehend

Der ausgehende Schutz ist der am häufigsten unterschätzte Teil von EOP. Er richtet sich nicht gegen Angreifer von außen, sondern gegen die Folgen eines kompromittierten Kontos im eigenen Tenant – und gegen den Reputationsschaden, den ein solcher Vorfall hinterlässt.

ASO-01 Default-Policy oder eigene Policy?

Die Empfehlung von 2023: „eigene erstellen.“ Der Gedanke dahinter ist nachvollziehbar – eine eigene Policy ist benennbar, dokumentierbar und lässt sich gezielt einem Empfängerkreis zuweisen.

Was dagegen spricht. Microsoft dokumentiert eine Einschränkung, die genau diesen Weg untergräbt: *„This setting works only in the default outbound spam policy. It doesn't work in custom outbound spam policies that you create.“* – gemeint ist `BccSuspiciousOutboundMail`. Wer alle Einstellungen in eine eigene Policy verlagert, verliert diese Funktion still.

Empfehlung 2026. Grenzwerte und Aktion in der **Default-Policy** setzen. Eigene Policies nur dort, wo ein abweichender Bedarf existiert – etwa ein dediziertes Versandpostfach für Rechnungen, das höhere Limits braucht.

Betriebliche Besonderheiten der Default-Policy: Sie hat keine zugehörige Rule, ihre Priorität ist fest auf „Lowest“ und sie lässt sich nicht deaktivieren. `Set-HostedOutboundSpamFilterPolicy` hat keinen `-Name-Parameter` – umbenennen geht nur über die Rule, die es bei der Default-Policy nicht gibt.

ASO-02 Empfänger-Limits

Die Empfehlung von 2023: maximal 200 pro Tag. Das ist deutlich strenger als alles, was Microsoft vorsieht – Strict setzt 800 pro Tag.

Herleitung der ursprünglichen Empfehlung. Ein normaler Büroarbeitsplatz verschickt selten mehr als 100 Empfänger am Tag. Wer 200 erreicht, tut mit hoher Wahrscheinlichkeit etwas Ungewöhnliches – und ein kompromittiertes Konto, das für Spam-Versand missbraucht wird, erreicht diesen Wert in Minuten. Ein niedriges Limit ist damit ein sehr wirksamer Frühindikator.

Warum die Empfehlung trotzdem nicht ungeprüft übernommen werden sollte. In jedem Tenant gibt es Konten, die legitim deutlich mehr verschicken: das Postfach, aus dem Rechnungen versendet werden, die Personalabteilung mit Bewerbungsabsagen, der Vertrieb mit Terminserien, das Ticketsystem, der Rechnungsdrucker. Ein Limit von 200 sperrt genau diese Konten – und zwar mit `BlockUser` bis zur manuellen Freigabe.

Empfehlung für diesen Standard. Mit den Microsoft-Standard-Werten starten (500 extern pro Stunde, 1000 intern pro Stunde, 1000 pro Tag), das tatsächliche Spitzenvolumen über zwei Wochen messen und **danach** bewusst absenken. Wo im

Tenant nachweislich kein legitimer Serienversand stattfindet, ist 200 eine gute Zahl – dann aber als dokumentierte Abweichung mit Begründung.

Parameter	Wertebereich	Default	Standard	Strict
RecipientLimitExternalPerHour	0–10000	0	500	400
RecipientLimitInternalPerHour	0–10000	0	1000	800
RecipientLimitPerDay	0–10000	0	1000	800

Der Wert 0 bedeutet: Es gelten die Service-Defaults. Werte oberhalb der harten Service-Limits haben keine Wirkung – die Policy-Limits können nur enger sein, nie weiter.

```
Set-HostedOutboundSpamFilterPolicy -Identity "Default" `
  -RecipientLimitExternalPerHour 500 -RecipientLimitInternalPerHour 1000 -
  RecipientLimitPerDay 1000
```

ASO-03 Aktion bei Limitüberschreitung

Die Empfehlung von 2023: „Send Admin-Alert.“ Damit ist der Wert `Alert` gemeint – nur benachrichtigen, nicht sperren.

Bewertung 2026: hier weicht der Standard bewusst ab. Beide Presets setzen `BlockUser`. Der Unterschied ist im Ernstfall erheblich:

Wert	Verhalten
<code>Alert</code>	Keine Aktion, nur Benachrichtigung. Das kompromittierte Konto verschickt weiter.
<code>BlockUserForToday</code>	Sperre bis zum Folgetag (UTC). Danach automatisch wieder frei.
<code>BlockUser</code>	Sperre bis zur manuellen Admin-Freigabe . Der Nutzer erscheint unter <i>Restricted users</i> .

Andere Werte gibt es nicht. `BlockUserForever` und `AlertOnly` existieren nicht, auch wenn sie in Drittquellen auftauchen.

Ein `Alert`, der um 3 Uhr nachts ausgelöst wird und den niemand liest, verhindert nichts. `BlockUser` stoppt den Versand sofort. Der Preis ist ein möglicher Fehlalarm mit gesperrtem Konto – deshalb gehört ASO-02 (realistische Limits) zwingend dazu.

```
Set-HostedOutboundSpamFilterPolicy -Identity "Default" -ActionWhenThresholdReached
BlockUser
```

Freigabe erfolgt unter <https://security.microsoft.com/restrictedusers>. Nach der Freigabe wird der Nutzer am selben Tag nicht erneut gesperrt.

ASO-04 Automatische externe Weiterleitungen

Dieser Punkt fehlt im Ursprungsdokument vollständig. Er gehört in jedes Hardening, weil er den häufigsten Weg nach einer Kontokompromittierung schließt.

Der Angriffsablauf, gegen den er schützt. Ein Angreifer erlangt Zugang zu einem Postfach. Statt sofort aufzufallen, richtet er eine Posteingangsregel ein, die eine Kopie jeder eingehenden Nachricht an eine externe Adresse weiterleitet – oder setzt ein Mailbox-Forwarding. Der Zugang kann danach verloren gehen, der Datenabfluss läuft weiter. In vielen Fällen bleibt das monatelang unentdeckt, weil die Regel für den Nutzer unsichtbar ist.

Der Schalter. `AutoForwardingMode` mit den Werten `Automatic`, `On` und `Off`.

Die Bezeichnung ist unglücklich gewählt: **Automatic ist gleichbedeutend mit off.** Microsoft schreibt wörtlich: „*The value Automatic - System-controlled is equivalent to Off - Forwarding is disabled.*” Historisch war `Automatic` einmal das Gegenteil und wurde im Zuge von „secure by default” umgestellt.

Default, Standard und Strict setzen alle `Automatic`. Der Prüfpunkt ist also nicht „einschalten”, sondern **„verifizieren, dass es niemand auf on gestellt hat”** – was in der Praxis regelmäßig vorkommt, weil eine einzelne Anforderung („Herr Meier braucht eine Weiterleitung auf sein privates Postfach”) tenantweit gelöst wurde.

```
Get-HostedOutboundSpamFilterPolicy | Format-Table Name,AutoForwardingMode
Set-HostedOutboundSpamFilterPolicy -Identity "Default" -AutoForwardingMode Automatic
```

Wichtige Details. Die Sperre erfasst Posteingangsregeln **und** Mailbox-Forwarding an externe Adressen. Weiterleitungen zwischen internen Nutzern sind nicht betroffen. Das NDR-Verhalten ist uneinheitlich: Bei Nachrichten externer Absender wird für alle Weiterleitungsmethoden ein NDR erzeugt, bei internen Absendern nur beim Mailbox-Forwarding – nicht bei Posteingangsregeln. Der Nutzer merkt also unter Umständen nicht, dass seine Regel nicht mehr greift.

Ausnahmen richtig lösen. Nicht die Default-Policy auf `on` stellen, sondern eine eigene Outbound-Policy mit `-AutoForwardingMode On` anlegen und über die zugehörige Rule eng auf die betroffenen Postfächer scopen.

Ergänzend lohnt eine regelmäßige Suche nach bestehenden Weiterleitungen:

```
Get-Mailbox -ResultSize Unlimited |
    Where-Object { $_.ForwardingSmtpAddress -or $_.ForwardingAddress } |
    Select-Object
    DisplayName,ForwardingSmtpAddress,ForwardingAddress,DeliverToMailboxAndForward
```

ASO-05 Benachrichtigungen – ein dokumentierter Zielkonflikt

Die Empfehlung von 2023 „Send Admin-Alert” zielt auf `NotifyOutboundSpam` und `BccSuspiciousOutboundMail`. Hier gibt es eine Besonderheit, die man dem Kunden erklären können sollte, weil sie sonst im Secure Score auffällt.

Microsofts Position. `NotifyOutboundSpam` ist „*in the process of being deprecated from outbound spam policies.*“ Stattdessen soll die eingebaute Alert Policy „**User restricted from sending email**“ verwendet werden, die bereits Benachrichtigungen an die Mitglieder der Gruppe `TenantAdmins` verschickt.

Der Konflikt. Die Secure-Score-Empfehlung „*Ensure Exchange Online Spam Policies are set to notify administrators*“ verlangt genau die Einstellung, die Microsoft in der Outbound-Spam-Policy gerade abkündigt. Wer den Presets folgt (beide setzen `$false`), verliert damit Secure-Score-Punkte. Wer dem Secure Score folgt, weicht von den Presets ab und nutzt eine abgekündigte Funktion.

Hinweis: Die Abkündigung von `NotifyOutboundSpam` ist wörtlich belegt. Ob Microsoft den Zielkonflikt an anderer Stelle selbst benennt, ließ sich nicht abschließend verifizieren – die Secure-Score-Empfehlung selbst existiert.

Empfehlung. Alert Policies pflegen (REP-02) und in der Checkliste unter „Notizen“ festhalten, dass der Secure-Score-Punkt bewusst nicht erfüllt wird. Wo der Kunde auf den Secure Score gemessen wird, ist die Aktivierung vertretbar – dann aber beides parallel, nicht statt.

ASO-06 Tenant External Recipient Rate Limit

2023 gab es das noch nicht. Seit 2025 begrenzt Microsoft die Zahl externer Empfänger, die eine gesamte Organisation pro Tag adressieren darf. Das Limit skaliert mit der Lizenzanzahl; Trial-Organisationen liegen bei 5.000 externen Empfängern pro Tag. Verteilergruppen zählen mit jedem einzelnen Mitglied – eine Nachricht an eine Gruppe mit 1.000 externen Empfängern verbraucht 1.000.

Der Fehlercode bei Überschreitung:

```
550 5.7.233 Your message can't be sent because your tenant exceeded its daily limit for sending email to external recipients (tenant external recipient rate limit).
```

Daneben gelten weiterhin die Service-Limits je Postfach: 10.000 Empfänger pro Tag (gleitendes 24-Stunden-Fenster), 30 Nachrichten pro Minute und 500 Empfänger je Nachricht (Default, über `Set-Mailbox -RecipientLimits` bis 1.000 konfigurierbar).

Die praktische Konsequenz für die Kundenberatung. Newsletter und Massenversand gehören nicht in Exchange Online. Das war schon vorher gute Praxis, ist jetzt aber eine harte technische Grenze. Kunden, die ihr Weihnachtsmailing über EXO verschicken, laufen dagegen – und der Ausfall trifft dann den regulären Geschäftsverkehr mit.

Anmerkung: Das ursprünglich angekündigte postfachbezogene External Recipient Rate Limit wurde von Microsoft wieder zurückgezogen. Geblieben ist das tenantweite Limit. Die genaue Berechnungsformel ist nicht öffentlich dokumentiert.

Anti-Phishing und Spoof-Schutz

Dieses Kapitel enthält die größte inhaltliche Veränderung gegenüber dem Ursprungsdokument. Der EOP-Teil der Anti-Phishing-Policy hat seit 2023 eine komplett neue Funktionsgruppe bekommen: die Durchsetzung fremder DMARC-Policies.

Was EOP kann und was Defender braucht

Diese Trennung ist die häufigste Ursache für falsche Erwartungen im Kundengespräch.

Funktionsgruppe	EOP	Defender P1/P2
Spoof Intelligence, AuthenticationFailAction	✓	✓
DMARC-Handling (HonorDmarcPolicy u. a.)	✓	✓
Unauthenticated-Sender-Symbol, via-Tag	✓	✓
First contact safety tip	✓	✓
Impersonation-Schutz (User, Domain)	x	✓
Mailbox Intelligence	x	✓
Phishing-Schwellwert	x	✓

Zwischen P1 und P2 unterscheidet die Anti-Phishing-Dokumentation **nicht** – alle Impersonation- und Threshold-Einstellungen sind ab P1 verfügbar. Die einzige P2-Abgrenzung in diesem Bereich ist Priority Account Protection (IMP-08).

Die Default-Policy heißt Office365 AntiPhish Default. Sie hat keinen Empfängerfilter, ihre Priorität ist fest, und der Name lässt sich nicht ändern – alle übrigen Einstellungen schon. Wichtig: In der Default-Policy sind Impersonation-Schutz und Phishing-Schwellwert **nicht vorkonfiguriert**. Wer diese Funktionen nutzen will, braucht eine Custom-Policy oder ein Preset.

APH-01 Spoof Intelligence

Die Empfehlung von 2023: „ein.“ Unverändert richtig. Microsoft: „*We recommend that you leave it turned on.*“ Abschalten kommt laut Dokumentation nur in Frage, „*if you have a domain that's protected by another email filtering service*“.

Die Änderung, die ältere Guides überholt. Bis vor kurzem galt: Spoof Intelligence aus bedeutet, der Spoof-Schutz ist aus. Das stimmt seit der Einführung des DMARC-Handlings nicht mehr:

„Disabling anti-spoofing protection only disables implicit spoofing protection from composite authentication checks.“

Mit anderen Worten: `EnableSpoofIntelligence $false` schaltet nur die **implizite** Prüfung ab – die heuristische Bewertung anhand der Composite Authentication. Die **explizite** Durchsetzung veröffentlichter DMARC-Policies über `HonorDmarcPolicy` läuft davon unabhängig weiter. Das sind zwei getrennte Schalter, die man auch getrennt bewerten muss.

Und ein Missverständnis, das Microsoft ausdrücklich ausräumt: *„You don’t need to disable anti-spoofing protection if your MX record doesn’t point to Microsoft 365; you enable Enhanced Filtering for Connectors instead.“* Wer bei einem Kunden mit vorgeschaltetem Gateway den Spoof-Schutz abschaltet, um Fehlalarme loszuwerden, behandelt das Symptom statt der Ursache – siehe EF-01.

APH-02 Aktion bei Spoof-Erkennung

Die Empfehlung von 2023: „Immer in Admin-Quarantäne, keine Benutzerbenachrichtigung.“

`AuthenticationFailAction` kennt nur zwei Werte: `MoveToJmf` und `Quarantine`. Der Default und das Standard-Preset setzen `MoveToJmf`, nur `Strict` setzt `Quarantine`. Die Empfehlung von 2023 liegt damit auf `Strict`-Niveau – technisch die stärkere Wahl.

Interessant ist der Blick auf die Deltas: Im gesamten Spoof-Block unterscheiden sich `Standard` und `Strict` in **genau zwei** Werten – `AuthenticationFailAction` und der zugehörigen Quarantäne-Policy. Alles andere ist identisch. Wer also den Spoof-Schutz auf `Strict`-Niveau haben will, muss nur diese beiden Werte ändern und braucht dafür kein `Strict`-Preset.

Der Parameter greift für Nachrichten von Absendern, die Spoof Intelligence automatisch blockiert hat, sowie für manuell in der TABL blockierte Spoof-Absender.

```
Set-AntiPhishPolicy -Identity "Office365 AntiPhish Default" `
  -AuthenticationFailAction Quarantine `
  -SpoofQuarantineTag DefaultFullAccessWithNotificationPolicy
```

Zur Quarantäne-Policy: `AdminOnlyAccessPolicy` entspricht der Empfehlung von 2023 („keine Benutzerbenachrichtigung“), `DefaultFullAccessWithNotificationPolicy` dem Microsoft-`Strict`-Wert. Dieselbe Abwägung wie bei ASI-03 – Sicherheit gegen Administrationsaufwand.

APH-03 bis APH-05 DMARC-Durchsetzung

Angekündigt im Juli 2023, ausgerollt ab 2024 – also unmittelbar nach Entstehung des Ursprungsdokuments und deshalb dort noch nicht enthalten.

Was die Funktion macht. Bis dahin hat EOP die DMARC-Policy einer fremden Absenderdomäne zwar ausgewertet, aber nur als einen Faktor unter vielen in die Gesamtbewertung einfließen lassen. Eine Domäne, die ausdrücklich `p=reject`

veröffentlicht hat – also „wenn die Authentifizierung fehlschlägt, weise die Nachricht ab“ –, konnte trotzdem im Junk-Ordner landen statt abgewiesen zu werden.

Mit HonorDmarcPolicy wird diese Anweisung tatsächlich umgesetzt.

Parameter	Gültige Werte	Default	Standard	Strict
HonorDmarcPolicy	\$true / \$false	\$true	\$true	\$true
DmarcQuarantineAction	MoveToJmf, Quarantine	Quarantine	Quarantine	Quarantine
DmarcRejectAction	Quarantine, Reject	Reject	Reject	Reject

Alle drei sind **EOP-Funktionen** und brauchen keine Defender-Lizenz.

Zwei Fallstricke bei den Enums: DmarcQuarantineAction kennt **kein** Reject, DmarcRejectAction kennt **kein** MoveToJmf. Die beiden Parameter haben unterschiedliche Wertemengen.

Sicherheitsnutzen. Der Schutz greift dort, wo die eigene Heuristik naturgemäß schwach ist: bei Absenderdomänen, mit denen der Kunde selten zu tun hat. Wenn die Hausbank p=reject veröffentlicht hat und jemand ihre Domäne fälscht, wird die Nachricht abgewiesen – ohne dass EOP die Bank kennen oder die Fälschung heuristisch erkennen müsste. Das ist eine deutliche Verbesserung gegenüber 2023.

Da Default, Standard und Strict identisch sind, gibt es hier keinen Härtungsspielraum. Der Prüfpunkt lautet: Hat es jemand abgeschaltet? Das kommt vor – meist als Reaktion auf Fehlalarme, deren eigentliche Ursache ein fehlendes Enhanced Filtering war.

Get-AntiPhishPolicy | [Format-List](#)
Name, HonorDmarcPolicy, DmarcQuarantineAction, DmarcRejectAction

Der kritische Fallstrick – bitte immer prüfen. Microsoft wörtlich:

„If the MX record for the Microsoft 365 domain points to a non-Microsoft service or device that sits in front of Microsoft 365, the Honor DMARC policy setting is applied only if Enhanced Filtering for Connectors is enabled for the connector that receives inbound messages.“

In einem Tenant mit vorgeschaltetem Secure Email Gateway ist die DMARC-Durchsetzung also **wirkungslos**, solange Enhanced Filtering nicht am Inbound-Connector aktiv ist. Der Kunde sieht die Einstellung auf \$true und hält sich für geschützt. Diese Kombination – DMARC-Handling an, Enhanced Filtering aus, Gateway davor – ist ein häufiger und gut versteckter Befund.

Empfehlung für die Einführungsphase. In den ersten Wochen DmarcRejectAction Quarantine statt Reject setzen. Der Unterschied: Bei Reject wird die Nachricht während der SMTP-Transaktion abgewiesen und ist nicht mehr wiederherstellbar. Bei Quarantine bleibt sie sichtbar und lässt sich im Zweifel freigeben. Nach zwei bis vier Wochen ohne Beanstandungen auf Reject wechseln.

Zusammenspiel mit Spoof Intelligence. Die vier Kombinationen im Überblick:

	Honor DMARC an	Honor DMARC aus
Spoof Intelligence an	Implizite Fehler → AuthenticationFailAction; explizite Fehler nach DMARC-Policy des Absenders	AuthenticationFailAction für alles; die veröffentlichte DMARC-Policy wird ignoriert
Spoof Intelligence aus	Keine impliziten Prüfungen; explizite Fehler weiterhin nach DMARC-Policy	Keine impliziten Prüfungen; p=quarantine und p=reject → AuthenticationFailAction

APH-06 und APH-07 Absender-Indikatoren

EnableUnauthenticatedSender ersetzt das Absenderbild durch ein Fragezeichen, wenn die Nachricht weder SPF noch DKIM besteht **und** auch DMARC beziehungsweise Composite Authentication nicht passiert.

EnableViaTag ergänzt die Absenderadresse um einen Hinweis, wenn die Domäne im From von der DKIM- oder MAIL-FROM-Domäne abweicht – etwa `chris@contoso.com via fabrikam.com`. Genau das ist das Muster, das ein Newsletter-Dienstleister erzeugt – und auch ein Angreifer, der über einen fremden Dienst versendet.

Beide stehen ab Werk auf `$true`. **Beide sind nur wirksam, solange Spoof Intelligence eingeschaltet ist** – ein weiteres Argument gegen APH-01 auf `$false`.

EnableFirstContactSafetyTips blendet den Hinweis „Sie erhalten nicht oft eine E-Mail von ...“ ein. Das ist der Balken, der im Ursprungsdokument als Banner-Variante II abgebildet ist.

Hier liegt eine der am häufigsten übersehenen Lücken: **Der Default der Default-Policy ist `$false`**. Beide Presets setzen `$true`, und Microsoft empfiehlt es ausdrücklich: *„This capability adds an extra layer of protection against potential impersonation attacks, so we recommend that you turn it on.“*

```
Set-AntiPhishPolicy -Identity "Office365 AntiPhish Default" `
  -EnableFirstContactSafetyTips $true -EnableUnauthenticatedSender $true -EnableViaTag $true
```

Zwei Hinweise zum Feature. Erstens: Bei mehreren Empfängern gilt ein Mehrheitsprinzip. Microsoft weist darauf hin, dass dadurch Rückschlüsse auf die Kommunikationsgewohnheiten einzelner Empfänger möglich sind – *„If you’re concerned that this behavior exposes the communication habits of one recipient to another, you shouldn’t enable the first contact safety tip.“* Für die meisten Kunden ist das kein Thema, in Kanzleien oder Praxen kann es eines sein. Zweitens: S/MIME-signierte Nachrichten bekommen den Hinweis nicht.

Zur Klarstellung gegenüber dem Kommentar im Ursprungsdokument: First Contact Safety Tip und die Kennzeichnung externer Mails sind zwei verschiedene Dinge – siehe EXT-01.

APH-08 Phishing-Schwellwert

Die Empfehlung von 2023: Stufe 2 von 4.

Was die Stufen bedeuten. Der Schwellwert verschiebt, ab welcher Erkennungssicherheit eine Nachricht wie eine mit „sehr hoher“ Sicherheit erkannte behandelt wird:

Wert	Bezeichnung	Wirkung
1	Standard	Aktionsschwere richtet sich nach dem Confidence-Grad. Default.
2	Aggressive	Treffer mit hoher Sicherheit werden wie „sehr hoch“ behandelt.
3	More aggressive	Treffer mit mittlerer oder hoher Sicherheit werden wie „sehr hoch“ behandelt.
4	Most aggressive	Treffer mit niedriger, mittlerer oder hoher Sicherheit werden wie „sehr hoch“ behandelt.

Herleitung der ursprünglichen Empfehlung. 2023 war Stufe 2 eine vernünftige Balance. Die Erkennungsmodelle produzierten bei höheren Stufen spürbar mehr Fehlalarme, und ein Kunde, dem nach der Härtung legitime Post fehlt, dreht die Maßnahme insgesamt zurück.

Bewertung 2026: Abweichung, Anpassung empfohlen. Microsoft setzt inzwischen im **Standard**-Preset bereits Stufe 3 und im **Strict**-Preset Stufe 4. Stufe 2 liegt damit unter dem, was heute als Normalmaß gilt. Der einzige Vorbehalt, den Microsoft formuliert, ist der erwartbare: „*The chance of false positives (good messages marked as bad) increases as you increase this setting.*“

Empfehlung. Stufe 3 als Baseline. Stufe 4 für exponierte Tenants – Kunden mit häufigen Zahlungsanweisungen, Geschäftsführung mit öffentlichem Profil, bereits erlebte BEC-Vorfälle. Stufe 2 nur noch als Zwischenschritt bei einer gestuften Einführung über zwei bis drei Wochen.

Set-AntiPhishPolicy -Identity "<Custom-Policy>" -PhishThresholdLevel 3

Zwei Fallstricke. Erstens: PhishThresholdLevel ist eine **Defender-Funktion** und braucht mindestens P1. Zweitens: In der Default-Policy ist der Wert nicht vorkonfiguriert – er wirkt nur in einer Custom-Policy oder über ein Preset. Wer ihn in der Default-Policy setzt, ändert unter Umständen nichts.

Impersonation-Schutz (Defender)

Impersonation ist etwas anderes als Spoofing. Beim Spoofing wird die Absenderadresse technisch gefälscht – dagegen helfen SPF, DKIM, DMARC und Spoof Intelligence. Bei Impersonation ist die Adresse **echt**, sie sieht der erwarteten nur zum Verwechseln ähnlich: `geschaeftsfuehrung@kunde-de.com` statt `@kunde.de`, oder ein Freemail-Konto mit dem Anzeigenamen des Geschäftsführers. Technisch ist an so einer Nachricht nichts zu beanstanden – deshalb greift keine der Authentifizierungsprüfungen.

Das ist der Angriffsweg hinter CEO-Fraud und Rechnungsmanipulation, und es ist der Bereich, in dem sich eine Defender-Lizenz am unmittelbarsten auszahlt.

Der Befund aus dem Ursprungsdokument

Der Screenshot der Anti-Phishing-Policy im Ursprungsdokument zeigt einen Zustand, der beim Kunden häufig vorkommt und deshalb als Prüfmuster wertvoll ist:

- Domain impersonation: **an** für eigene und eine Custom-Domain
- User impersonation: **aus**, 0 Absender konfiguriert
- Mailbox intelligence: **an**
- Mailbox intelligence for impersonations: **an**
- Aktionen: „**Don't apply any action**“ – für alle drei Impersonation-Typen

Das heißt in der Praxis: Der Schutz ist eingeschaltet und erzeugt Telemetrie, aber er tut nichts. Erkannte Impersonation-Versuche werden zugestellt wie jede andere Nachricht.

Genau diese Kombination – Erkennung an, Aktion auf `NoAction` – ist in der Checkliste als **kritisch** zu bewerten (IMP-04). Sie entsteht fast immer dadurch, dass jemand die Policy angelegt und die Aktionsseite des Assistenten durchgeklickt hat.

IMP-01 und IMP-02 Geschützte Domänen

Eigene Domänen über `EnableOrganizationDomainsProtection $true`. Das entspricht der Checkbox „Include domains I own“ aus dem Screenshot und deckt automatisch alle Accepted Domains ab. Diese zählen nicht gegen das Limit.

Fremde Domänen über `EnableTargetedDomainsProtection` und `TargetedDomainsToProtect`. Maximal 50 pro Policy. Microsofts Auswahlkriterium: „*domains (sender domains) that you don't own, but you frequently interact with.*“

Für die Aufnahme beim Kunden ist das eine konkrete Frage: Von welchen fremden Domänen kommt Post, bei der ein Missbrauch teuer würde? Typische Antworten: Hausbank, Steuerberater, Wirtschaftsprüfer, die zwei größten Lieferanten, der Zahlungsdienstleister, die Rechtsanwaltskanzlei, bei Kommunalversorgern zusätzlich Netzbetreiber und Aufsichtsbehörden.

Fallstrick. Die Erkennung ist bewusst unscharf. Microsoft wörtlich: „*if your domain is contoso.com, we check for different top-level domains (.com, .biz, etc.), but also*“

domains that are even slightly similar. For example, contosososo.com OR contoabcdef.com might be seen as impersonation attempts." Bei ähnlich klingenden Konzern- oder Tochterdomänen kann das Fehlalarme erzeugen – dann gehören sie in die Ausnahmen (IMP-07), nicht die Schutzfunktion abgeschaltet.

```
Set-AntiPhishPolicy -Identity "<Policy>" `
-EnableOrganizationDomainsProtection $true `
-EnableTargetedDomainsProtection $true `
-TargetedDomainsToProtect @{Add="hausbank.de","steuerberater.de"} `
-TargetedDomainProtectionAction Quarantine `
-TargetedDomainQuarantineTag DefaultFullAccessWithNotificationPolicy
```

IMP-03 Geschützte Benutzer

Der Punkt, der im Screenshot des Ursprungsdokuments auf „Off – 0 sender(s) specified“ steht.

Das Format ist eigenwillig und eine häufige Fehlerquelle: "Anzeigenname;E-Mail-Adresse" – Semikolon zwischen beiden Teilen, Komma zwischen Einträgen. Die Kombination muss eindeutig sein. Maximal 350 Nutzer pro Policy.

```
Set-AntiPhishPolicy -Identity "<Policy>" `
-EnableTargetedUserProtection $true `
-TargetedUsersToProtect @{Add="Max Mustermann;max.mustermann@kunde.de","Erika
Beispiel;erika.beispiel@kunde.de"} `
-TargetedUserProtectionAction Quarantine `
-TargetedUserQuarantineTag DefaultFullAccessWithNotificationPolicy
```

Wen aufnehmen. Microsoft: „users (message senders) in key roles. Internally, protected senders might be your CEO, CFO, and other senior leaders.“ In der Praxis beim Mittelstand: Geschäftsführung, Prokuristen, Leitung Buchhaltung und Einkauf, Assistenz der Geschäftsführung. Die Assistenz wird oft vergessen und ist ein bevorzugtes Ziel, weil sie legitim im Namen der Geschäftsführung schreibt.

Wichtige Einschränkung, die man vorher kennen sollte. Der Schutz wirkt gegen fremde Absender, die einen geschützten Nutzer imitieren. Er schützt **nicht** vor einem kompromittierten Konto des geschützten Nutzers selbst – dafür sind MFA, Conditional Access und die Outbound-Kontrollen zuständig.

IMP-04 Die Aktionen

Ohne gesetzte Aktion ist der gesamte Impersonation-Schutz wirkungslos. Gültige Werte für alle drei Aktions-Parameter: NoAction, BccMessage, Delete, MoveToJmf, Quarantine, Redirect.

Parameter	Default	Standard	Strict
TargetedUserProtectionAction	NoAction	Quarantine	Quarantine
TargetedDomainProtectionAction	NoAction	Quarantine	Quarantine
MailboxIntelligenceProtectionAction	NoAction	MoveToJmf	Quarantine

Empfehlung: Quarantine für User und Domain, MoveToJmf für Mailbox Intelligence. Der Unterschied ist begründet – Mailbox Intelligence arbeitet auf gelernten

Kommunikationsmustern und ist damit anfälliger für Fehllalarme als eine explizit gepflegte Namensliste.

Anmerkung zu einer Doku-Inkonsistenz: Die Cmdlet-Referenz verweist bei TargetedUserProtectionAction für BccMessage und Redirect auf TargetedDomainActionRecipients. Funktional gehört dort TargetedUserActionRecipients hin. Solange man mit Quarantine arbeitet, spielt das keine Rolle.

IMP-05 Mailbox Intelligence

Die Beschreibung im Ursprungsdokument ist zutreffend: „Lernt angeblich, mit wem man so im Allgemeinen zu tun hat und nutzt dieses Wissen zur Spoofing-Erkennung.“

Technisch baut Defender je Postfach eine Kontaktkarte aus dem tatsächlichen Nachrichtenverkehr auf. Weicht ein Absender davon ab – gleicher Anzeigename, andere Adresse; ein Kontakt, der plötzlich von einer neuen Domäne schreibt –, ist das ein Signal.

Zwei Schalter, nicht einer:

Parameter	Default	Standard	Strict	Bedeutung
EnableMailboxIntelligence	\$true	\$true	\$true	Kontaktkarte wird aufgebaut und zur Fehllalarm-Reduktion genutzt
EnableMailboxIntelligenceProtection	\$false	\$true	\$true	Eigene Erkennung mit eigener Aktion

Der zweite ist ab Werk aus. Die Empfehlung von 2023 „ein“ bezieht sich erkennbar auf beide Checkboxes im Screenshot – korrekt, und es ist wichtig, dass beide gemeint sind. Ohne den zweiten liefert Mailbox Intelligence nur eine Fehllalarm-Bremse, aber keine eigene Erkennung.

Wechselwirkung, die man kennen muss. Microsoft wörtlich:

„When both Enable mailbox intelligence and Enable intelligence for impersonation protection are turned on, User impersonation protection doesn’t work if the sender and recipient previously communicated via email.“

Das ist gewollt und dient der Fehllalarm-Reduktion. Es bedeutet aber auch: Ein Angreifer, der über ein bereits bekanntes Konto schreibt, umgeht den User-Impersonation-Schutz. Dieselbe Logik gilt für Domain Impersonation.

IMP-06 Safety Tips für Impersonation

Drei Parameter, alle ab Werk \$false, in beiden Presets \$true:

- EnableSimilarUsersSafetyTips – Hinweis bei ähnlichem Benutzernamen
- EnableSimilarDomainsSafetyTips – Hinweis bei ähnlicher Domäne
- EnableUnusualCharactersSafetyTips – Hinweis bei ungewöhnlichen Zeichen, etwa kyrillischen Buchstaben in einer lateinischen Domäne

Das ist der Mechanismus hinter **Banner-Variante II** aus dem Ursprungsdokument. Der Vorteil gegenüber einem Transportregel-Banner ist genau die Selektivität: Der Hinweis erscheint nur, wenn es einen Anlass gibt – und wird deshalb noch gelesen.

Hinweis: Die gerenderte Learn-Seite zeigt für diese Parameter teilweise `$true` als Default an. Die Quelldaten sagen eindeutig `$false`. Immer den Ist-Zustand auslesen, nicht auf den Default vertrauen.

```
Set-AntiPhishPolicy -Identity "<Policy>" `
  -EnableSimilarUsersSafetyTips $true `
  -EnableSimilarDomainsSafetyTips $true `
  -EnableUnusualCharactersSafetyTips $true
```

IMP-07 Ausnahmen

ExcludedSenders und ExcludedDomains – die „Trusted senders and domains“ aus dem Screenshot.

Die Empfehlung von 2023 „muss nicht gesetzt werden, wenn für Domain aktiv“ ist richtig gelesen: Diese Listen sind Ausnahmen, keine Schutzeinstellungen. Sie gehören nur dort hin, wo ein konkreter Fehlalarm sie erzwingt.

Drei Dinge sind wichtig:

1. Sie wirken **ausschließlich gegen Impersonation** – nicht gegen Spoof, Spam oder Malware. Der Reichweitenschaden eines Eintrags ist damit deutlich geringer als bei AllowedSenderDomains.
2. **Subdomains sind nicht eingeschlossen.** Jede Subdomain braucht einen eigenen Eintrag.
3. Das Limit liegt bei 1.024 Einträgen kombiniert (die Cmdlet-Referenz nennt abweichend „ca. 1000“).

Ein Nebeneffekt, den man beim Audit im Kopf haben sollte: Meldet ein Administrator eine Impersonation-Erkennung als Fehlalarm, wird **kein** TABL-Eintrag erzeugt – der Absender landet automatisch in dieser Liste. Sie wächst also im Betrieb, ohne dass jemand sie bewusst pflegt. Beim Assessment gehört sie deshalb durchgesehen.

Bekannte Microsoft-Systemabsender, die als Impersonation erkannt werden können: noreply@email.teams.microsoft.com, noreply@emeaemail.teams.microsoft.com, noreply@sharepointonline.com.

IMP-08 Priority Account Protection

Gab es 2023 noch nicht. Ein eigenständiges, tenantweites Feature – **nicht** Teil der Anti-Phishing-Policy.

```
Get-EmailTenantSettings | Format-List Identity,EnablePriorityAccountProtection  
Set-EmailTenantSettings -EnablePriorityAccountProtection $true
```

Es greift über den Benutzer-Tag „**Priority account**“, der im Microsoft-365-Admin-Center vergeben wird, nicht über TargetedUsersToProtect. Microsoft begründet es so: *„Priority account protection offers extra heuristics tailored to company executives that don't benefit regular users.“*

Die praktische Konsequenz: VIPs müssen doppelt erfasst werden – einmal als Priority Account für die Heuristik und die Report-Filter, einmal in TargetedUsersToProtect für die Impersonation-Aktion. Eines ersetzt das andere nicht. Das wird in der Praxis regelmäßig verwechselt.

Lizenz: Defender for Office 365 Plan 2. In P2-Tenants ist es ab Werk an; Microsoft rät ausdrücklich davon ab, es abzuschalten.

Tenant Allow/Block List

Warum dieses Kapitel wichtiger geworden ist

Das Ursprungsdokument behandelt die TABL als Nebenschauplatz: „nur einsetzen, wenn benötigt“, mit vier Unterpunkten für Absender, Spoof-Freigaben, URLs und Datei-Hashes. Das war 2023 angemessen.

2026 ist die TABL der reguläre Ausnahmemechanismus von EOP. Zwei Entwicklungen haben dazu geführt: Die Safe-Links-Global-Block-List wurde abgeschafft und ihre Funktion hierher verlagert, und Microsoft hat die Rangfolge der Allow-Methoden ausdrücklich veröffentlicht – mit der TABL auf Platz eins.

Die Empfehlung „nur einsetzen, wenn benötigt“ bleibt inhaltlich richtig – jeder Eintrag ist ein Loch. Sie ist nur nicht mehr die ganze Geschichte: Wenn ein Loch gebraucht wird, gehört es hierher und nirgendwo anders hin.

TABL-01 Der empfohlene Allow-Weg

Microsofts Rangfolge, von best nach schlecht:

1. **Tenant Allow/Block List**
2. Exchange-Transportregeln
3. Outlook-Safe-Senders der Nutzer
4. IP Allow List im Connection Filter
5. Allow-Listen in Anti-Spam-Policies

Und die Warnungen zu den Alternativen, jeweils wörtlich:

- **Transportregeln:** Nie eine Regel „*with only the sender domain as the condition to skip spam filtering*“ – das „*significantly increases the likelihood that attackers can: Spoof the sending domain ... Skip all spam filtering ... Skip sender authentication checks.*“
- **Outlook Safe Senders:** „*creates a high risk of attackers successfully delivering email that would otherwise be filtered*“ und „*interferes with zero-hour auto purge (ZAP).*“
- **IP Allow List:** „*email from sources in the IP Allow List skips spam filtering and sender email authentication (SPF, DKIM, and DMARC).*“
- **Anti-Spam-Allowlisten:** vermeiden „*if at all possible*“.

Der technische Kern. Ein TABL-Allow überspringt nur die Filter, die mit der freigegebenen Entität zu tun haben: „*if messages containing the entities in the allow entries pass other checks in the filtering stack, the messages are delivered.*“ Der Rest des Stacks läuft weiter. Ein Eintrag in `AllowedSenderDomains` dagegen setzt SCL -1 und schaltet alles ab.

Ablaufverhalten – hier gibt es zwei Zahlen, die oft verwechselt werden:

Mechanismus	Wert	Bedeutung
-RemoveAfter 45	45 Tage	Gezählt ab der letzten Nutzung . Einziger gültiger Wert. Nur mit -Allow und für Sender, FileHash, Url.
-ExpirationDate	max. 30 Tage	Festes Ablaufdatum ab Anlage. Maximum für Allow -Einträge.
Block-Einträge	30 Tage Default	Bis 90 Tage oder -NoExpiration setzbar.
Spoofed senders, Teams	nie	Laufen nicht ab.
IP-Adressen	„Never expire“ als Default	Im Portal sind zusätzlich feste Ablaufdaten bis 90 Tage wählbar.

Allow mit festem Ablauf

```
New-TenantAllowBlockListItems -ListType Sender -Allow `
-Entries "rechnung@lieferant.de" -ExpirationDate (Get-Date).AddDays(30) -Notes "Ticket 4711"
```

Allow mit dynamischem Ablauf ab letzter Nutzung

```
New-TenantAllowBlockListItems -ListType Sender -Allow -Entries "info@partner.de" -
RemoveAfter 45
```

Einschränkung beim Anlegen von Allow-Einträgen. Direkt in der TABL lassen sich nur Bulk-, Spam-, High-confidence-Spam- und Phishing-Verdicts überschreiben. Für **Malware** und **High confidence phishing** geht das nicht – dort führt der Weg zwingend über *Submissions* mit „I’ve confirmed it’s clean“. Das ist Absicht: Microsoft wörtlich, „Unnecessary allow entries expose your organization to malicious email that the system would otherwise filter.“

Entry-Limits nach Lizenz (gilt je für Domains/Adressen, URLs und IPs):

Lizenz	Gesamt	Allow	Block
ohne Defender	1.000	500	500
Defender P1	2.000	1.000	1.000
Defender P2	15.000	5.000	10.000

Spoof-Einträge haben einen eigenen, lizenzunabhängigen Pool von 1.024.

TABL-02 Blocks

Ein TABL-Block erzeugt das Verdict **High confidence phishing**. Drei Konsequenzen, die man kennen sollte:

1. Er blockiert **auch den ausgehenden Verkehr** an diese Adresse. NDR: 550 5.7.703 Your message can't be delivered because messages to XXX are blocked by your organization using Tenant Allow Block List. Und zwar die gesamte Nachricht, auch wenn nur einer von zehn Empfängern betroffen ist.

2. **Block schlägt Allow.** Ein Eintrag auf beiden Listen wird blockiert.
3. **Hybrid-Falle:** Trägt eine externe Nachricht den Header X-MS-Exchange-Organization-AuthAs: Internal, greifen Block-Einträge auf eingehende Post **nicht**.

Wer nur „diese Domäne soll wie Spam behandelt werden“ möchte, ist mit BlockedSenderDomains in der Anti-Spam-Policy besser bedient – das ist die mildere Stufe.

Wildcard-Syntax für Domain plus Subdomains: *.TLD, *.SD1.TLD und so weiter.

TABL-03 Spoof-Freigaben

Die Empfehlung von 2023: „nur freigeben, wenn nicht anders lösbar (siehe **korrekte SPF**s).“ Diese Formulierung ist die beste im ganzen Ursprungsdokument und heute noch wichtiger als 2023 – denn **Spoof-Allow-Einträge laufen nie ab**.

Der übliche Ablauf: Ein Dienstleister versendet im Namen des Kunden, hat aber keinen SPF-Eintrag. Die Mails werden als Spoof erkannt. Der schnelle Weg ist ein Allow-Eintrag. Der richtige Weg ist ein Anruf beim Dienstleister mit der Bitte, den SPF-Record zu ergänzen oder DKIM einzurichten.

Der Unterschied wird spätestens bei der DMARC-Einführung relevant: Ein Absender, der als Spoof durchgewinkt wird, besteht auch DMARC nicht. Wer die Freigabe wählt, verschiebt das Problem auf den Tag, an dem p=reject scharf geschaltet wird.

Get-TenantAllowBlockListSpoofItems | [Format-Table](#)
SpoofedUser, SendingInfrastructure, SpoofType, Action

```
New-TenantAllowBlockListSpoofItems -Identity Default -Action Allow `
-SpoofedUser "dienst@partner.de" -SendingInfrastructure "mailer.partner.de" -SpoofType
External
```

Struktur. Ein Eintrag ist immer ein Paar aus *Spoofed user* und *Sending infrastructure* – eine Freigabe für nur die Domäne gibt es nicht. SendingInfrastructure akzeptiert eine Domäne oder eine IP in /24-Notation.

Einschränkung. Set-TenantAllowBlockListSpoofItems kann ausschließlich -Action umschalten (Allow ↔ Block). Wer Absender oder Infrastruktur ändern will, muss löschen und neu anlegen.

Beziehung zum Spoof Intelligence Insight. Sobald ein Verdict im Insight manuell überschrieben wird, verschwindet der Absender dort und ist nur noch im Tab *Spoofed senders* der TABL zu finden. Beim Assessment beide Orte ansehen:

Get-SpoofIntelligenceInsight | [Format-Table](#)
SpoofedUser, SendingInfrastructure, MessageCount, LastSeen, SpoofType, Action

TABL-04 bis TABL-06 URLs, Dateien, IP-Adressen

URLs. Seit der Abschaffung der Safe-Links-Global-Block-List der einzige Ort für URL-Blocks. Skripte oder Konfigurationswerkzeuge, die noch Set-AtpPolicyFor0365 -BlockUrls verwenden, brechen – der Parameter ist nicht mehr dokumentiert.

Wichtig für das Verständnis von SL-06, und hier ist die Microsoft-Dokumentation nicht ganz einheitlich: Die TABL-URL-Seite sagt, ein Allow-Eintrag verhindere das Wrapping durch Safe Links **nicht** – er übersteuere nur das Verdict beim Klick. Die Safe-Links-Seite beschreibt dagegen für einen über *Submissions* erzeugten Allow-Eintrag, dass die URL weder im Mailfluss noch beim Klick geprüft oder umgeschrieben wird. Wer beides sicher erreichen will, meldet die URL über Submissions als „confirmed clean“, statt einen Eintrag manuell anzulegen.

Datei-Hashes. Nur SHA256, maximal 64 Zeichen. Praktisch relevant in der Incident Response, wenn ein bestimmter Anhang gezielt gesperrt werden soll. Allow-Einträge für Dateien lassen sich nicht direkt anlegen.

IP-Adressen. Neu seit der Entstehung des Ursprungsdokuments – mit einer entscheidenden Einschränkung. Microsoft wörtlich:

„IPv4 addresses (both single addresses and ranges) aren't supported in the Tenant Allow/Block List for this feature. Only IPv6 addresses are supported here. To allow or block IPv4 addresses, use the default connection filter policy instead.”

Für IPv4 bleibt also der Connection Filter zuständig (CF-02). Ein IPv6-Block verwirft eingehende Nachrichten am Rand des Dienstes, bevor sie überhaupt in die Filterung gelangen.

```
New-TenantAllowBlockListItems -ListType IP -Block -Entries "2001:db8::/32" -NoExpiration
```

Anti-Malware

Anti-Malware, Safe Attachments und Safe Links sind zwischen Standard- und Strict-Preset in jedem dokumentierten Wert identisch. Das gesamte Delta der beiden Presets liegt bei Anti-Spam und Anti-Phishing. Nützlich zu wissen, wenn ein Kunde nach „dem strengsten Modus“ fragt: Für Malware- und Linkschutz gibt es keinen strengeren Modus.

AMW-01 Common Attachment Filter

Die Empfehlung von 2023: „ein.“ Unverändert richtig und in allen Presets so gesetzt.

Was die Funktion macht. Sie blockiert Anhänge anhand des Dateityps, unabhängig davon, ob eine Malware-Signatur greift. Das ist wichtig, weil die eigentliche Virenerkennung nur findet, was sie kennt – eine frisch kompilierte `.exe` oder ein präpariertes `.lnk` sind neu und unbekannt. Der Typfilter greift trotzdem.

Wichtig: Gefiltert wird nach dem **echten Dateityp**, nicht nur nach der Endung. Umbenennen hilft nicht.

Die Default-Liste umfasst 53 Typen:

ace, ani, apk, app, appx, arj, bat, cab, cmd, com, deb, dex, dll, docm, elf, exe, hta, img, iso, jar, jnlp, kext, lha, lib, library, lnk, lzh, macho, msc, msi, msix, msp, mst, pif, ppa, ppam, reg, rev, scf, scr, sct, sys, uif, vb, vbe, vbs, vxd, wsc, wsf, wsh, xll, xz, z

Zur Frage nach einer „empfohlenen erweiterten Liste“: Die gibt es nicht. Microsoft dokumentiert die Default-Liste und eine Liste zusätzlich *auswählbarer* Typen, spricht aber keine Erweiterungsempfehlung aus. Jede Erweiterung ist damit eine Consultant-Entscheidung und sollte gegenüber dem Kunden auch so benannt werden.

Zwei Kandidaten, über die sich reden lässt:

- **ps1, js, jse, vbs-Verwandte und chm** – ausführbare Skriptformate, die im normalen Geschäftsverkehr praktisch nie per Mail kommen. Geringes Risiko, spürbarer Gewinn.
- **Archive (zip, 7z, rar)** – hier ist Vorsicht geboten. Sie sind bewusst nicht im Default, und ihre Aufnahme bricht typischerweise Geschäftsprozesse: Angebotsunterlagen, CAD-Pakete, Fotostrecken. Vor der Aufnahme das tatsächliche Volumen im Threat Explorer messen.

Randnotiz: In der Liste der zusätzlich auswählbaren Typen – nicht in der Default-Liste – führt Microsoft den Eintrag `dotx` und markiert ihn selbst mit `[sic]`. Vermutlich ein Tippfehler für `dotx`.

AMW-02 ZAP für Malware

ZapEnabled – hier heißt der Parameter noch so, anders als in der Anti-Spam-Policy. Default in allen Varianten `$true`. Microsoft: „By default, ZAP for malware is turned on, and we recommend that you leave it on.“

Das ist genau die Anforderung „Mails werden nachträglich bei neu-erkannten Viren aus der Mailbox gelöscht“ aus der Anforderungstabelle des Ursprungsdokuments – vollständig erfüllt.

AMW-03 Aktion des Typfilters

FileTypeAction kennt genau zwei Werte:

- **Reject** (Default, und in beiden Presets) – die Nachricht wird abgewiesen, der Absender bekommt einen NDR.
- **Quarantine** – die Nachricht landet still in der Quarantäne, der Absender erfährt nichts.

Die Abwägung: **Reject** ist gegenüber legitimen Absendern fairer – der Geschäftspartner, dessen Angebot mit .iso-Anhang abgewiesen wurde, weiß Bescheid und kann es anders schicken. **Quarantine** ist für die Forensik besser und verrät einem Angreifer nichts über die Filterregeln.

Für die meisten Mittelstandskunden ist **Reject** die richtige Wahl. Wo es eine besetzte Security-Funktion gibt, ist **Quarantine** vertretbar – dann greift auch der QuarantineTag.

AMW-04 Quarantäne-Policy

Die Empfehlung von 2023: „admin access“, Benachrichtigung an die Admin-Quarantäne. Deckt sich vollständig mit allen Microsoft-Presets: AdminOnlyAccessPolicy.

Ein Detail, das man im Kundengespräch bereithalten sollte, weil es regelmäßig zu Diskussionen führt: **Für Malware wird eine Release-Berechtigung nie gewährt.** Microsoft wörtlich:

„By default, recipients don't receive notifications for messages that were quarantined as malware, and users can't release their own quarantined malware messages, regardless of any available settings that admins configure.”

Selbst wenn man einer Anti-Malware-Policy eine Quarantäne-Policy mit vollen Rechten zuweist, wird das Release automatisch zu einer *Freigabeanfrage* herabgestuft. Die Frage „können wir Nutzern erlauben, Malware-Quarantäne selbst freizugeben“ ist damit technisch beantwortet – nein.

AMW-05 Admin-Benachrichtigungen

Die Anforderung „Ein Administrator wird benachrichtigt“ aus der Anforderungstabelle ist erfüllbar:

```
Set-MalwareFilterPolicy -Identity "Default" `
    -EnableInternalSenderAdminNotifications $true -InternalSenderAdminAddress
"security@kunde.de"
```

Drei Einschränkungen dazu:

1. **Absender-Benachrichtigungen** gibt es in Exchange Online nicht. Die Parameter `EnableInternalSenderNotifications` und `EnableExternalSenderNotifications` sind ausdrücklich on-premises-only.
2. **Empfänger-Benachrichtigungen** sind in die Quarantäne-Policy gewandert – sie werden nicht mehr hier gesteuert.
3. **Admin-Benachrichtigungen** werden nur für Anhänge verschickt, nicht für Body-basierte Malware-Verdicts.

Die Presets setzen diese Benachrichtigungen bewusst **nicht**. Microsofts Weg dafür sind Alert Policies (REP-02), die aggregieren statt jede einzelne Erkennung zu melden. Bei einem Kunden mit nennenswertem Mailvolumen ist das der praktikablere Weg – Einzelbenachrichtigungen werden nach zwei Wochen weggefiltert und dann nie wieder gelesen.

Safe Attachments und Safe Links (Defender)

Beide Funktionen setzen Defender for Office 365 P1 oder P2 voraus. Bei reinen EOP-Kunden entfällt dieses Kapitel – dann sind die entsprechenden Zeilen der Checkliste mit „n.a. (nicht lizenziert)“ zu bewerten. Ohne P1 gibt es keine Detonation von Anhängen, keine Prüfung von Links beim Klick und keinen Impersonation-Schutz.

SA-01 Safe Attachments: Aktion

Was die Funktion macht. Anhänge, die von den signaturbasierten Prüfungen nicht beanstandet wurden, werden in einer isolierten Umgebung tatsächlich ausgeführt und beobachtet. Damit werden auch Schädlinge erkannt, für die es noch keine Signatur gibt – der eigentliche Mehrwert gegenüber EOP.

Die Änderung gegenüber dem Screenshot im Ursprungsdocument. Dort ist die Option „Replace – Block attachments with detected malware, but deliver the message. **(To be deprecated. The Block action will be applied.)**“ noch sichtbar. Diese Ankündigung ist inzwischen vollzogen: **Replace existiert nicht mehr.**

Gültige Werte 2026:

Wert	Portal-Label	Bedeutung
Allow	Monitor	Zustellen, Ergebnis protokollieren
Block	Block	Nachricht blockieren – Default
DynamicDelivery	Dynamic Delivery	Text sofort zustellen, Anhang nachreichen

Dazu `-Enable $false` für „Off“.

Alle drei Presets – Built-in, Standard und Strict – setzen `Block`. Der Screenshot des Ursprungsdocuments zeigt ebenfalls `Block`. Bewertung: unverändert richtig.

`Get-SafeAttachmentPolicy` | [Format-Table](#)

`Name, Enable, Action, QuarantineTag, Redirect, RedirectAddress`

`Set-SafeAttachmentPolicy -Identity "<Policy>" -Enable $true -Action Block -QuarantineTag AdminOnlyAccessPolicy`

Prüfauftrag beim Kunden: Bestandsolicies auf Altwerte durchsehen. Eine Policy, die noch auf `Replace` stand, ist migriert worden – aber wohin, sollte man wissen.

SA-02 Redirect und der verschwundene Fehlerfall

Redirect. Der Screenshot zeigt „Enable redirect“ nicht gesetzt – richtig so. Wichtiger ist die Regel dahinter: Microsoft schreibt, `Redirect` sei „*meaningful only when the value of the Action parameter is Allow*“. Die Kombination `-Redirect $true` mit `-Action Block` wird ohne Fehler akzeptiert und **tut nichts**. Ein Konfigurationsfehler, der nur bei genauem Hinsehen auffällt.

Der verschwundene Parameter. Im Screenshot ist außerdem die Checkbox „Apply the Safe Attachments detection response if scanning can't complete (timeout or errors)“ zu sehen, gesetzt. Der zugehörige Parameter `ActionOnError` **existiert 2026 nicht mehr** – weder in der Cmdlet-Referenz noch im dokumentierten Portal. Ein Nachfolger ist nicht dokumentiert.

Für die Praxis bedeutet das: Wer ein Skript aus 2023 wiederverwendet, das `ActionOnError` setzt, bekommt einen Fehler. Und die Frage „was passiert, wenn der Scan nicht durchläuft“ lässt sich aus der aktuellen Dokumentation nicht mehr beantworten. In der Checkliste als offener Punkt führen.

SA-03 und SA-04 Globale Einstellungen

SharePoint, OneDrive und Teams. `EnableATPForSPOTeamsODB` – im Screenshot des Ursprungsdokuments aktiviert. Richtig, und über das Built-in-protection-Preset ohnehin gesetzt.

Ein Zusatzschritt fehlt aber fast immer: Die Aktivierung markiert erkannte Dateien, verhindert aber **nicht automatisch den Download**. Dafür ist ein separater Befehl in der SharePoint Online Management Shell nötig:

```
# SharePoint Online Management Shell, nicht Exchange Online
Set-SPOTenant -DisallowInfectedFileDownload $true
```

Ohne diesen Schritt kann ein Nutzer eine als schädlich erkannte Datei weiterhin herunterladen.

Safe Documents. Im Screenshot ebenfalls aktiviert, mit „Allow people to click through“ aus – beides richtig konfiguriert.

Aber: Lizenzfalle. Safe Documents hängt am Service Plan *Office 365 SafeDocs* und ist verfügbar in Microsoft 365 A5, E5, GCC G5, GCC High G5 und der Microsoft Defender Suite. **In MDO P1 oder P2 standalone ist es nicht enthalten.** Bei einem Kunden mit M365 E3 plus MDO P1 ist der Schalter also entweder gar nicht da oder wirkungslos. Vor der Empfehlung die Lizenzierung prüfen.

```
Get-AtPolicyFor0365 | Format-List
Name,EnableATPForSPOTeamsODB,EnableSafeDocs,AllowSafeDocsOpen
Set-AtPolicyFor0365 -Identity Default -EnableATPForSPOTeamsODB $true -EnableSafeDocs $true
-AllowSafeDocsOpen $false
```

SA-05 Dynamic Delivery

Existiert weiterhin, ist aber in keinem Preset gesetzt. Die Idee ist gut – der Nachrichtentext wird sofort zugestellt, der Anhang folgt nach Abschluss der Prüfung, sodass keine Zustellverzögerung entsteht.

Die dokumentierten Lücken sprechen dagegen: Es funktioniert **nur für Exchange-Online-Postfächer** (nicht für on-premises oder hybrid geroutete), nicht bei öffentlichen Ordnern, **nicht bei S/MIME-verschlüsselten Nachrichten** und nicht bei Nachrichten mit Custom-Routing-Regeln.

Soll-Wert in diesem Standard ist `Block` – Dynamic Delivery gehört nicht in die Baseline. Wenn ein Kunde konkret über Zustellverzögerungen klagt, ist es eine mögliche, bewusst zu dokumentierende Abweichung; dann aber mit dem Hinweis auf die genannten Lücken.

SL-01 bis SL-05 Safe Links: die Kernschalter

Der Screenshot im Ursprungsdokument zeigt eine gut konfigurierte Policy. Alle sichtbaren Werte entsprechen dem Standard-Preset:

Portal-Label	Parameter	Screenshot	Standard	Strict
Safe Links für E-Mail	<code>EnableSafeLinksForEmail</code>	✓	<code>\$true</code>	<code>\$true</code>
Interne Absender einbeziehen	<code>EnableForInternalSenders</code>	✓	<code>\$true</code>	<code>\$true</code>
Echtzeit-URL-Prüfung	<code>ScanUrls</code>	✓	<code>\$true</code>	<code>\$true</code>
Auf Scan warten	<code>DeliverMessageAfterScan</code>	✓	<code>\$true</code>	<code>\$true</code>
Nur API, kein Rewriting	<code>DisableUrlRewrite</code>	✗	<code>\$false</code>	<code>\$false</code>
Teams	<code>EnableSafeLinksForTeams</code>	✓	<code>\$true</code>	<code>\$true</code>
Office-Apps	<code>EnableSafeLinksForOffice</code>	✓	<code>\$true</code>	<code>\$true</code>
Klicks protokollieren	<code>TrackClicks</code>	✓	<code>\$true</code>	<code>\$true</code>
Durchklicken erlauben	<code>AllowClickThrough</code>	✗	<code>\$false</code>	<code>\$false</code>

Warum `EnableForInternalSenders` wichtig ist. Nach einer Kontokompromittierung ist der nächste Schritt fast immer eine interne Mail an Kollegen – die wirkt vertrauenswürdig, weil sie von einem bekannten Absender kommt. Ohne diesen Schalter werden ihre Links nicht geprüft. Bemerkenswert: Das **Built-in-protection-Preset** setzt hier `$false`. Ein Tenant, der sich auf Built-in verlässt, hat diese Lücke.

Warum `AllowClickThrough` auf `$false` gehört. Auf `$true` darf der Nutzer die Warnseite mit einem Klick übergehen. Damit ist der Schutz eine Empfehlung statt einer Kontrolle. Auch hier: **Built-in** setzt `$true`, Standard und Strict setzen `$false`.

Fallstrick bei der Skript-Erstellung. Die PowerShell-Defaults von `New-SafeLinksPolicy` weichen von den Portal-Vorbelegungen ab. Wer eine Policy per Skript anlegt und Parameter wegzulassen glaubt „weil der Default ja stimmt“, bekommt unter Umständen etwas anderes als im Portal. Immer alle Parameter explizit setzen.

```
Set-SafeLinksPolicy -Identity "<Policy>" `
  -EnableSafeLinksForEmail $true -EnableForInternalSenders $true `
```

```
-ScanUrls $true -DeliverMessageAfterScan $true -DisableUrlRewrite $false `
-EnableSafeLinksForTeams $true -EnableSafeLinksForOffice $true `
-TrackClicks $true -AllowClickThrough $false
```

SL-06 „Do not rewrite the following URLs”

Das Ursprungsdokument hat hier den wichtigsten Punkt bereits richtig erfasst:

„Einträge werden während des Mailflusses nicht gescannt oder umgeschrieben. Es schützt aber nicht vor der Einstufung der URL als schädlich. Um dies zu umgehen (whitelisten) muss die Tenant Allow/Block List verwendet werden.”

Das ist bestätigt. Microsoft wörtlich: Einträge „*aren’t scanned or wrapped by Safe Links during mail flow, but might still be blocked at time of click.*”

Und die Gegenprobe auf der TABL-Seite ergänzt das Bild um die andere Richtung: „*A URL allow entry doesn’t prevent the URL from being wrapped by Safe Links protection.*”

Die beiden Mechanismen adressieren unterschiedliche Wirkungen:

Ziel	Mechanismus
URL soll nicht umgeschrieben werden	DoNotRewriteUrls in der Safe-Links-Policy
URL soll nicht blockiert werden	TABL-URL-Allow
Beides zuverlässig	Meldung über <i>Submissions</i> als „confirmed clean”, zusätzlich DoNotRewriteUrls

Anmerkung: Microsoft beschreibt für einen über Submissions erzeugten Allow-Eintrag, dass die URL weder im Mailfluss noch beim Klick gewrappt oder geprüft wird – die TABL-Seite formuliert für manuell angelegte Einträge enger. Im Zweifel im Tenant nachmessen.

Weitere Fallstricke der Liste, die im Ursprungsdokument nicht stehen:

- Maximal **3 Wildcards** pro Eintrag.
- *.contoso.com deckt contoso.com **nicht** ab – beide Einträge sind nötig.
- contoso.com allein deckt keine Pfade ab. Für Domain plus Pfade: contoso.com/*. Für alles: *.contoso.com/*.
- **Microsoft Teams und die Office Web Apps ignorieren die Liste vollständig.**

Empfehlung: Liste leer oder minimal halten. Die typischen Einträge (interner Ticketlink, Intranetportal) sind meist überflüssig, weil interne URLs ohnehin nicht beanstandet werden.

SL-07 Warnseite und Benachrichtigungstext

Ein Prüfpunkt, der sich direkt aus dem Screenshot ergibt: Dort ist ein Platzhaltertext als Custom notification text hinterlegt, mit aktiviertem Translator.

Dieser Text wird jedem Nutzer angezeigt, der auf einen blockierten Link klickt – also in dem Moment, in dem Vertrauen in die IT gefragt ist. Bei jedem Kunden prüfen, ob dort ein produktiver Text steht.

Ein brauchbarer Text nennt drei Dinge: was passiert ist, dass es Absicht ist, und an wen man sich wendet.

```
Set-SafeLinksPolicy -Identity "<Policy>" `
  -EnableOrganizationBranding $true `
  -CustomNotificationText "Diese Adresse wurde von der IT-Sicherheit blockiert. Wenn Sie
den Link für geschäftlich notwendig halten, wenden Sie sich bitte an den Service Desk." `
  -UseTranslatedNotificationText $true
```

EnableOrganizationBranding setzt voraus, dass das Microsoft-365-Organisationsdesign vorher konfiguriert wurde. Der Aufwand lohnt sich: Eine Warnseite im Corporate Design ist deutlich schwerer zu imitieren als eine generische.

Quarantäne-Policies

Das Ursprungsdokument verweist knapp auf diesen Bereich: „Hier sind vor allem die Global settings spannend.“ Das trifft zu – und die beiden Kommentare im Dokument zeigen, dass die Details schon damals Fragen aufgeworfen haben. Beide sind hier zu klären.

Wie das Modell funktioniert

Eine Quarantäne-Policy legt fest, was ein Endanwender mit einer quarantänierten Nachricht tun darf und ob er überhaupt davon erfährt. Sie wird nicht global gesetzt, sondern **je Verdict** in der jeweiligen Schutz-Policy zugewiesen. Ein Tenant hat also nicht „eine Quarantäne-Einstellung“, sondern bis zu elf.

Die vorgefertigten Policies:

Name	Berechtigungen	Benachrichtigung
AdminOnlyAccessPolicy	keine (Wert 0)	nein
DefaultFullAccessPolicy	Full access (Wert 39)	nein
DefaultFullAccessWithNotificationPolicy	Full access (Wert 39)	ja
NotificationEnabledPolicy	Full access	ja – nur in Tenants, die sie historisch erhalten haben

QUA-01 Die Zuordnung je Verdict

Zunächst die Korrektur zum Kommentar im Ursprungsdokument. Dort steht: „Stand auf AdminOnlyAccessWithNotifyPolicy – so gelassen!“

Eine vorgefertigte Policy dieses Namens **existiert nicht**. Sie kommt in der Microsoft-Dokumentation nicht vor. Wahrscheinlichste Erklärung ist eine Verwechslung mit DefaultFullAccessWithNotificationPolicy – oder es handelte sich um eine im Tenant selbst angelegte Policy. Beim Kunden ist das konkret nachzusehen:

Get-QuarantinePolicy | [Format-Table](#) Name,ESNEnabled,EndUserQuarantinePermissionsValue

Die vollständige Soll-Zuordnung:

Feature	Verdict	Parameter	Standard	Strict	Soll hier
Anti-Malware	Malware	QuarantineTag	AdminOnly	AdminOnly	AdminOnly
Safe Attachments	Malware	QuarantineTag	AdminOnly	AdminOnly	AdminOnly
Anti-Spam	Spam	SpamQuarantineTag	FullAccess	FullAccess+Notify	FullAccess+Notify
Anti-Spam	High conf. spam	HighConfidenceSpamQuarantineTag	FullAccess+Notify	FullAccess+Notify	FullAccess+Notify

Feature	Verdict	Parameter	Standard	Strict	Soll hier
Anti-Spam	Phishing	PhishQuarantineTag	FullAccess+Notify	FullAccess+Notify	FullAccess+Notify
Anti-Spam	High conf. phishing	HighConfidencePhishQuarantineTag	AdminOnly	AdminOnly	AdminOnly
Anti-Spam	Bulk	BulkQuarantineTag	FullAccess	FullAccess+Notify	FullAccess+Notify
Anti-Phishing	Spoof	SpoofQuarantineTag	FullAccess	FullAccess+Notify	FullAccess+Notify
Anti-Phishing	User impersonation	TargetedUserQuarantineTag	FullAccess+Notify	FullAccess+Notify	FullAccess+Notify
Anti-Phishing	Domain impersonation	TargetedDomainQuarantineTag	FullAccess+Notify	FullAccess+Notify	FullAccess+Notify
Anti-Phishing	Mailbox intelligence	MailboxIntelligenceQuarantineTag	FullAccess	FullAccess+Notify	FullAccess+Notify

Der einzige Nicht-Malware-Verdict, der durchgehend admin-only bleibt, ist **High confidence phishing**. Alles andere ist bei Microsoft Full access – der Sprung von Standard auf Strict besteht bei der Quarantäne fast ausschließlich darin, Benachrichtigungen einzuschalten, nicht darin, Rechte zu entziehen.

Die Linie von 2023 „möglichst Admin-Quarantäne“ ist damit strenger als Microsoft. Das ist verteidigbar, hat aber einen Preis: Jeder Fehlalarm wird zum Ticket. Die Entscheidung gehört mit dem Kunden getroffen, nicht vom Consultant allein.

Ein Fallstrick beim Anlegen von Policies im Portal: Microsoft wörtlich – „*Although the Apply quarantine policy value appears unselected when you create an anti-phishing policy in the Defender portal, the quarantine policy named DefaultFullAccessPolicy is used if you don't select a quarantine policy.*“ Wer das Feld leer lässt, bekommt also Full access, nicht „nichts“.

QUA-02 Eine eigene Policy bauen

Was der Kommentar im Ursprungsdokument gemeint hat – Benachrichtigung an den Nutzer, aber keine Freigabemöglichkeit – lässt sich herstellen:

```
New-QuarantinePolicy -Name "AdminOnlyWithNotify" -EndUserQuarantinePermissionsValue 0 -ESNEnabled $true
```

Der Nutzer erhält die Quarantäne-Benachrichtigung, sieht den Nachrichtenkopf und weiß damit, dass etwas für ihn abgefangen wurde – kann aber nichts freigeben. Für viele Kunden ist das genau die richtige Mitte zwischen „Admin-only“ und „Nutzer entscheidet selbst“.

Zur Berechtigungs-Bitmask. EndUserQuarantinePermissionsValue ist ein Dezimalwert aus acht Bits:

Bit	Berechtigung	Dezimal
1	View message header	128
2	Download	64
3	Allow sender	32
4	Block sender	16
5	Request release	8
6	Release	4
7	Preview	2
8	Delete	1

Vorgefertigte Kombinationen: **0** = No access, **43** = Limited access (32+8+2+1), **39** = Full access (32+4+2+1).

Drei Eigenheiten, die man kennen sollte:

- **Bit 128 ist wirkungslos.** Microsoft: „*The value 0 doesn't hide the View message header action in quarantine.*“ Deshalb ist „No access“ der Wert 0 und nicht 128.
- **Bit 64 ist tot.** „*This permission is not used (the value 0 or 1 does nothing).*“
- **Request release (8) und Release (4) schließen sich aus.** Microsoft: „*Set one value to 1 and the other value to 0, or set both values to 0.*“
- **Block sender (16) ist in keiner Preset-Gruppe enthalten.** Wer es will, braucht einen eigenen Wert, etwa 43+16 = 59.

QUA-03 Benachrichtigungsfrequenz

Der Kommentar im Ursprungsdokument ist bestätigt und weiterhin aktuell:

„Benachrichtigungen waren bis vor kurzem nur einmal am Tag möglich. Dies hat Microsoft geändert. Benachrichtigung innerhalb von 4 Stunden konfigurierbar in den globalen Quarantänen Benachrichtigungs Einstellungen.“

Gültige Werte sind ausschließlich diese drei:

Wert	Bedeutung
04:00:00	alle 4 Stunden
1.00:00:00	täglich – Default
7.00:00:00	wöchentlich

```
Get-QuarantinePolicy -QuarantinePolicyType GlobalQuarantinePolicy |  
Set-QuarantinePolicy -EndUserSpamNotificationFrequency 04:00:00
```

Empfehlung: 4 Stunden. Die Begründung ist praktisch: Bei täglicher Benachrichtigung wartet ein Nutzer im ungünstigen Fall fast 24 Stunden auf eine irrtümlich abgefangene Nachricht. Genau daraus entsteht der Ruf, „der Spamfilter frisst unsere Post“. Alle vier

Stunden reduziert die maximale Wartezeit auf ein Maß, das niemanden mehr stört – und macht damit die strengeren Aktionen (Quarantäne statt Junk) überhaupt erst durchsetzbar.

Die Einstellung ist **tenant-global** und gilt für alle Quarantäne-Policies mit `ESNEnabled $true`.

QUA-04 Branding und Absenderadresse

Die Anforderung „Quarantäne-Notifications sind mit Corporate Branding möglich“ aus der Anforderungstabelle ist erfüllbar:

```
Get-QuarantinePolicy -QuarantinePolicyType GlobalQuarantinePolicy | Set-QuarantinePolicy `
  -OrganizationBrandingEnabled $true `
  -EndUserSpamNotificationCustomFromAddress "quarantaene@kunde.de"
```

Der Standard-Absender ist `quarantine@messaging.microsoft.com`. Eine eigene Absenderadresse aus der Kundendomäne hat einen konkreten Sicherheitsnutzen, der über Kosmetik hinausgeht: **Gefälschte Quarantäne-Benachrichtigungen sind eine der verbreitetsten Phishing-Kampagnen.** Sie imitieren exakt die Microsoft-Standardmail. Wenn die echten Benachrichtigungen von der eigenen Domäne kommen und das Logo des Kunden tragen, ist die Fälschung für den Nutzer sofort erkennbar.

Voraussetzung für das Branding ist ein konfiguriertes Microsoft-365-Organisationsdesign. Mehrsprachigkeit ist auf 3 Sprachen begrenzt, der Disclaimer je Sprache auf 200 Zeichen.

Advanced Delivery

ADV-01 SecOps-Postfach

Was die Funktion macht. Ein als SecOps-Postfach gekennzeichnetes Postfach empfängt Nachrichten ohne Filterung – gedacht für ein Security-Team, das Phishing-Nachrichten im Original analysieren will, und für Meldepostfächer, in die Nutzer Verdachtsfälle weiterleiten.

Die Warnung, die im Ursprungsdokument fehlt. Ein SecOps-Postfach bekommt nicht nur Spam ungefiltert. Microsoft ist hier präzise:

„Filters in Microsoft 365 take no action on these messages. Malware filtering is bypassed for SecOps mailboxes only.“ „Zero-hour auto purge (ZAP) for spam and phishing take no action on these messages. ZAP for malware is bypassed for SecOps mailboxes only.“

Das heißt: **Auch der Malware-Filter und Malware-ZAP werden übersprungen.** Ein SecOps-Postfach erhält echte, funktionsfähige Schadsoftware direkt zugestellt.

Daraus folgt: Es darf niemals ein produktives Benutzer- oder Shared-Postfach sein. Zugriff nur für das Security-Team, keine automatische Weiterleitung, keine mobile Synchronisierung, und der Zugriff sollte von einem Gerät erfolgen, auf dem das Öffnen von Anhängen keinen Schaden anrichtet.

Bei einem Kunden ohne dediziertes Security-Team ist die richtige Antwort auf die Frage nach einem SecOps-Postfach: nicht einrichten. Für den Meldeweg der Nutzer gibt es den besseren Mechanismus der User Reported Settings (REP-03).

Achtung bei den Cmdlet-Namen: Die Rule-Cmdlets tragen ein Exo-Präfix, die Policy-Cmdlets nicht. New-SecOpsOverrideRule ohne Exo existiert nicht.

```
New-SecOpsOverridePolicy -Name SecOpsOverridePolicy -SentTo "secops@kunde.de"
New-ExoSecOpsOverrideRule -Name SecOpsOverrideRule -Policy SecOpsOverridePolicy
```

ADV-02 Phishing-Simulationen

Die Korrektur zum Ursprungsdokument. Dort steht: „Gehört zu MDO-E5!“

Das ist nicht zutreffend. Der Advanced-Delivery-Artikel nennt als Geltungsbereich ausdrücklich „Built-in security features for all cloud mailboxes“, „Microsoft Defender for Office 365 Plan 1 and Plan 2“ und „Microsoft Defender XDR“. Eine E5- oder P2-Beschränkung ist nicht dokumentiert.

Woher die Verwechslung vermutlich kommt. Es gibt zwei verschiedene Dinge:

	Attack Simulation Training	Advanced Delivery / Phishing Simulation
Was es ist	Microsofts eigenes Simulationsprodukt	Ausnahmeregel für Drittanbieter -Simulationen

	Attack Simulation Training	Advanced Delivery / Phishing Simulation
Lizenz	MDO P2 / E5	ab P1 , teils EOP
Portal	Attack simulation training	Advanced delivery

Wer also mit KnowBe4, SoSafe, Proofpoint oder einem ähnlichen Anbieter simuliert, braucht kein E5 – nur die Advanced-Delivery-Regel. Die Empfehlung von 2023 „ab und zu mal machen“ bleibt richtig und ist günstiger umsetzbar als angenommen.

Warum es zwingend über Advanced Delivery laufen muss. Der verbreitete Behelf ist eine Transportregel oder eine IP-Freigabe für den Simulationsanbieter. Microsoft warnt davor ausdrücklich:

„Don't try to work around this limitation by adding the IP addresses of the on-premises or non-Microsoft sending infrastructure to the non-Microsoft phishing simulation. Doing so effectively bypasses spam filtering for any internet sender who impersonates the domain specified.“

Dazu kommen drei praktische Gründe:

1. **Selektivität.** Advanced Delivery prüft Domäne **und** Absender-IP gemeinsam. Eine IP-Allow-Liste prüft nur die IP – jeder Absender hinter dieser IP kommt durch.
2. **Malware bleibt aktiv.** Bei Phishing-Simulationen wird der Malware-Filter **nicht** übersprungen (anders als beim SecOps-Postfach). Eine Transportregel mit scl - 1 hebt auch den aus.
3. **Die Telemetrie bleibt korrekt.** Nur über Advanced Delivery werden Simulationsnachrichten als solche erkannt: Admin-Meldungen bekommen eine automatische „ist eine Simulation“-Antwort, Nutzermeldungen erscheinen im Submissions-Bereich, ohne Alerts, Untersuchungen oder Incidents auszulösen. Mit einer Transportregel erzeugt jede Simulationskampagne echte Sicherheitsvorfälle – und verdirbt zugleich die Auswertung der Awareness-Maßnahme.

```
New-PhishSimOverridePolicy -Name PhishSimOverridePolicy
New-ExoPhishSimOverrideRule -Name PhishSim -Policy PhishSimOverridePolicy `
  -Domains "simulation.anbieter.de" -SenderIdRanges "203.0.113.0/24"
```

```
# Simulations-URLs separat über die TABL – der ListSubType ist zwingend
New-TenantAllowBlockListItems -Allow -ListType Url -ListSubType AdvancedDelivery `
  -Entries "sim.anbieter.de/*" -NoExpiration
```

Limits: maximal 50 Domänen, 10 Absender-IPs und 30 Simulations-URLs.

ADV-03 Filter-Bypässe im Bestand

Ein neuer Prüfpunkt, der aus allem Vorhergehenden folgt. Die sauberste Policy-Konfiguration nützt nichts, wenn eine Transportregel die Filterung vorher abschaltet.

```
Get-TransportRule |
  Where-Object { $_.SetSCL -eq '-1' -or $_.SetHeaderName -like '*BypassFocusedInbox*' } |
  Format-Table Name,State,Priority,SetSCL,SenderIdRanges,FromScope
```

Solche Regeln entstehen fast immer aus einem konkreten Anlass – ein Dienstleister, dessen Mails „immer im Spam landeten“, ein Monitoring-System, ein Newsletter. Sie überleben den Anlass regelmäßig um Jahre.

Beim Assessment jede gefundene Regel einzeln bewerten: Wozu wurde sie angelegt? Gibt es den Grund noch? Lässt sich derselbe Zweck über einen TABL-Eintrag mit Ablaufdatum erreichen? In den allermeisten Fällen lautet die Antwort auf die letzte Frage ja.

Besonders kritisch sind Regeln, die als einzige Bedingung die **Absenderdomäne** prüfen. Weil die Domäne im From-Header trivial fälschbar ist, macht eine solche Regel den Filter-Bypass für jeden Angreifer verfügbar, der diese Domäne spoofet.

E-Mail-Authentifizierung

Das Ursprungsdokument fasst diesen Bereich kurz: „DKIM und SPF sind ein. DMARC: optional.“ Für 2023 war das eine vertretbare Priorisierung. **Für 2026 ist sie überholt** – aus zwei unabhängigen Gründen, die beide erst danach entstanden sind.

Grund eins: Das DMARC-Handling in der Anti-Phish-Policy (APH-03). Es setzt die DMARC-Policies *fremder* Absender durch. Wer selbst keine veröffentlicht, wird davon nicht geschützt – die eigene Domäne bleibt für Angreifer frei fälschbar, obwohl der Mechanismus, der das verhindern würde, im Tenant längst aktiv ist.

Grund zwei: Microsofts Sender Requirements seit Mai 2025 (AUTH-11). Absender, die mehr als 5.000 Nachrichten pro Tag an outlook.com, hotmail.com, live.com oder msn.com schicken, brauchen SPF, DKIM **und** DMARC mit funktionierendem Alignment. Sonst: 550 5.7.515, Reject.

DMARC ist damit vom Reifegrad-Thema zur Grundvoraussetzung geworden.

AUTH-01 bis AUTH-03 SPF

Der korrekte Record für Exchange Online 2026 – unverändert gegenüber 2023, es gibt keinen neuen Include:

```
v=spf1 include:spf.protection.outlook.com -all
```

Mit On-Prem-Servern, die direkt ins Internet zustellen:

```
v=spf1 ip4:<öffentliche Ausgangs-IP> include:spf.protection.outlook.com -all
```

Es gibt kein Cmdlet und kein Portal dafür. Microsoft wörtlich: „*There are no admin portals or PowerShell cmdlets in Microsoft 365 for you to manage SPF records in your domain.*“ SPF ist reine DNS-Arbeit beim Hoster.

```
Get-AcceptedDomain | Select-Object DomainName,DomainType,Default  
Resolve-DnsName -Name kunde.de -Type TXT | Where-Object { $_.Strings -match '^v=spf1' }
```

-all oder ~all? Microsoft empfiehlt für M365-Domänen -all (Hardfail). Der Vorbehalt ist praktischer Natur: Vorher muss wirklich jede legitime Versandquelle im Record stehen. Die Liste, die in der Praxis vergessen wird: Multifunktionsdrucker mit Scan-to-Mail, ERP- und CRM-System, Newsletter-Dienstleister, Bewerbermanagement, Monitoring, Fax-Gateway, Ticketsystem, Zeiterfassung, die Website mit ihrem Kontaktformular.

Das 10-Lookup-Limit. include:, a, mx, exists und redirect zählen; ip4:, ip6: und all nicht. Verschachtelte Includes zählen kumulativ. Bei Überschreitung schlägt SPF mit einem permerror fehl – und zwar für **alle** Nachrichten, nicht nur die betroffene Quelle. Ein Kunde mit M365, Newsletter-Tool, CRM, Monitoring und Fax-Gateway ist schnell am Limit.

Microsofts Lösungsweg dafür: **Subdomains**. Jede Subdomain hat ihr eigenes 10-Lookup-Budget. news.kunde.de für den Newsletter-Versand entlastet also die Hauptdomäne und isoliert zugleich den Reputationsschaden, wenn dort etwas schiefgeht.

Flattening – also das Auflösen von Includes in feste IP-Adressen – ist bei Drittanbietern mit dokumentiert stabilen IP-Bereichen vertretbar. Für `spf.protection.outlook.com` **niemals**: Microsoft nutzt dynamische Adressen, die sich häufig ändern.

Hybrid-Fallstricke, in der Reihenfolge ihrer Häufigkeit:

1. Die öffentliche Ausgangs-IP des On-Prem-Servers fehlt im Record. Alles, was nicht über EXO läuft, failt SPF.
2. Die Firewall macht Source-NAT auf eine andere IP als angenommen – die Load-Balancer-VIP ist nicht der Outbound-NAT-Pool.
3. Jede Subdomain braucht einen eigenen Record. Es gibt keine Vererbung.
4. Beim Providerwechsel wird der `ip4:-`Eintrag vergessen.

Ungenutzte und geparkte Domänen (AUTH-03) sind ein Punkt, der fast immer offen ist. Alte Marken-, Tippfehler- und Vorgängerdomänen liegen im Tenant, versenden nie – und sind deshalb ideal geeignet, um den Kunden bei sich selbst zu fälschen.

Absicherung:

```
SPF: v=spf1 -all
DMARC: v=DMARC1; p=reject;
```

Das gilt auch für die `*.onmicrosoft.com`-Domäne, wenn sie nicht für den Versand genutzt wird.

AUTH-04 und AUTH-05 DKIM

Was ohne Custom-DKIM passiert. Exchange Online signiert ausgehende Nachrichten automatisch – aber mit der `onmicrosoft.com`-Domäne. Das genügt technisch, ist aber **nicht DMARC-aligned**. Microsoft wörtlich: „*DKIM passes DMARC validation only if the domain that DKIM signed the message and the domain in the From address align.*”

Konkret:

Konstellation	DMARC-Ergebnis
From: user@kunde.de, DKIM d=kunde.de	Pass über DKIM
From: user@kunde.de, DKIM d=kunde.onmicrosoft.com	kein Alignment – DKIM trägt nichts bei

Die Konsequenz ist wichtiger, als sie klingt: Ohne Custom-DKIM hängt DMARC allein an SPF. **Und SPF bricht bei jeder Weiterleitung und bei jeder Mailingliste.** Damit ist `p=reject` ohne Custom-DKIM praktisch nicht betriebssicher – jede weitergeleitete Nachricht des Kunden würde beim Empfänger abgewiesen.

Custom-Domain-DKIM ist damit die faktische Voraussetzung für belastbares DMARC. Das ist der Grund, warum es in diesem Standard vor DMARC steht.

Der Ablauf:

```
New-DkimSigningConfig -DomainName kunde.de -Enabled $false -KeySize 2048
Get-DkimSigningConfig -Identity kunde.de | Format-List Selector1CNAME,Selector2CNAME
```

```
# → beide CNAMEs im DNS publizieren, Propagation abwarten
Set-DkimSigningConfig -Identity kunde.de -Enabled $true
```

Set-DkimSigningConfig -Enabled \$true schlägt fehl, solange die CNAMEs nicht auflösbar sind – das ist gewollt und ein nützlicher Selbsttest.

CNAME-Werte niemals selbst konstruieren. Das Format enthält ein tenantabhängiges Partitionszeichen, das sich nicht ableiten lässt:

```
selector1._domainkey → selector1-kunde-de._domainkey.kunde.n-v1.dkim.mail.microsoft
```

Immer aus Selector1CNAME und Selector2CNAME auslesen. Beide Records sind zwingend – fehlt der zweite, schlägt später die Schlüsselrotation fehl.

Statuswerte: NoDKIMKeys → CnameMissing → Valid.

Schlüssellänge. Der Default ist 1024 Bit. Microsoft unterstützt 2048, spricht dafür aber **keine ausdrückliche Empfehlung** aus – die Empfehlung in diesem Standard ist also eine eigene, keine zitierbare.

Zwei Fallstricke bei der Umstellung:

1. **Set-DkimSigningConfig hat keinen -KeySize-Parameter.** Die Schlüssellänge lässt sich nachträglich nur über Rotate-DkimSigningConfig ändern.
2. **Eine Rotation hebt nur den gerade inaktiven Selektor an.** Microsoft: „Upgrading the key size to 2048 only upgrades the selector that isn’t currently active.” Für beide Selektoren sind **zwei** Rotationen nötig, mit etwa 96 Stunden Abstand.

```
Rotate-DkimSigningConfig -Identity kunde.de -KeySize 2048
# nach ca. 96 Stunden Status prüfen und erneut rotieren:
Get-DkimSigningConfig -Identity kunde.de |
  Format-List Name,Status,RotateOnDate,Selector1KeySize,Selector2KeySize
Rotate-DkimSigningConfig -Identity kunde.de -KeySize 2048
```

Hybrid-Fallstrick. Nachrichten, die on-premises erzeugt und **direkt** ins Internet zugestellt werden, laufen nie über EXO und werden deshalb auch nicht von EXO signiert. Entweder man routet ausgehend über Exchange Online, oder man braucht eine On-Prem-Signierung – die Exchange Server nicht nativ beherrscht, dafür ist ein Transport-Agent eines Drittanbieters nötig. Die dabei verwendeten Selektoren müssen zusätzlich zu selector1 und selector2 im DNS stehen.

AUTH-06 und AUTH-07 DMARC

Es gibt kein Portal und kein Cmdlet für den eigenen DMARC-Record. Die Registerkarte „E-Mail-Authentifizierungseinstellungen“ im Defender-Portal enthält nur DKIM und ARC.

Microsofts empfohlener Rollout in drei Phasen, pro Domäne, Subdomains zuerst, Hauptdomäne zuletzt:

Phase	Record	Zweck
1	v=DMARC1; p=none; pct=100; rua=mailto:rua@kunde.de	Beobachten. Keine

Phase	Record	Zweck
		Zustellwirkung. Quellen inventarisieren.
2	v=DMARC1; p=quarantine; pct=100; rua=...	Durchsetzen, optional gestuft über pct=10 → 25 → 50 → 100
3	v=DMARC1; p=reject; pct=100; rua=...	Zielzustand

Phase 1 sollte mindestens vier Wochen laufen. Ihr eigentlicher Zweck ist die Inventur: Die Aggregate-Reports zeigen, welche Systeme tatsächlich im Namen der Domäne versenden. In der Praxis tauchen dort regelmäßige Quellen auf, die im Kundengespräch niemand genannt hatte.

Fallstricke beim Reporting, die in der Praxis regelmäßig für Verwirrung sorgen:

- **Externe rua-Adresse braucht einen Autorisierungs-Record.** Liegt die Reporting-Adresse in einer fremden Domäne – also bei praktisch jedem DMARC-Analysedienst –, muss die *Zieldomäne* publizieren:


```
kunde.de._report._dmarc TXT "v=DMARC1;"
```

Fehlt der Record, verwerfen konforme Reporter die Reports. Der Kunde wundert sich dann, warum das teuer eingekaufte Dashboard leer bleibt.
- **Microsoft sendet keine Forensic-Reports.** Wörtlich: „*Microsoft 365 doesn't send DMARC Forensic reports (also known as DMARC Failure reports), even if a valid ruf=mailto: address exists.*“ Andere Provider tun es. Datenschutzrechtlich ist das relevant, weil Failure-Reports Nachrichteninhalte enthalten können.
- **Aggregate-Reports von Microsoft setzen voraus, dass der MX der Empfängerdomäne direkt auf M365 zeigt.** Bei vorgeschaltetem Gateway sendet M365 keine.
- **rua= immer auf ein dediziertes Postfach**, nie auf ein Benutzerpostfach. Das Volumen ist erheblich.

Eine Nebenwirkung beim ausgehenden Verkehr, die man kennen sollte:

Ausgehende Nachrichten aus M365-Domänen, die beim Empfänger DMARC brechen, werden über den High-Risk Delivery Pool geroutet, wenn die Domäne p=reject oder p=quarantine veröffentlicht – ohne Möglichkeit, das zu übersteuern. Relevant für Kunden, deren Anwendungen fremde Absenderdomänen über EXO relayen.

AUTH-08 ARC

Die Einschätzung im Ursprungsdokument – „ein recht proprietäres Verfahren“ – ist als **Skepsis berechtigt**, auch wenn ARC formal ein offener Standard ist (RFC 8617).

Wofür es gebraucht wird. Wenn ein zwischengeschalteter Dienst Nachrichten verändert – Disclaimer anhängt, Anhänge entfernt, URLs umschreibt, Banner einfügt –, bricht die DKIM-Signatur. Ein ARC-Sealer bezeugt in dem Fall das ursprüngliche Authentifizierungsergebnis. EOP kann dieser Bezeugung vertrauen, wenn der Sealer als vertrauenswürdig eingetragen ist.

Typische Fälle: vorgelagerte Security-Gateways (Proofpoint, Mimecast, Barracuda, Sophos), Mailinglisten mit Betreff-Präfix und Footer, Weiterleitungen über Drittsysteme.

Warum die Skepsis berechtigt ist. Ein Trusted Sealer darf beliebige Authentifizierungsergebnisse bezeugen. Wer dort eine Domäne einträgt, die er nicht kontrolliert oder nicht braucht, öffnet einen Umgehungsweg für den gesamten Spoof-Schutz. Die Liste gehört minimal gehalten.

Zwei praktische Punkte:

- Der d=-Wert muss aus einem **echten ARC-Seal-Header einer Testnachricht** stammen. Nicht raten, nicht die eigene Domäne eintragen.
- **Set-ArcConfig ersetzt die gesamte Liste.** Ein naives Set-ArcConfig - ArcTrustedSealers "neuer.de" löscht alle bestehenden Einträge. Immer additiv arbeiten:

```
$sealers = @(Get-ArcConfig | Select-Object -ExpandProperty ArcTrustedSealers)
$sealers += "pphosted.com"
Set-ArcConfig -Identity Default -ArcTrustedSealers $sealers
```

Get-ArcConfig hat keinen -Identity-Parameter und liefert nichts zurück, wenn keine Sealer konfiguriert sind.

Verhältnis zu Enhanced Filtering. Die beiden lösen unterschiedliche Teilprobleme desselben Szenarios:

	Enhanced Filtering	Trusted ARC Sealer
Löst	verlorene Quell-IP	gebrochene Signaturen durch Inhaltsänderung
Konfiguriert auf	Inbound Connector	tenantweit
Voraussetzung	man kennt die Gateway-IPs	Gateway unterstützt ARC-Sealing

In der Praxis werden beide kombiniert. Wenn das Gateway kein ARC beherrscht, bleibt nur Enhanced Filtering.

Nicht nötig ist ARC, wenn der weiterleitende Dienst selbst ein Microsoft-365-Tenant ist – diese Signaturen werden automatisch akzeptiert.

AUTH-09 und AUTH-10 Transportverschlüsselung

Die Anforderungen „STARTTLS“ und „STARTTLS per Policy erzwingen“ aus dem Ursprungsdokument haben 2026 differenziertere Antworten.

MTA-STS. Ein Standard, mit dem eine Domäne veröffentlicht, dass Post an sie nur über verifiziertes TLS zugestellt werden darf.

- **Ausgehend ist MTA-STS in Exchange Online immer aktiv** – „*always turned on like other core SMTP features*“, keine Konfiguration nötig. EXO respektiert also die MTA-STS-Policies der Empfängerdomänen automatisch.
- **Eingehend muss der Kunde selbst publizieren.** Es gibt weder Portal noch Cmdlet:

```
_mta-sts.kunde.de    TXT    "v=STSv1; id=20260807120000Z;"
```

plus eine Policy-Datei per HTTPS unter <https://mta-sts.kunde.de/.well-known/mta-sts.txt>:

```
version: STSv1
mode: enforce
mx: *.mail.protection.outlook.com
max_age: 604800
```

Erst mit mode: testing starten, dann auf enforce wechseln. Microsoft empfiehlt als Hosting Azure Static Web Apps, weil dort das TLS-Zertifikat automatisch bereitgestellt wird.

NDR-Codes bei fehlgeschlagener Validierung: 5.4.8 (Ziel-MX nicht in der Policy) und 5.7.5 (Zertifikatsproblem).

SMTP DANE mit DNSSEC. Ausgehend ebenfalls automatisch aktiv (SmtpDaneMode Opportunistic als Default am Outbound Connector). Eingehend ist es inzwischen produktiv konfigurierbar, aber in zwei Schritten und ausschließlich per PowerShell:

```
Enable-DnssecForVerifiedDomain -DomainName kunde.de
Enable-SmtpDaneInbound -DomainName kunde.de
Get-DnssecStatusForVerifiedDomain -DomainName kunde.de
```

Das erste Cmdlet gibt einen **kundenspezifischen MX-Wert** aus, der beim Hoster gesetzt und dessen Delegation DNSSEC-signiert werden muss; die TLSA-Records erzeugt Microsoft selbst. Damit hängt eingehendes DANE am MX-Ziel – in Gateway- oder Hybrid-Empfangsszenarien, in denen der MX auf ein vorgelagertes System zeigt, bleibt es außen vor. Den erreichten Stand je Zieldomäne zeigt im Exchange Admin Center der Bericht *Outbound messages in Transit Security*.

Zur Korrektur einer verbreiteten Annahme: **Ein Set-SmtpDaneInboundStatus gibt es nicht.** Es existieren Get-SmtpDaneInboundStatus, Enable-SmtpDaneInbound, Disable-SmtpDaneInbound, Enable-DnssecForVerifiedDomain und Get-DnssecStatusForVerifiedDomain.

TLS zu einem definierten Partner erzwingen – das ist die direkte Umsetzung von „STARTTLS per Policy erzwingen“:

```
New-OutboundConnector -Name "Secure to Partner" -ConnectorType Partner `
  -RecipientDomains partner.de -UseMXRecord $true `
  -TlsSettings DomainValidation -TlsDomain "/*.partner.de"
```

Die Stufen von schwach nach stark: EncryptionOnly (verschlüsselt, aber ohne Zertifikatsprüfung), CertificateValidation (Zertifikat muss gültig und vertrauenswürdig sein), DomainValidation (zusätzlich Prüfung des Zertifikat-FQDN gegen TlsDomain).

TlsDomain wirkt nur bei DomainValidation.

Für die Gegenrichtung: `Set-InboundConnector -RequireTls $true -TlsSenderCertificateName <Zertifikatsdomäne>`.

Nicht verwechseln mit `RouteAllMessagesViaOnPremises` – das erzwingt Centralized Mail Transport und verändert den gesamten Ausgangspfad. Als TLS-Maßnahme ist es das falsche Werkzeug.

AUTH-11 Microsoft Sender Requirements

Seit Mai 2025 in Kraft. Wer von derselben From-Domäne mehr als 5.000 Nachrichten pro Tag an Microsoft-Consumer-Dienste (outlook.com, hotmail.com, live.com, msn.com) schickt, muss erfüllen:

1. **SPF** publiziert, Nachricht aus autorisierter Quelle
2. **DKIM** aktiviert und signiert
3. **DMARC** mindestens `p=none`
4. **Alignment** über SPF und/oder DKIM – mindestens eines muss zur From-Domäne passen

Sonst wird die Zustellung abgelehnt: `550 5.7.515 Access denied, sending domain <domain> does not meet the required authentication level.`

Hinweis zur Durchsetzungsstufe: Microsoft hat die Ankündigung Ende April 2025 angepasst. Die erste Stufe war Zustellung in den Junk-Ordner, die Ablehnung wurde für einen später anzukündigenden Zeitpunkt vorgesehen. Der Fehlercode ist belegt; ob im konkreten Fall abgelehnt oder gejunkt wird, vor dem Kundengespräch am Microsoft-Blog gegenprüfen.

Der Klebe-Effekt. Einmal überschritten, gelten die Anforderungen dauerhaft – auch wenn das Volumen danach wieder sinkt.

Wen betrifft das konkret? Nicht den typischen Mittelstands-Tenant mit reiner Geschäftskorrespondenz. Sehr wohl aber:

- Newsletter und Marketing an Privatkundenverteiler
- Transaktionsmail: Rechnungen, Bestellbestätigungen, Passwort-Resets an Privatadressen
- Vereins- und Verbandsmailings
- Terminerinnerungen von Praxen, Kanzleien, Handwerksbetrieben

Bei Kommunalversorgern und Stadtwerken ist die Schwelle mit Jahresverbrauchsabrechnungen an Privatkunden schnell erreicht.

Was beim Dienstleister zu prüfen ist. Der Versanddienstleister muss From-Adresse, Return-Path und DKIM-Signierung auf die Kundendomäne oder eine ausgerichtete Subdomain umstellen. Viele Standardkonfigurationen verwenden die Domäne des Dienstleisters im `MAIL FROM` – dann gibt es kein SPF-Alignment, und die DMARC-Prüfung hängt allein an DKIM.

Anmerkung: „High Volume Email (HVE) for Microsoft 365“ ist hierfür kein Lösungsweg. HVE ist ausschließlich für interne Empfänger im eigenen Tenant gedacht und kann nicht ins Internet zustellen.

Enhanced Filtering for Connectors

EF-01 Bedarf richtig bewerten

Die Aussage im Ursprungsdokument: „Im Normalfall nicht benötigt.“

Bewertung: bedingt richtig – als pauschale Regel aber gefährlich. Das ist einer der wenigen Punkte, an denen dieser Guide dem Ursprungsdokument ausdrücklich widerspricht.

Wann die Aussage stimmt. Wenn der MX-Record der Kundendomäne direkt auf *.mail.protection.outlook.com zeigt und kein Dienst dazwischensitzt. Dann sieht EOP ohnehin die echte Quell-IP, und Enhanced Filtering wäre nicht nur überflüssig, sondern schädlich – ein Skip der letzten IP würde genau die tatsächliche Absender-IP überspringen.

Wann sie falsch ist – und diese Fälle sind im deutschen Mittelstand alles andere als selten:

- vorgelagerter Managed-Spamfilter (Hornetsecurity, NoSpamProxy Cloud, Retarus, Proofpoint, Mimecast, Securepoint)
- Hybrid mit MX auf dem On-Prem-Server oder einem Edge-Transport
- Firewall oder UTM mit SMTP-Proxy (Sophos, Fortinet FortiMail, Barracuda)
- Archivierungs- oder Compliance-Gateway im Empfangspfad
- Multi-Hop-Routing über ein Konzern-Relay

Was ohne Enhanced Filtering passiert, wenn ein Gateway davorsteht:

Problem	Wirkung
Falsche Quell-IP	EOP sieht die Gateway-IP statt der echten. SPF und DMARC prüfen gegen den falschen Host.
DMARC systematisch falsch	Alle Ergebnisse sind wertlos – und damit auch HonorDmarcPolicy.
Spoof Intelligence degradiert	Die Modelle arbeiten mit falschen Quelldaten.
Forensik	Der Nachrichtenursprung ist nicht mehr zurückverfolgbar.
Prüfmodus	Rückfall von expliziter Authentifizierung auf implizite Heuristik.

Enhanced Filtering ist in diesen Fällen also kein Feinschliff, sondern Voraussetzung dafür, dass die IP-basierten Prüfungen überhaupt auf korrekten Daten arbeiten.

Für die Kundenmethodik:

Enhanced Filtering ist nur erforderlich, wenn dem EOP ein weiterer MTA vorgeschaltet ist – dann aber zwingend. Prüfkriterium: Zeigt der MX-Record der Domäne direkt auf Exchange Online?

Das richtige Cmdlet. Nicht Set-HostedConnectionFilterPolicy (das ist der Connection Filter), sondern **Set-InboundConnector**:

```
Resolve-DnsName -Name kunde.de -Type MX
Get-InboundConnector | Format-List
Name, Enabled, ConnectorType, SenderIPAddresses, EFSkipLastIP, EFSkipIPs, EFUsers
```

```
# Ein vorgelagerter Hop
Set-InboundConnector -Identity "From Gateway" -EFSkipLastIP $true
```

```
# Pilotierung auf einzelne Empfänger
Set-InboundConnector -Identity "From Gateway" -EFSkipLastIP $true -EFUsers
"test1@kunde.de", "test2@kunde.de"
```

Parameter	Bedeutung
EFSkipLastIP	\$true: nur die letzte Quelle wird übersprungen, automatisch erkannt. Der Normalfall bei einem einzelnen Gateway.
EFSkipIPs	Explizite Liste zu überspringender IPs. Nur wirksam, wenn EFSkipLastIP auf \$false steht.
EFUsers	Auf welche Empfänger Enhanced Filtering angewendet wird. Leer = alle.

EFSkipMailGateway und EFTestMode sind als „reserved for internal Microsoft use“ gekennzeichnet und dürfen nicht verwendet werden.

EF-02 Fallstricke

1. Konkurrierende SCL(-1)-Regeln müssen weg. Microsoft formuliert das als Pflicht („must disable“). Eine Transportregel, die Nachrichten über diesen Connector von der Filterung ausnimmt, hebt genau das auf, was Enhanced Filtering gerade wiederhergestellt hat. Das ist der häufigste Grund, warum eine korrekt konfigurierte Skip-Listung nichts bewirkt.

2. EFUsers braucht exakte Adressen. Die primäre SMTP-Adresse deckt keine Alias-Adressen ab. Hat ein Postfach fünf Adressen, müssen alle fünf gelistet werden.

3. In Hybrid ist die TargetAddress zu verwenden, nicht die primäre SMTP-Adresse – also user@kunde.mail.onmicrosoft.com.

4. Alles-oder-nichts pro Nachricht. Enthält eine Nachricht auch nur einen Empfänger, der nicht in EFUsers steht, gilt für **alle** Empfänger dieser Nachricht die normale Filterung. Bei einer Pilotierung mit fünf Testnutzern greift die Skip-Listung also nur bei Nachrichten, die ausschließlich an diese fünf gehen.

5. Verbotene IP-Bereiche. Microsoft-365-IPs dürfen nicht eingetragen werden (das bricht die Filterung). Loopback und RFC-1918-Adressen werden automatisch übersprungen – Gateways brauchen also öffentliche Adressen.

6. Zur Verifikation gibt es zwei Header: X-MS-Exchange-ExternalOriginalInternetSender (nur bei erfolgreichem Skip und Empfängertreffer) und X-MS-Exchange-SkipListedInternetSender (immer, wenn Enhanced Filtering am Connector aktiv ist – nützlich für What-if-Analysen).

Kennzeichnung externer E-Mails

Das Ursprungsdokument behandelt dieses Thema am ausführlichsten von allen und schließt mit einem Satz, der weiterhin richtig ist:

„Mit Kunden muss allerdings eine Diskussion geführt werden, welche Variante gewünscht/gewollt ist.“

Was dieser Guide ergänzt, ist die Entscheidungsgrundlage für diese Diskussion – denn die drei Ansätze sind nicht gleichwertig.

EXT-01 Das native External-Tag

Der Kommentar im Ursprungsdokument nennt das richtige Cmdlet, die Begründung ist aber zu korrigieren. Dort steht:

„Korrigiert mich, aber das ist doch nur der First Contact Safety Tip und keine Kennzeichnung als externe Mail. Das Feature müsste über die Exchange Online Powershell aktiviert werden. `Set-ExternalInOutlook -Enabled $true`“

Das Cmdlet ist richtig. Die Aussage, es handele sich „nur um den First Contact Safety Tip“, trifft aber nicht zu. **Das sind zwei völlig getrennte Features:**

	External Sender Identification	First Contact Safety Tip
Cmdlet	<code>Set-ExternalInOutlook -Enabled \$true</code>	<code>Set-AntiPhishPolicy -EnableFirstContactSafetyTips \$true</code>
Objekt	organisationsweites Einzelobjekt	Anti-Phishing-Policy, mit Empfängerbereich
Auslöser	jede Mail von außerhalb der Organisation	Absender, von dem der Empfänger selten oder erstmals Post bekommt – auch intern möglich
Darstellung	„External“-Tag an der Betreffzeile	Textzeile im Nachrichtenkopf: „Sie erhalten nicht oft eine E-Mail von ...“
Häufigkeit	dauerhaft	einmalig pro Absender

Beide sollten parallel aktiv sein. Sie beantworten unterschiedliche Fragen: „Kommt das von draußen?“ und „Ist das jemand Neues?“

```
Get-ExternalInOutlook | Format-List Enabled,AllowList
Set-ExternalInOutlook -Enabled $true
```

Eigenschaften des Features:

- Wirksamkeit erst nach **24 bis 48 Stunden**, und nur für neu eingehende Nachrichten – nicht rückwirkend.

- Es greift **nicht in den Nachrichtentext ein**. Deshalb keine Probleme mit S/MIME, keine Interferenz mit Safe Attachments, keine doppelten Banner in Antwortketten.
- AllowList: maximal 200 Einträge, insgesamt 8 KB. Der Abgleich erfolgt auf die From-Adresse.
- Lizenz: Exchange Online, jeder Plan. Keine MDO-Lizenz nötig.
- **Nicht verfügbar für on-premises-Postfächer.**

Zur Clientabdeckung: Microsoft nennt „Outlook, Outlook for Mac, Outlook on the web, and Outlook for iOS and Android“. Zwischen klassischem und neuem Outlook für Windows unterscheidet die Dokumentation nicht. Für den konkreten Kunden empfiehlt sich ein Sichttest nach der Aktivierung – das ist ohnehin der Moment, in dem man die Wirkung zeigen will.

EXT-02 Die drei Varianten im Vergleich

Kriterium	Natives External-Tag	Transportregel-Banner	First Contact Safety Tip
Was der Nutzer sieht	„External“-Tag an der Betreffzeile	frei gestaltbarer HTML-Block im Nachrichtentext	Textzeile im Kopf, bei seltenem Absender
Auslöser	jede externe Mail	jede Mail, die die Regel trifft	nur erster/seltener Kontakt
Eingriff in den Text	nein	ja	nein
Clientabdeckung	Outlook-Familie	alle Clients – ist Teil des Textes	Clients, die Safety Tips darstellen
Aufwand	1 Cmdlet	Regeldesign, Ausnahmen, HTML, Testphase	1 Parameter je Policy
Nebenwirkungen	keine bekannten	S/MIME, Safe Attachments, Duplikate, Kalender, Hybrid	sehr gering
Microsoft-Empfehlung	keine ausdrückliche Aussage	keine ausdrückliche Aussage	ausdrücklich empfohlen

Empfehlung für diesen Standard:

1. **First Contact Safety Tip immer aktivieren.** Einziger der drei Ansätze mit ausdrücklicher Microsoft-Empfehlung, kostenlos, nebenwirkungsarm – und ab Werk aus.
2. **Natives External-Tag aktivieren.** Ein Cmdlet, kein Eingriff in den Nachrichtentext.
3. **Transportregel-Banner nur**, wenn die Clientabdeckung im konkreten Tenant nachweislich nicht ausreicht oder ein Body-Hinweis regulatorisch gefordert ist.

Ehrlichkeitshinweis: Es gibt keine Microsoft-Aussage, die Transportregel-Banner generell ab- oder anrät. Das häufig zitierte Argument, Dauerbanner würden zu Gewöhnung führen, ist Erfahrungswissen und keine belegte Microsoft-Position – im Kundengespräch bitte auch so darstellen.

Ein Punkt, der aber belegbar ist: **Variante I und Variante II parallel zu betreiben ist redundant** und führt zu doppelter Kennzeichnung. Auch das gehört bewusst entschieden.

EXT-03 Wenn der Transportregel-Banner gewählt wird

Der Screenshot im Ursprungsdokument zeigt die Regel „External mail sender“: Prepend, Ausnahme für automatische Antworten, Priority 64, Mode Enforce. Daran sind zwei Dinge zu korrigieren und einiges zu ergänzen.

Der wichtigste Fallstrick

`ApplyHtmlDisclaimerFallbackAction` **darf nicht auf Wrap stehen**. Microsoft wörtlich:

„Don't use the value Wrap in rules that affect incoming messages from external senders. Use the value Reject instead. The effects of the value Wrap interfere with Safe Attachments scanning of messages from external senders.“

Wrap ist der Default. Wer den Parameter beim Anlegen weglässt, bricht also Safe Attachments für genau die Nachrichten, die er kennzeichnen wollte – für alle externen Mails, bei denen der Banner nicht eingefügt werden kann.

Da `Reject` (Unzustellbarkeitsmeldung an den externen Absender) für ein reines Kennzeichnungsszenario unverhältnismäßig ist, bleibt praktisch **Ignore**: Der Banner wird dann bei verschlüsselten und signierten Nachrichten weggelassen, die Nachricht aber normal zugestellt und normal gescannt.

```
Get-TransportRule -Identity "External mail sender" |  
    Format-List  
Name,State,Mode,Priority,FromScope,ApplyHtmlDisclaimerLocation,ApplyHtmlDisclaimerFallbackAction
```

```
Set-TransportRule -Identity "External mail sender" -ApplyHtmlDisclaimerFallbackAction  
Ignore
```

Werte, die es in Exchange Online nicht gibt

Die Cmdlet-Referenz ist ein gemeinsames Dokument für Exchange Server und Exchange Online und listet beide Wertemengen. In Exchange Online gilt:

- `FromScope`: nur `InOrganization` und `NotInOrganization`. Die Werte `Inside`, `Outside`, `ExternalPartner` und `ExternalNonPartner` gehören zum on-premises-Enum und werden abgelehnt.
- `ExceptIfMessageTypeMatches`: gültig sind `00F`, `AutoForward`, `Encrypted`, `Calendaring`, `PermissionControlled`, `Voicemail`, `Signed`, `ApprovalRequest`, `ReadReceipt`. **Ein Wert `AutomaticReply` existiert nicht** – das UI-Label lautet so, der PowerShell-Wert heißt `00F`. Kalendereinladungen sind `Calendaring`.

- `ExceptIfMessageTypeMatches` **akzeptiert nur einen Wert pro Regel**. Wer Autoreplies und Kalendereinladungen ausnehmen will, braucht zwei Regeln oder einen anderen Ausnahmetyp.

Doppelte Banner in Antwortketten

Microsoft empfiehlt eine Ausnahme, die auf einen eindeutigen Text im Banner prüft. In der Praxis ist das fehleranfällig, weil der Bannertext in zitierten Antworten mitläuft. Robuster ist der Weg über einen Marker-Header:

Regel 1: Marker setzen

```
New-TransportRule -Name "EXT-Marker" -FromScope NotInOrganization -SentToScope InOrganization `
  -SetHeaderName "X-EXT-Banner" -SetHeaderValue "applied" -Priority 0 -Mode Enforce
```

Regel 2: Banner, aber nicht wenn der Marker schon da ist

```
New-TransportRule -Name "EXT-Banner" -FromScope NotInOrganization -SentToScope InOrganization `
  -ApplyHtmlDisclaimerLocation Prepend `
  -ApplyHtmlDisclaimerText '<div style="border:1px solid #9B9A87;padding:6px;background:#FE642E;font-family:Arial,sans-serif;font-size:11pt;"><b>ACHTUNG:</b> Diese E-Mail stammt von außerhalb der Organisation. Klicken Sie keine Links und &ouml;ffnen Sie keine Anh&auml;nge, wenn Sie den Absender nicht kennen.</div><br>' `
  -ApplyHtmlDisclaimerFallbackAction Ignore `
  -ExceptIfHeaderMatchesMessageHeader "X-EXT-Banner" -ExceptIfHeaderMatchesPatterns "applied" `
  -ExceptIfMessageTypeMatches Calendaring `
  -Priority 1 -Mode Audit
```

Hybrid-Besonderheit

`FromScope NotInOrganization` greift, sobald Exchange Online den Absender **nicht** als organisationsintern authentifiziert. In Hybrid-Umgebungen, bei Centralized Mail Transport oder mit vorgeschalteten Gateways kann interner Verkehr fälschlich als extern eingestuft werden – dann tragen interne Mails den Banner.

Die naheliegende Gegenmaßnahme `-ExceptIfSenderDomainIs <eigene Domänen>` ist **die falsche**: Die From-Domäne ist trivial fälschbar. Ein Angreifer, der die Kundendomäne spoof, erbt damit genau die Banner-Ausnahme – bei einem Feature, dessen Zweck die Warnung vor genau solchen Nachrichten ist.

Richtig ist `-ExceptIfSenderIpRanges` mit den eigenen Ausgangs-IPs. Und darüber hinaus: Enhanced Filtering konfigurieren, damit Exchange Online die tatsächliche Ursprungs-IP wieder auswertet (EF-01).

Vor Enforce testen

Microsoft empfiehlt ausdrücklich, jede Transportregel zunächst im Modus `Audit` oder `AuditAndNotify` zu betreiben. Bei einer Banner-Regel, die jede eingehende Mail des Unternehmens anfasst, ist das keine Formalie.

Zwei weitere Punkte: Der Disclaimer-Text ist auf **5.000 Zeichen** begrenzt. Und bei reinen Text-Nachrichten wird das HTML-Markup nicht gerendert – der Text sollte also auch ohne Formatierung lesbar bleiben.

Reporting und Alerting

Die Anforderungstabelle des Ursprungsdokuments nennt „Es gibt ein konfigurierbares Reporting hierüber“ und beantwortet das mit „Ja (diverse)“. Das stimmt, ist aber der Punkt, der in der Praxis am seltensten umgesetzt wird. Eine Härtung, deren Wirkung niemand beobachtet, wird beim ersten Fehlalarm zurückgedreht.

REP-01 Berichte

Die für das Assessment relevanten Berichte im Defender-Portal:

Bericht	Zweck
Threat protection status	Was wurde blockiert, in welcher Kategorie
Mailflow status summary	Gesamtvolumen ein- und ausgehend, Filterquoten
Spoof detections	Wer versucht, im Namen der eigenen Domänen zu schreiben
Compromised users	Nutzer mit auffälligem Sendeverhalten – 7 Tage
Top senders and recipients	Auffälligkeiten im Volumen
Submissions	Was Nutzer und Admins gemeldet haben
URL protection	Klicks auf blockierte Links – nur mit MDO

Alle unterstützen „Create schedule“ für den automatischen Versand. Bei einem Kunden ohne eigenes Security-Team ist ein wöchentlicher Threat-Protection-Status-Bericht an die IT-Leitung das Minimum – er hält das Thema sichtbar und liefert die Zahlen für den nächsten Termin.

Verschobene Berichte, falls jemand sie sucht: URL trace → URL protection report; Malware- und Spam-Detections → Threat protection status; Exchange transport rule report → Exchange Admin Center; Forwarding report → EAC, Auto forwarded messages.

```
Get-MailFlowStatusReport -StartDate (Get-Date).AddDays(-7) -EndDate (Get-Date) -Direction Inbound
Get-SpoofMailReport -StartDate (Get-Date).AddDays(-7) -EndDate (Get-Date)
```

Für Skripte relevant: Get-MailTrafficPolicyReport verlangt künftig zwingend -EventType TransportRuleHits oder TransportRuleActionHits, um Transportregel-Daten zu liefern (Message Center MC1323250). Ohne den Parameter kommen leere Ergebnisse zurück – ohne Fehlermeldung.

REP-02 Alert Policies

Der Ersatz für das abgekündigte NotifyOutboundSpam. Eingebaute Policies mit Relevanz für EOP:

Alert	Schwere	Lizenz
User restricted from sending email	Hoch	E1/E3/E5
Suspicious email sending patterns detected	Mittel	E1/E3/E5
Suspicious connector activity	Hoch	E1/E3/E5
Tenant restricted from sending unprovisioned email	Hoch	E1/E3/E5
Email messages containing malware removed after delivery	Info	E1/E3/E5
Email messages containing phish URLs removed after delivery	Info	MDO P1
A potentially malicious URL click was detected	Hoch	MDO P2 / E5

Der wichtigste ist „User restricted from sending email“ – er feuert genau dann, wenn ActionWhenThresholdReached BlockUser (ASO-03) greift, also bei einem vermutlich kompromittierten Konto.

Der Prüfpunkt ist die Empfängerliste. Ab Werk gehen die Benachrichtigungen an die Mitglieder der Gruppe *TenantAdmins*, also an die globalen Administratoren. Bei vielen Kunden ist das ein Konto, das niemand liest. Die Empfänger gehören auf den Verteiler, der tatsächlich reagiert.

Bei eingebauten Policies sind **nur drei Dinge änderbar**: an/aus, Empfänger, Tageslimit. Microsoft wörtlich: „*The other settings for these policies can't be edited.*“ Und: „*You cannot modify default alert policies—only those created with New-ProtectionAlert.*“

Wichtiger technischer Hinweis für Skripte: Get-ProtectionAlert ist das **einzige** Cmdlet in diesem gesamten Standard, das eine Security-&-Compliance-Session braucht:

```
Connect-IPPSSession
Get-ProtectionAlert | Where-Object { $_.Category -eq 'ThreatManagement' } |
    Format-Table Name,Severity,Disabled,NotifyUser
```

Entgegen einer verbreiteten Annahme laufen Get-QuarantinePolicy, Get-TenantAllowBlockListItems und Get-ReportSubmissionPolicy **nicht** über Connect-IPPSSession, sondern über Connect-ExchangeOnline.

Änderungen an Alert Policies brauchen bis zu 24 Stunden, bis sie greifen.

REP-03 Meldeweg für Nutzer

Ohne funktionierenden Meldeweg fehlt der Rückkanal, über den sich die Filterqualität verbessert – und die Nutzer haben keine Alternative dazu, verdächtige Mails einfach zu löschen oder eben doch anzuklicken.

```
Get-ReportSubmissionPolicy | Format-List
EnableReportToMicrosoft,ReportJunkToCustomizedAddress,ReportJunkAddresses,EnableThirdPartyAddress,DisableQuarantineReportingOption
Set-ReportSubmissionPolicy -Identity DefaultReportSubmissionPolicy -EnableReportToMicrosoft $true
```

Es gibt genau eine Policy (DefaultReportSubmissionPolicy) und eine Rule (DefaultReportSubmissionRule).

Zwei Konsistenzregeln, deren Verletzung schwer zu diagnostizieren ist: Die drei Parameter ReportJunkToCustomizedAddress, ReportNotJunkToCustomizedAddress und ReportPhishToCustomizedAddress müssen **identisch** gesetzt sein. Und die konfigurierten Adressen müssen dem -SentTo der zugehörigen Rule entsprechen.

Für Kunden mit interner IT ist die Kombination sinnvoll: Meldung an Microsoft **und** an ein internes Postfach. Microsoft verbessert die Erkennung, die interne IT bekommt mit, was im Haus ankommt.

REP-04 Message Trace

Get-MessageTrace und Get-MessageTraceDetail sind offiziell abgelöst: „*This cmdlet is replaced by the Get-MessageTraceV2 cmdlet and will eventually be deprecated.*“ Ein Abschalt datum ist nicht genannt.

Was sich für Skripte ändert:

- **-Page und -PageSize gibt es nicht mehr.** Paginierung läuft über StartingRecipientAddress und EndDate als Cursor aus dem vorherigen Ergebnis. Wer ein Altskript portiert, muss diese Logik neu bauen.
- Aufbewahrung 90 Tage, aber **maximal 10 Tage je Abfrage**. Ohne Datumsangabe werden nur die letzten 48 Stunden geliefert.
- -ResultSize von 1 bis 5000, Default 1000.
- Throttling: maximal 100 Abfragen je rollierendem 5-Minuten-Fenster.

```
Get-MessageTraceV2 -StartDate (Get-Date).AddDays(-2) -EndDate (Get-Date) `
-RecipientAddress "user@kunde.de" | Format-Table Received,SenderAddress,Subject,Status
```

Hybrid und On-Premises

Das Ursprungsdokument enthält unter „Lokale Konfiguration“ zwei Punkte: die Einschränkung des Default Receive Connectors und ausgehende Firewall-Regeln. Beide bleiben relevant. Dazu kommen drei Themen, die 2023 noch nicht existierten und heute jedes Hybrid-Projekt betreffen.

HYB-01 Exchange Server im Support

Support-Ende für Exchange Server 2016 und 2019: 14. Oktober 2025. Beide Versionen am selben Tag. Nach diesem Datum gibt es keine Sicherheitsupdates mehr – die Server laufen weiter, aber jede neue Schwachstelle bleibt offen.

Microsoft hat ein kostenpflichtiges Extended-Security-Update-Programm aufgelegt, das laut Ankündigung im Oktober 2026 endet. Damit ist der Zeitdruck für Bestandskunden real.

Exchange Server Subscription Edition (SE) ist seit Juli 2025 verfügbar. Die RTM-Codebasis entspricht Exchange 2019 CU15 – neue Funktionen kommen erst ab CU1. Nur noch Mailbox- und Edge-Transport-Rolle, Unified Messaging ist entfernt.

Upgrade-Pfade:

Von	Nach SE
Exchange 2019 CU14/CU15	In-Place-Upgrade möglich, geringes Risiko
Exchange 2016	kein direkter Weg – erst auf 2019 CU14/CU15, dann SE. Oder neuen SE-Server aufsetzen und Postfächer verschieben.
Exchange 2013	erst auf 2019 CU14, 2013 vollständig entfernen, dann SE

Ein Punkt, der bei Hybrid-Kunden regelmäßig für Überraschung sorgt: Der kostenlose Hybrid-Lizenzschlüssel existiert für Exchange 2019 und SE **nicht mehr**. Microsoft wörtlich: „*The free Exchange Server license isn't available for Exchange 2019 or later hybrid servers.*“ Er gab es für 2010 SP3, 2013 und 2016.

Für Kunden, die nur noch einen Hybrid-Server zur Verwaltung betreiben, dokumentiert Microsoft inzwischen einen Weg über die **Exchange Management Tools ohne laufenden Server**. Voraussetzungen: alle Postfächer in Exchange Online, Recipient-Verwaltung über AD mit Entra Connect, keine On-Prem-EAC-Nutzung. Wichtigster Fallstrick dabei: Den letzten Exchange Server **nicht deinstallieren, sondern nur herunterfahren** – Setup /m:Uninstall entfernt AD-Konfigurationscontainer, die die Management Tools brauchen.

Zur Lizenzierung von SE und der Management Tools: Die konkreten Bedingungen stehen in den Product Terms, nicht in der öffentlichen Dokumentation. Für Kundenzusagen über Volume Licensing absichern.

HYB-02 Dedizierte Exchange-Hybrid-App

Dieser Punkt fehlt im Ursprungsdokument, weil es ihn 2023 nicht gab. Er ist inzwischen erzwungen.

Der Hintergrund. Bis 2025 nutzte die Hybrid-Verbindung einen von allen Tenants geteilten First-Party-Service-Principal. Über diesen konnte ein kompromittierter On-Prem-Exchange Tokens für den Cloud-Tenant ausstellen – Lateral Movement von on-premises in die Cloud, ohne Spuren im Cloud-Audit. Die Schwachstellenklasse ist als **CVE-2025-53786** dokumentiert.

Microsoft hat den geteilten Service Principal durch eine **pro Organisation dedizierte Entra-App** ersetzt.

Der harte Termin: 31. Oktober 2025. Seitdem ist der EWS-Zugriff über den geteilten Service Principal **permanent blockiert**. Ohne Umstellung brechen Free/Busy-Abfragen, MailTips und Profilbilder zwischen on-premises und Cloud – vollständig. On-Prem-Nutzer können die Kalenderverfügbarkeit von Cloud-Nutzern nicht mehr abrufen.

Das ist beim Kunden schnell geprüft:

```
$result = Test-OAuthConnectivity -Service EWS -TargetUri https://outlook.office365.com -  
Mailbox <onprem-mailbox>  
$result.ResultType
```

Die Umstellung erfolgt über ein Microsoft-Skript:

```
# https://aka.ms/ConfigureExchangeHybridApplication  
.\ConfigureExchangeHybridApplication.ps1 -FullyConfigureExchangeHybridApplication
```

Voraussetzungen: Application Administrator in Entra, Organization Management in Exchange, ausgehendes HTTPS zu login.microsoftonline.com und graph.microsoft.com, und ein Server auf einem Mindest-Build (Exchange SE RTM, 2019 CU14/CU15 mit April-2025-HU oder 2016 CU23 mit April-2025-HU).

Nach der Umstellung gehört der alte geteilte Service Principal bereinigt – das ist der eigentliche Härtungsschritt, nicht nur die Funktionswiederherstellung.

Ein weiterer Termin am Horizont: **EWS wird im Oktober 2026 in Exchange Online abgeschaltet**. Kunden mit EWS-abhängigen Anwendungen sollten das jetzt auf dem Schirm haben.

HYB-03 Receive Connector

Die Anforderung aus dem Ursprungsdokument:

„Der Default Receive Connector von Exchange Server muss auf die zulässigen internen Systeme beschränkt werden, die per TCP/25 Mail senden dürfen“

Die Absicht ist richtig, der Weg ist zu korrigieren. Den „Default Frontend“-Connector einzuschränken bricht typischerweise den Internet-Mailfluss – dieser Connector nimmt auch die Zustellung von Exchange Online Protection an. Wer dort RemoteIPRanges auf die internen Systeme setzt, sperrt die eingehende Post aus.

Best Practice ist ein **zusätzlicher, eng gescoppter Relay-Connector**. Exchange wählt bei mehreren passenden Connectors den mit der höchsten Spezifität – ein Connector mit einer expliziten IP-Liste gewinnt gegen den Default-Connector mit 0.0.0.0-255.255.255.255.

```
# Ist-Zustand aufnehmen
Get-ReceiveConnector | Format-Table
Identity,Enabled,Bindings,RemoteIPRanges,PermissionGroups,AuthMechanism
Get-ReceiveConnector | Get-ADPermission | Where-Object { $_.ExtendedRights -like '*SMTP*' }

# Dedizierter Relay-Connector
New-ReceiveConnector -Name "Internal Relay" -Usage Custom -TransportRole FrontendTransport `
    -Bindings 0.0.0.0:25 -RemoteIPRanges 10.0.0.10,10.0.0.11,10.0.20.0/24 `
    -PermissionGroups AnonymousUsers
Add-ADPermission -Identity "Internal Relay" -User "NT AUTHORITY\ANONYMOUS LOGON" `
    -ExtendedRights ms-Exch-SMTP-Accept-Any-Recipient
```

Das Recht ms-Exch-SMTP-Accept-Any-Recipient ist das, was aus einem Empfangs-Connector einen Relay macht. Es gehört ausschließlich auf einen Connector mit expliziter IP-Liste.

Die typischen Systeme in dieser Liste: Multifunktionsdrucker mit Scan-to-Mail, ERP, Monitoring, Zeiterfassung, Fachanwendungen, Backup-Software. Die Aufnahme dieser Liste ist beim Kunden meist der aufwendigste Teil – und der wertvollste, weil sie danach dokumentiert ist.

HYB-04 Ausgehende Firewall-Regeln

Die Empfehlung aus dem Ursprungsdokument – ausgehend TCP/25 sperren außer für den Exchange Server, möglichst auch 465, 587, 143, 993, 110 und 995 – **bleibt unverändert gültig.**

Mit einer Einschränkung zur Ehrlichkeit gegenüber dem Kunden: Es gibt dazu keine offizielle Microsoft-Empfehlung. Das ist gute Betriebspraxis, keine herstellergestützte Vorgabe. Wenn der Kunde nach einer Quelle fragt, sollte man das so sagen.

Die Begründung trägt trotzdem. Ein infizierter Client, der direkt auf Port 25 nach außen sprechen kann, verschickt Spam unter der Unternehmens-IP. Die Folge ist ein Eintrag auf Blocklisten – und der trifft dann die legitime Post aller Mitarbeiter, oft für Tage. Zugleich umgeht dieser Weg jede Outbound-Kontrolle von EOP: Die Limits aus ASO-02 und die Sperre aus ASO-03 greifen nur für Post, die tatsächlich über Exchange Online läuft.

HYB-05 und HYB-06 Legacy-Protokolle

Beide Punkte fehlen im Ursprungsdokument und ergänzen die Firewall-Empfehlung um die Cloud-Seite.

SMTP AUTH. Authentifizierte SMTP-Einlieferung mit Basic Authentication ist einer der letzten verbliebenen Wege für Passwort-Spraying gegen Exchange Online – der Angreifer probiert Zugangsdaten gegen einen Endpunkt, der weder MFA noch Conditional Access kennt.

```
Get-TransportConfig | Format-List SmtplibClientAuthenticationDisabled
Get-CASMailbox -ResultSize Unlimited |
  Where-Object { $_.SmtplibClientAuthenticationDisabled -eq $false } | Select-Object
Identity
```

```
Set-TransportConfig -SmtplibClientAuthenticationDisabled $true
Set-CASMailbox -Identity "scanner@kunde.de" -SmtplibClientAuthenticationDisabled $false
```

Die Ausnahmen sind fast immer Drucker, Scanner und Fachanwendungen. Für die gibt es den besseren Weg: den internen Relay-Connector aus HYB-03. Ein Gerät im eigenen Netz braucht keine authentifizierte Verbindung zu Exchange Online.

POP3 und IMAP4. Diese Clients umgehen sämtliche Warnhinweise – Safety Tips, External-Tag, Safe Links werden nicht dargestellt. Ein Nutzer mit IMAP-Client sieht nichts von der gesamten Kennzeichnungsarbeit aus EXT-01 bis EXT-03.

```
Get-CASMailboxPlan | Set-CASMailboxPlan -PopEnabled $false -ImapEnabled $false
Get-CASMailbox -ResultSize Unlimited | Set-CASMailbox -PopEnabled $false -ImapEnabled
$false
```

Wichtig: Der Mailbox-Plan wirkt nur auf **neu angelegte** Postfächer. Bestandspostfächer müssen separat umgestellt werden – deshalb beide Befehle.

HYB-07 Nachrichtengrößen

Die Anforderung „Größenbeschränkung für Mails: ein/ausgehend in Exchange“ ist erfüllbar, verteilt sich aber auf mehrere Ebenen:

```
# Exchange Online
Get-MailboxPlan | Format-Table Name,MaxSendSize,MaxReceiveSize
Get-Mailbox -ResultSize Unlimited | Select-Object -First 5
Identity,MaxSendSize,MaxReceiveSize
Get-TransportConfig | Format-List MaxSendSize,MaxReceiveSize
```

```
Get-MailboxPlan | Set-MailboxPlan -MaxSendSize 35MB -MaxReceiveSize 35MB
```

On-premises kommen Set-TransportConfig, Set-ReceiveConnector -MaxMessageSize und Set-SendConnector -MaxMessageSize dazu.

Der Hybrid-Fallstrick: Die Werte müssen auf beiden Seiten **und** auf allen Connectors zusammenpassen. Weicht ein Connector ab, entstehen NDRs im Grenzbereich, die sich nur schwer reproduzieren lassen – die 28-MB-Mail geht durch, die 32-MB-Mail nicht, und niemand weiß warum.

HYB-08 und HYB-09 Connectors

TLS erzwingen ist unter AUTH-09 beschrieben. Ergänzend hier der Prüfpunkt am Bestand.

Connector-Audit. Jeder Connector sollte einen bekannten Zweck haben. Verwaiste Connectors aus abgelösten Gateway-Projekten sind ein häufiger Befund – und sie sind gefährlich, weil sie in der Regel weitreichende Rechte tragen.

Get-InboundConnector | [Format-List](#)

Name, Enabled, ConnectorType, ConnectorSource, SenderIPAddresses, `

SenderDomains, RestrictDomainsToIPAddresses, TreatMessagesAsInternal, EFSkipLastIP, EFSkipIPs

Get-OutboundConnector | [Format-List](#)

Name, Enabled, ConnectorType, RecipientDomains, SmartHosts, `

TlsSettings, TlsDomain, RouteAllMessagesViaOnPremises

Worauf besonders zu achten ist: `TreatMessagesAsInternal $true` auf einem Partner-Connector hebt die Unterscheidung zwischen intern und extern auf. Damit greifen das External-Tag, der First Contact Safety Tip und TABL-Blocks für eingehende Post nicht mehr – und zwar unbemerkt, weil alle Einstellungen im Portal korrekt aussehen.

Ein Hinweis zum Mailfluss

Wenn on-premises Exchange Post direkt aus dem Internet empfängt, ohne dass sie vorher durch EOP läuft, greift von allem in diesem Guide nur ein Bruchteil. Anti-Spam, Anti-Phishing, Safe Links, Safe Attachments und ZAP arbeiten auf Nachrichten, die durch Exchange Online laufen.

Bei jedem Hybrid-Kunden gehört deshalb an den Anfang der Aufnahme die Frage:

Wohin zeigt der MX-Record, und welchen Weg nimmt eine eingehende Nachricht tatsächlich? Die Antwort entscheidet über EF-01 und darüber, welche Teile dieses Standards überhaupt wirksam sind.

Betrieb und Voraussetzungen

OPS-01 Rollen

Zweck	Empfohlene Rollen
Audit, nur lesend	Global Reader und Security Reader – deckt Exchange- und Defender-Seite ab
Umsetzung	Security Administrator (EOP/MDO-Policies) und Exchange Administrator (Transportregeln, Set-ExternalInOutlook)
Alert Policies lesen	zusätzlich View-Only Manage Alerts

Global Administrator ist zu vermeiden – Microsoft empfiehlt das ausdrücklich, und für nichts in diesem Standard wird er gebraucht.

Zwei Fallstricke:

1. **DKIM- und ARC-Einstellungen.** Für die E-Mail-Authentifizierungsseite im Defender-Portal reicht die Rolle Security Administrator laut Dokumentation nicht. Nötig ist Exchange Organization Management oder die entsprechende Defender-XDR-RBAC-Rolle.
2. **Defender Unified RBAC.** Ist es für Email & collaboration aktiviert, ist die klassische Berechtigungsseite im Portal nicht mehr verfügbar. Microsoft: „*You must configure or import your roles before activating Defender unified RBAC.*“

OPS-02 PowerShell-Voraussetzungen

Windows PowerShell 5.1 wird vollständig unterstützt. Microsoft wörtlich: „*All versions of the module are supported and compatible in Windows PowerShell 5.1.*“ Die Anhebung der Mindestversion in neueren Modulversionen betrifft nur PowerShell 7.

Voraussetzungen unter 5.1:

Anforderung	Wert
.NET Framework	4.7.2 oder neuer
TLS 1.2	erforderlich – die PowerShell Gallery akzeptiert nichts anderes
PowerShellGet	erforderlich für REST-Verbindungen
Execution Policy	RemoteSigned

```
[Net.ServicePointManager]::SecurityProtocol = [Net.SecurityProtocolType]::Tls12
Install-Module ExchangeOnlineManagement -Scope CurrentUser -Force
Connect-ExchangeOnline -UserPrincipalName admin@kunde.de
```

Zwei Einschränkungen, die man vor Ort kennen sollte:

- **-Device (Device Code Flow) und -InlineCredential brauchen PowerShell 7** und funktionieren unter 5.1 nicht. Für unbeaufsichtigte Läufe unter 5.1 bleibt die

zertifikatsbasierte App-only-Authentifizierung (-AppId, -Organization, -CertificateThumbprint).

- **-UseRPSSession ist ab Modulversion 3.9.2 abgekündigt** und gehört aus Altskripten entfernt. Basic Authentication über Remote PowerShell wurde bereits im Oktober 2023 durch REST-Verbindungen ersetzt.

Bestehende Verbindung wiederverwenden. Beide Skripte dieses Standards prüfen zu Beginn mit `Get-ConnectionInformation`, ob bereits eine Verbindung besteht, und verwenden sie weiter. Man meldet sich also einmal an und kann Audit und Hardening nacheinander fahren. Wichtig für eigene Skripte: **Get-PSSession taugt dafür nicht mehr.** Microsoft schreibt ausdrücklich: „*This cmdlet is required because the Get-PSSession cmdlet in Windows PowerShell doesn't return information for REST API connections.*“ Seit der Umstellung auf REST-Verbindungen liefert `Get-PSSession` für Exchange Online nichts zurück — ein Altskript mit dieser Prüfung baut bei jedem Lauf eine neue Verbindung auf.

Nützlich ist dabei ein Nebeneffekt: Die Rückgabe enthält `Organization`, `UserPrincipalName` und `TenantID`. Wer mit mehreren Kundentenanten im selben Fenster arbeitet, sollte das vor jeder Änderung ausgeben lassen — es ist die einfachste Absicherung gegen den Griff in den falschen Tenant.

`Get-ConnectionInformation` | [Format-List](#)
`Organization,UserPrincipalName,TenantID,IsEopSession,TokenExpiryTimeUTC`

`IsEopSession` unterscheidet dabei die beiden Verbindungsarten: `$false` steht für Exchange Online, `$true` für Security & Compliance.

Session-Matrix. Fast alles in diesem Standard läuft über `Connect-ExchangeOnline`. Die einzige Ausnahme:

Cmdlet-Gruppe	Session
Anti-Spam, Anti-Phishing, Anti-Malware, Safe Links, Safe Attachments	<code>Connect-ExchangeOnline</code>
Quarantäne-Policies, Tenant Allow/Block List, Report Submission	<code>Connect-ExchangeOnline</code>
Transportregeln, Connectors, Set-ExternalInOutlook, DKIM, ARC	<code>Connect-ExchangeOnline</code>
Message Trace, Reports	<code>Connect-ExchangeOnline</code>
*-ProtectionAlert	<code>Connect-IPPSSession</code>

OPS-03 Ausgangszustand sichern

Es gibt in EOP und MDO keine Rollback-Funktion. Der Export des Ist-Zustands vor der ersten Änderung *ist* das Rollback.

Das Audit-Skript `Invoke-EopAudit.ps1` erledigt das mit `-ExportJson`: Es schreibt alle Policy-Objekte im Original in eine Datei. Damit lässt sich jeder einzelne Wert nachträglich zurücksetzen.

Zusätzlich lohnt der Blick auf das Unified Auditing – ist es aktiv, zeigt der Configuration Analyzer im Tab „Configuration drift analysis and history“ bis zu 90 Tage rückwirkend, wer wann was geändert hat.

OPS-04 Nachkontrolle

Der Termin nach 7 bis 14 Tagen ist kein Nice-to-have. Die meisten Rückfragen entstehen genau in diesem Zeitraum, und sie konzentrieren sich auf drei Punkte: Bulk-Schwelle (ASI-01), Phishing-Schwellwert (APH-08) und Impersonation (IMP-01 bis IMP-04).

Was beim Nachtermin durchzugehen ist:

1. **Quarantäne durchsehen.** Was liegt drin, was davon ist legitim? Das ist die einzige belastbare Messung der Fehlalarmrate.
2. **Configuration Analyzer erneut laufen lassen.** Hat jemand etwas zurückgedreht?
3. **Threat-Protection-Status-Bericht ansehen.** Wie viel wird jetzt abgefangen, das vorher durchging?
4. **Offene Punkte aus der Checkliste abarbeiten** – meist die, die eine Entscheidung des Kunden brauchten.
5. **Ausnahmen prüfen.** Sind seit dem Hardening neue TABL-Einträge oder Transportregeln entstanden? Wenn ja: mit welcher Begründung, und mit welchem Ablaufdatum?

Ohne diesen Termin landen die Rückfragen ungefiltert beim Kunden, und die Härtung wird im Zweifel pauschal zurückgedreht.

Ergänzungen: Teams, Weiterleitungen, Domänenkonfiguration

Die folgenden Punkte kommen im Ursprungsdokument nicht vor. Drei davon, weil es sie 2023 noch nicht gab, zwei, weil sie in der Praxis regelmäßig übersehen werden.

TEAMS-01 Teams Protection

Was sich geändert hat. Microsoft Defender for Office 365 schützt inzwischen auch Microsoft Teams: Zero-hour Auto Purge für Teams-Nachrichten, eine Admin-Quarantäne für Teams-Inhalte und die Möglichkeit für Nutzer, verdächtige Teams-Nachrichten zu melden. Seit Januar beziehungsweise Februar 2026 sind ZAP, Admin-Quarantäne und User-Reporting für Teams auch in **Plan 1** verfügbar – vorher waren sie P2-Funktionen.

Warum das relevant ist. Bei vielen Kunden hat Teams die interne E-Mail als Hauptkanal abgelöst. Ein kompromittiertes Konto verschickt heute eher eine Teams-Nachricht mit einem Link als eine Mail – und die läuft an jeder E-Mail-Filterung vorbei.

Wo es liegt. Nicht bei den Bedrohungsrichtlinien, wo man zuerst sucht, sondern unter *Einstellungen > E-Mail & Zusammenarbeit > Microsoft Teams-Schutz*. Per PowerShell: `Get-TeamsProtectionPolicy` und `Get-TeamsProtectionPolicyRule`.

Nicht verwechseln mit Safe Links für Teams (SL-01). Das ist eine andere Funktion: Safe Links prüft Links beim Anklicken, Teams Protection entfernt bereits zugestellte Nachrichten nachträglich und stellt sie in die Quarantäne.

`Get-TeamsProtectionPolicy | Format-List`
`Identity, ZapEnabled, HighConfidencePhishQuarantineTag, MalwareQuarantineTag`

```
Set-TeamsProtectionPolicy -Identity "Teams Protection Policy" `
  -ZapEnabled $true `
  -HighConfidencePhishQuarantineTag AdminOnlyAccessPolicy `
  -MalwareQuarantineTag AdminOnlyAccessPolicy
```

Der Default von `ZapEnabled` ist laut Cmdlet-Referenz `$false` – der Schalter muss also aktiv gesetzt werden.

ASO-07 Der zweite Weg für automatische Weiterleitungen

ASO-04 schließt automatische externe Weiterleitungen über die Outbound-Spam-Policy. Es gibt aber einen zweiten, davon unabhängigen Schalter: die **Remote Domain**.

Microsoft dokumentiert für `AutoForwardEnabled` ausdrücklich: „*\$true: Auto-forwarded messages are delivered to recipients in the remote domain. **This value is the default for new remote domains that you create and the built-in remote domain named Default in Exchange Online.***“

Wer also nur ASO-04 prüft, hat den zweiten Pfad nicht angesehen.

```
Get-RemoteDomain | Format-Table
Name, DomainName, AutoForwardEnabled, AutoReplyEnabled, Allowed00FType
Set-RemoteDomain -Identity Default -AutoForwardEnabled $false
```

Hybrid-Fallstrick. In Hybrid-Umgebungen existiert eine eigene Remote Domain für *.mail.onmicrosoft.com. Diese braucht AutoForwardEnabled \$true, weil darüber der interne Mailfluss zwischen Cloud und On-Premises läuft. Nur die **Default**-Remote-Domain umstellen, nicht pauschal alle.

Verwandte Einstellungen in derselben Remote Domain, die man bei der Gelegenheit ansehen sollte: AutoReplyEnabled (Abwesenheitsnotizen nach außen) und Allowed00FType – letzteres bestimmt, ob externe Empfänger die interne oder die externe Abwesenheitsnotiz bekommen. Ein Allowed00FType External mit einer intern formulierten Abwesenheitsnotiz verrät Vertretungsregelungen und Durchwahlen nach außen.

ASO-08 Versand aus der onmicrosoft.com-Domäne

Microsoft drosselt den ausgehenden Versand aus der Default-onmicrosoft.com-Domäne. Betroffen sind genau die Konten, die in einem Hardening ohnehin auffallen: Testpostfächer, Dienstkonto von Fachanwendungen, Multifunktionsdrucker und Monitoring-Systeme, für die nie eine richtige Adresse eingerichtet wurde.

Symptom ist ein NDR mit dem Fehlercode 550 5.7.236. Die Abhilfe ist immer dieselbe: eine Primäradresse aus einer Custom-Domäne vergeben.

```
Get-Mailbox -ResultSize Unlimited |
  Where-Object { $_.PrimarySmtpAddress -like '*.onmicrosoft.com' } |
  Select-Object DisplayName, PrimarySmtpAddress, RecipientTypeDetails
```

Den exakten Grenzwert vor einer Kundenaussage im Exchange-Team-Blog („Limiting Onmicrosoft Domain Usage for Sending Emails“) gegenprüfen – er wurde seit der Ankündigung angepasst.

HYB-10 Accepted-Domain-Typ und Directory Based Edge Blocking

Ein Befund, der in Hybrid-Umgebungen häufig übersehen wird und den man in dreißig Sekunden prüft.

```
Get-AcceptedDomain | Format-Table DomainName, DomainType, Default
```

Was die beiden Typen bedeuten. Bei **Authoritative** liegen alle Empfänger der Domäne in Exchange Online; Nachrichten an unbekannte Adressen werden abgewiesen. Bei **InternalRelay** nimmt EOP auch Nachrichten an unbekannte Empfänger an und leitet sie an den eigenen Server weiter.

Warum das eine Sicherheitsfrage ist. Microsoft: „Setting this option enables Directory-Based Edge Blocking (DBEB), which rejects messages for invalid recipients at the service network perimeter.“ Steht der Typ auf InternalRelay, obwohl alle Empfänger in der Cloud liegen, geht diese kostenlose Filterstufe verloren: EOP nimmt jede Nachricht an, auch an frei erfundene Adressen. Die Folge sind unnötige Verarbeitungslast, Backscatter durch nachgelagerte Unzustellbarkeitsmeldungen und ein bequemer Weg für Angreifer, gültige Adressen zu erraten.

Vor der Umstellung. Authoritative weist Post an unbekannte Empfänger ab – das ist der Zweck, aber auch das Risiko. Vorher sicherstellen, dass wirklich jeder Empfänger im Tenant bekannt ist, einschließlich Verteilerlisten, freigegebener Postfächer, Aliasse und Kontakte.

```
Set-AcceptedDomain -Identity "kunde.de" -DomainType Authoritative
```

AUTH-12 BIMi

BIMi zeigt das Logo des Absenders im Postfach des Empfängers an. Es setzt DMARC mit p=quarantine oder p=reject voraus und ist damit die logische Fortsetzung von AUTH-06. Microsoft unterstützt es in Outlook.

Sicherheitstechnisch ist BIMi kein zusätzlicher Schutz – der Schutz kommt von DMARC. Praktisch ist es trotzdem nützlich: Es ist das sichtbare Ergebnis eines Projekts, das sonst rein technisch bleibt, und regelmäßig das Argument, mit dem sich die DMARC-Einführung im Haus durchsetzen lässt.

```
Resolve-DnsName -Name default._bimi.kunde.de -Type TXT
```

Für die Anzeige in den meisten Postfächern wird zusätzlich ein Verified Mark Certificate benötigt – ein kostenpflichtiges Zertifikat, das die Markenrechte am Logo bestätigt. Das gehört in die Aufwandsschätzung.

Wirksamkeit nachweisen

Ein Hardening, dessen Wirkung niemand gesehen hat, wird beim ersten Fehlalarm zurückgedreht. Dieses Kapitel beschreibt, wie sich am Ende eines Termins zeigen lässt, dass die Einstellungen greifen.

Vorab abstimmen. Alle folgenden Tests erzeugen Einträge in der Quarantäne und teilweise Alerts. Vorher mit dem Kunden vereinbaren und protokollieren, damit sie nicht als echter Vorfall behandelt werden.

VER-01 Malware und Anhangsfilter

EICAR. Die EICAR-Testdatei ist eine harmlose, standardisierte Zeichenkette, die jede Antivirenlösung als Testsignatur erkennt. Von einem externen Postfach an ein Testpostfach im Tenant senden.

Erwartetes Ergebnis: Die Nachricht erscheint nicht im Posteingang. Je nach Konfiguration liegt sie in der Admin-Quarantäne (AMW-04) oder der Absender erhält eine Unzustellbarkeitsmeldung.

Anhangsfilter. Eine leere Datei mit einer Endung aus der Filterliste – etwa `.iso` oder `.jar` – anhängen. Bei `FileTypeAction Reject` (AMW-03) bekommt der externe Absender einen NDR; bei `Quarantine` landet die Nachricht still in der Quarantäne.

VER-02 Header lesen

Die Nachrichten-Header sind der einzige belastbare Nachweis, dass eine Einstellung tatsächlich gegriffen hat. In Outlook über *Datei > Eigenschaften > Internetkopfeilen*, in Outlook on the web über *Nachrichtendetails anzeigen*.

X-Forefront-Antispam-Report – die wichtigsten Felder:

Feld	Bedeutung
CAT:	Das gewonnene Verdict. MALW Malware, HPHSH High confidence phishing, PSH Phishing, HSPM High confidence spam, SPOOF Spoofing, SPM Spam, BULK Bulk
SCL:	Spam Confidence Level. -1 bedeutet: Filterung übersprungen
SFV:	Wie die Einstufung zustande kam. SKA Treffer auf einer Allow-Liste, SKB Treffer auf einer Block-Liste, SPM durch Filterung als Spam eingestuft
BCL:	Bulk Complaint Level – die Zahl, gegen die <code>BulkThreshold</code> (ASI-01) prüft
IPV:CAL	Die Quell-IP stand auf der IP Allow List des Connection Filters

Feld	Bedeutung
SFTY:	Welcher Safety Tip gesetzt wurde. 9.25 First contact, 9.19 Domain impersonation, 9.20 User impersonation
CIP:	Die IP-Adresse, mit der EOP tatsächlich gerechnet hat

Authentication-Results – hier steht, wie die Absenderauthentifizierung ausgefallen ist: spf=, dkim=, dmarc= und compauth= mit einem reason-Code. reason=000 steht für eine explizite Authentifizierungslücke, reason=001 für eine implizite, reason=6xx für organisationsinternes Spoofing, reason=130 für einen erfolgreichen ARC-Override.

Zwei Header, die Enhanced Filtering belegen (EF-01): X-MS-Exchange-ExternalOriginalInternetSender erscheint nur bei erfolgreichem Skip und passendem Empfänger, X-MS-Exchange-SkipListedInternetSender immer dann, wenn Enhanced Filtering am Connector aktiv ist.

Der Blick auf CIP: ist bei Kunden mit vorgeschaltetem Gateway besonders aufschlussreich. Steht dort die IP des Gateways statt die des echten Absenders, ist EF-01 offen – und alle IP-basierten Prüfungen laufen ins Leere.

VER-03 Spoof- und Linkschutz

Spoof-Test. Von einem externen Postfach eine Nachricht mit der Kundendomäne als Absenderadresse schicken. Erwartetes Ergebnis nach APH-01 bis APH-05: Quarantäne oder Ablehnung, je nach DMARC-Policy der Domäne und den gesetzten Aktionen. Der Test zeigt dem Kunden unmittelbar, was die Konfiguration bewirkt – und deckt gleichzeitig auf, wenn der eigene DMARC-Record noch auf p=none steht.

Safe-Links-Test. Einen Link auf eine bekannte Testadresse anklicken und prüfen, ob die Warnseite erscheint und ob sie das Branding des Kunden trägt (SL-07). Zugleich der Moment, an dem auffällt, wenn dort noch ein Platzhaltertext hinterlegt ist.

Auswertung im Portal. Im Threat Explorer (MDO) oder über den Spoof-Detections-Bericht (EOP) lassen sich die Testnachrichten anschließend zeigen:

```
Get-SpoofMailReport -StartDate (Get-Date).AddDays(-1) -EndDate (Get-Date)
Get-MessageTraceV2 -StartDate (Get-Date).AddHours(-4) -EndDate (Get-Date) `
-RecipientAddress "test@kunde.de" | Format-Table Received,SenderAddress,Subject,Status
```

GOV-01 Datenschutz und Mitbestimmung

Für deutsche Kunden gehört dieser Punkt an den Anfang und nicht ans Ende. Mehrere Funktionen dieses Standards geben Administratoren Einblick in die Kommunikation einzelner Beschäftigter:

- Die **Quarantäne** zeigt Absender, Betreff und Vorschau abgefangener Nachrichten.
- Der **Message Trace** zeigt, wer wann mit wem kommuniziert hat – 90 Tage rückwirkend.

- Der **Threat Explorer** (MDO) erlaubt Auswertungen über Empfänger, Absender und Betreffzeilen.
- Der **First Contact Safety Tip** (APH-07) legt bei mehreren Empfängern offen, dass ein Kollege selten mit einem bestimmten Absender kommuniziert.
- **DMARC-Failure-Reports** (AUTH-07) können Nachrichteninhalte enthalten.

Zu klären ist jeweils: Wer darf worauf zugreifen, wie lange werden die Daten vorgehalten, wird der Zugriff protokolliert, und ist das in einer Betriebsvereinbarung abgebildet? Bei Kunden mit Betriebsrat sollte das vor der Umsetzung besprochen sein – nicht danach.

Zwei Punkte, die dabei helfen: Die Aufbewahrung in der Quarantäne ist auf maximal 30 Tage begrenzt (ASI-09) und damit gut argumentierbar. Und über die Rollentrennung aus OPS-01 lässt sich der Lesezugriff sauber vom Änderungsrecht trennen.

P2-01 Wenn der Kunde Defender Plan 2 hat

Dieser Standard ist bewusst auf EOP und Plan 1 ausgelegt, weil das die Lizenzlage bei den meisten Mittelstandskunden ist. Ein E5-Kunde bezahlt aber für mehr:

Funktion	Wofür
Automated Investigation and Response (AIR)	Untersucht Vorfälle automatisch und schlägt Aktionen vor – die jemand freigeben muss
Threat Explorer	Rückwirkende Suche über alle Nachrichten, nach Absender, URL, Anhang, Verdict
Campaign Views	Erkennt zusammenhängende Kampagnen statt Einzelnachrichten
Advanced Hunting	Freie Abfragen über die Telemetrie
Attack Simulation Training	Microsofts eigene Phishing-Simulation, Alternative zu ADV-02
Priority Account Protection	IMP-08

Der praktisch wichtigste Punkt beim Assessment: **AIR erzeugt Untersuchungen mit ausstehenden Aktionen.** Wenn niemand sie im Action Center freigibt, bleiben sie liegen und die automatische Bereinigung findet nicht statt. Das ist ein häufiger Befund bei E5-Kunden ohne eigenes Security-Team – und ein guter Anlass, über den Betrieb zu sprechen.

Threat Explorer und Campaign Views sind zugleich die Werkzeuge, mit denen sich die Wirkung des Hardenings beim Nachtermin belegen lässt.

Anhang A: Prüfpunkt-Index

Alle Prüfpunkte in der Reihenfolge der Checkliste. Die IDs sind zwischen Checkliste, Guide und den PowerShell-Skripten identisch.

Preset Security Policies

ID	Prüfpunkt	Soll 2026	Lizenz
PRE-01	Grundsatzentscheidung: Preset (Standard/Strict) vs. Custom-Policies	Bewusste, dokumentierte Entscheidung. Empfehlung 2026: Custom-Policies auf Standard-Preset-Niveau, wo Kontr...	EOP (EOP-Teil) / MDO P1+ (MDO-Teil)
PRE-02	Built-in protection Preset (Safe Links / Safe Attachments) aktiv, keine pauschalen Ausnahmen	Aktiv, keine Ausnahmen für ganze Domänen	MDO P1/P2
PRE-03	Policy-Präzedenz dokumentiert und geprüft (welche Policy greift je Empfänger?)	Kette dokumentiert: Strict > Standard > MDO-Evaluation > Custom (nach Priority) > Built-in + Default (gleic...	EOP
PRE-04	Configuration Analyzer ausgewertet (Standard- und Strict-Empfehlungen)	Vor und nach dem Hardening ausgeführt, Abweichungen dokumentiert	EOP / MDO
PRE-05	Policy-Inventar: verwaiste und deaktivierte Policies	Jede Policy hat eine aktive Regel oder ist bewusst stillgelegt und dokumentiert	EOP / MDO

Anti-Spam inbound

ID	Prüfpunkt	Soll 2026	Lizenz
ASI-01	Bulk-Schwellwert (BCL)	6	EOP
ASI-02	Aktion bei Spam	MoveToJmf (Junk)	EOP

ID	Prüfpunkt	Soll 2026	Lizenz
	(SCL 5/6)		
ASI-03	Aktion bei High Confidence Spam (SCL 7/8/9)	Quarantine + DefaultFullAccess WithNotificationPolicy (MS-konform) ODER AdminOnlyAccessPolicy (strengere Var...	EOP
ASI-04	Aktion bei Phishing	Quarantine + DefaultFullAccess WithNotificationPolicy	EOP
ASI-05	Aktion bei High Confidence Phishing	Quarantine + AdminOnlyAccessPolicy	EOP
ASI-06	Aktion bei Bulk (BCL-Schwelle erreicht)	MoveToJmf	EOP
ASI-07	Spam Safety Tips (farbige Inline-Warnung)	\$true	EOP
ASI-08	ZAP für Spam und Phishing	SpamZapEnabled \$true, PhishZapEnabled \$true	EOP
ASI-09	Quarantäne-Aufbewahrung	30 Tage	EOP
ASI-10	Allowed senders / allowed sender domains leer bzw. begründet	Leer. Ausnahmen ausschließlich über die Tenant Allow/Block List (TABL-01).	EOP
ASI-11	Sprach- und Länderfilter	Aus, sofern kein konkreter Anlass. Bei Einsatz: Trefferliste vorher per Threat Explorer messen.	EOP
ASI-12	Intra-Organizational Filtering (interne Nachrichten)	Default (= High Confidence Phishing)	EOP

Advanced Spam Filter (ASF)

ID	Prüfpunkt	Soll 2026	Lizenz
ASF-01	ASF-Features zur Score-Erhöhung (Image links, Numeric IP, URL redirect, .biz/.info)	Off (alle vier)	EOP
ASF-02	ASF-Features 'Mark as Spam' (Empty messages, HTML-Tags, Web bugs, Sensitive words u.a.)	Off (alle acht)	EOP
ASF-03	SPF Hard Fail als Spam-Kriterium	Off — die Frage im Ursprungsdokument ist mit NEIN beantwortet	EOP
ASF-04	Sender-ID Hard Fail und NDR-Backscatter	Off (beide)	EOP
ASF-05	ASF Test-Modus	None	EOP

Connection Filter

ID	Prüfpunkt	Soll 2026	Lizenz
CF-01	IP Allow List	Leer. Falls unvermeidbar: einzelne /32, dokumentiert, mit Ablaufdatum im Betriebshandbuch.	EOP
CF-02	IP Block List	Nur bei konkretem Anlass; IPv4-Blocks gehören hierher (nicht in die TABL).	EOP
CF-03	Safe List (EnableSafeList)	\$false	EOP

Anti-Spam outbound

ID	Prüfpunkt	Soll 2026	Lizenz
ASO-01	Eigene Outbound-Policy vs. Default-Policy	Grenzwerte und Aktion in der DEFAULT-Policy setzen; eigene	EOP

ID	Prüfpunkt	Soll 2026	Lizenz
		Policies nur für begründete Ausnahmen (z.B. Vers...	
ASO-02	Empfänger-Limits (extern/intern/Tag)	Extern 500/h, intern 1000/h, 1000/Tag (= MS Standard). 200/Tag nur, wenn im Tenant nachweislich kein legiti...	EOP
ASO-03	Aktion bei Erreichen der Limits	BlockUser (= MS Standard/Strict) + Alert Policy 'User restricted from sending email' mit gepflegten Empfängern	EOP
ASO-04	Automatische externe Weiterleitungen	Automatic (= systemgesteuert = aus)	EOP
ASO-05	Benachrichtigung/BCC bei verdächtigem Ausgangsverkehr	Bewusste Entscheidung: MS-Preset-konform (true).	EOP
ASO-06	Tenant External Recipient Rate Limit (TERRL) bekannt und eingeplant	Kunde kennt das Limit; Massenversand läuft nicht über EXO	EOP

Anti-Phishing / Spoof

ID	Prüfpunkt	Soll 2026	Lizenz
APH-01	Spoof Intelligence aktiv	\$true	EOP
APH-02	Aktion bei Spoof-Erkennung (blockierte Spoof-Absender)	Quarantine + SpoofQuarantineTag (Strict-Niveau). Strengere Variante: 'AdminOnlyAccess Policy' als bewusste V...	EOP
APH-03	DMARC-Policy des	HonorDmarcPolicy	EOP

ID	Prüfpunkt	Soll 2026	Lizenz
	Absenders berücksichtigen	\$true	
APH-04	Aktion bei DMARC p=quarantine	Quarantine	EOP
APH-05	Aktion bei DMARC p=reject	Reject (Default). In der Einführungsphase optional Quarantine.	EOP
APH-06	Unauthentifizierter Absender: Fragezeichen im Absenderbild	\$true	EOP
APH-07	First Contact Safety Tip	\$true	EOP
APH-08	Phishing-Schwellwert	3 (More aggressive). Stufe 2 nur als Zwischenschritt in einer gestuften Einführung.	MDO P1+

Impersonation (MDO)

ID	Prüfpunkt	Soll 2026	Lizenz
IMP-01	Geschützte Domänen: eigene Domänen	EnableOrganization DomainsProtection \$true	MDO P1+
IMP-02	Geschützte Domänen: fremde Domänen (Partner, Banken, Steuerberater)	\$true mit gepflegter Liste der wichtigsten Geschäftspartner	MDO P1+
IMP-03	Geschützte Benutzer (Geschäftsführung, Buchhaltung, Einkauf)	\$true mit Liste der Schlüsselrollen	MDO P1+
IMP-04	Impersonation-Aktionen tatsächlich gesetzt (nicht 'NoAction')	Quarantine für User- und Domain-Impersonation; Mailbox Intelligence MoveToJmf (Standard) bzw.	MDO P1+

ID	Prüfpunkt	Soll 2026	Lizenz
IMP-05	Mailbox Intelligence	Quarantine (S... EnableMailboxIntell igence \$true UND EnableMailboxIntell igenceProtection \$true	MDO P1+
IMP-06	Impersonation Safety Tips	alle drei \$true	MDO P1+
IMP-07	Trusted senders / trusted domains (Impersonation- Ausnahmen)	Leer bzw. minimal und begründet	MDO P1+
IMP-08	Priority Account Protection	\$true; Priority- Accounts im M365 Admin Center getaggt	MDO P2 / E5

Tenant Allow/Block List

ID	Prüfpunkt	Soll 2026	Lizenz
TABL-01	TABL als primärer Allow- Mechanismus etabliert	Etabliert als EINZIGER regulärer Allow- Weg; Safe-Sender- Listen und Transportregel- Bypässe abgebaut	EOP (Limits abhängig von MDO-Plan)
TABL-02	Absender-/Domain- Blocks gepflegt und mit Ablaufdatum	Bestand geprüft, Altlasten entfernt, Ablaufdaten gesetzt	EOP / MDO
TABL-03	Spoofed senders (freigegebene Spoof-Absender) geprüft	Bestand geprüft; jeder Allow-Eintrag hat einen dokumentierten Grund und ein Ticket. Vorrang hat die Korrekt...	EOP
TABL-04	URL-Einträge	Nur bei Bedarf; Blocks bevorzugt hier statt in der (abgeschafften) Safe-Links-Global- Block-List	EOP / MDO
TABL-05	Datei-Hashes	Nur bei Bedarf	EOP / MDO

ID	Prüfpunkt	Soll 2026	Lizenz
TABL-06	IP-Einträge (IPv6)	(Incident Response) Nur bei Bedarf; IPv4 gehört in den Connection Filter	EOP / MDO

Anti-Malware

ID	Prüfpunkt	Soll 2026	Lizenz
AMW-01	Common Attachment Filter (Blockieren nach Dateityp)	EnableFileFilter \$true; Default-Liste (54 Typen) als Minimum, Erweiterung nach Messung	EOP
AMW-02	ZAP für Malware	\$true	EOP
AMW-03	Aktion des Dateityp-Filters	Reject (MS- konform) oder Quarantine (wenn NDRs an Absender unerwünscht sind)	EOP
AMW-04	Quarantäne-Policy für Malware	AdminOnlyAccessP olicy	EOP
AMW-05	Admin- Benachrichtigungen bei Malware- Funden	Optional. MS- Presets nutzen es NICHT - stattdessen Alert Policies (REP-02).	EOP

Safe Attachments (MDO)

ID	Prüfpunkt	Soll 2026	Lizenz
SA-01	Safe-Attachments- Policy aktiv und Aktion = Block	Enable \$true, Action Block, QuarantineTag AdminOnlyAccessP olicy	MDO P1+
SA-02	Redirect- Konfiguration konsistent	Redirect \$false (bei Action Block)	MDO P1+
SA-03	Safe Attachments für SharePoint, OneDrive und Teams	\$true	MDO P1+

ID	Prüfpunkt	Soll 2026	Lizenz
SA-04	Safe Documents	\$true, AllowSafeDocsOpen \$false — sofern lizenziert	M365 E5 / A5 / E5 Security — NICHT in MDO P1 oder P2 standalone
SA-05	Dynamic Delivery — bewusste Entscheidung	Nicht verwenden; Block ist die belegbare MS- Empfehlung	MDO P1+

Safe Links (MDO)

ID	Prüfpunkt	Soll 2026	Lizenz
SL-01	Safe Links für E-Mail, Teams und Office-Apps	alle drei \$true	MDO P1+
SL-02	Interne Absender einbeziehen	\$true	MDO P1+
SL-03	Warten auf Scan-Abschluss vor Zustellung	\$true	MDO P1+
SL-04	Durchklicken zur Original-URL unterbinden	AllowClickThrough \$false	MDO P1+
SL-05	URL-Rewriting aktiv (nicht 'API only')	DisableUrlRewrite \$false	MDO P1+
SL-06	'Do not rewrite the following URLs' — Bestand und korrektes Verständnis	Liste leer bzw. minimal; Verdict-Ausnahmen ausschließlich über TABL-URL-Allow	MDO P1+
SL-07	Warnseiten-Branding und Benachrichtigungstext	Organisationsbranding aktiv, sinnvoller deutscher Text ODER Default-Text	MDO P1+

Quarantäne-Policies

ID	Prüfpunkt	Soll 2026	Lizenz
QUA-01	Zuordnung Quarantäne-Policy je Verdict vollständig und bewusst	Malware/Safe Attachments/HC-Phish: AdminOnlyAccessPolicy. Übrige Verdicts:	EOP

ID	Prüfpunkt	Soll 2026	Lizenz
		DefaultFullAccess WithNotificatio...	
QUA-02	Eigene Quarantäne-Policy 'Admin-only mit Benachrichtigung' (falls gewünscht)	Nur anlegen, wenn der Kunde das Verhalten wirklich will	EOP
QUA-03	Globale Benachrichtigungsfrequenz	04:00:00 (alle 4 Stunden)	EOP
QUA-04	Corporate Branding und Absenderadresse der Quarantäne-Benachrichtigungen	OrganizationBrandingEnabled \$true, eigene Absenderadresse gesetzt	EOP

Advanced Delivery

ID	Prüfpunkt	Soll 2026	Lizenz
ADV-01	SecOps-Postfach	Nur wenn ein dediziertes, isoliertes Security-Postfach existiert. Sonst bewusst nicht konfigurieren.	EOP / MDO P1+
ADV-02	Phishing-Simulation (Drittanbieter) korrekt eingebunden	Über Advanced Delivery, niemals über Transportregel oder IP-Allow-Liste. Simulations-URLs über TABL mit Lis...	EOP / MDO P1 und P2 — KEINE E5-Anforderung
ADV-03	Keine Transportregeln mit SCL -1 / Filter-Bypass im Bestand	Keine Regel, die pauschal die Filterung überspringt. Ausnahmen dokumentiert und befristet.	EOP

E-Mail-Authentifizierung

ID	Prüfpunkt	Soll 2026	Lizenz
AUTH-01	SPF-Record je akzeptierter	v=spf1 [ip4:<eigene Ausgangs-IPs>] include:spf.protecti	EOP

ID	Prüfpunkt	Soll 2026	Lizenz
	Domäne	on.outlook.com -all	
AUTH-02	SPF-Qualifier -all statt ~all	-all	EOP
AUTH-03	Ungenutzte und geparkte Domänen abgesichert	SPF: v=spf1 -all / DMARC: v=DMARC1; p=reject;	EOP
AUTH-04	DKIM für alle versendenden Custom-Domänen aktiv	Enabled \$true, Status 'Valid' für jede versendende Domäne	EOP
AUTH-05	DKIM- Schlüssellänge 2048 Bit	2048 (beide Selektoren)	EOP
AUTH-06	DMARC-Record je versendender Domäne	Zielzustand p=reject. Einführung gestuft: p=none -> p=quarantine -> p=reject.	EOP
AUTH-07	DMARC-Reporting (rua) auf ein dediziertes Postfach	rua= auf Sammelpostfach oder Analysedienst; bei externer Domäne Autorisierungs- Record prüfen	EOP
AUTH-08	ARC Trusted Sealers	Nur konfigurieren, wenn ein vorgelagerter Dienst Nachrichten verändert UND ARC-Sealing unterstützt.	EOP
AUTH-09	MTA-STS inbound für eigene Domänen	Optional, empfohlen: TXT- Record _mta-sts + Policy-Datei per HTTPS, erst mode: testing, dann enforce	EOP
AUTH-10	SMTP DANE mit DNSSEC	Outbound: Opportunistic	EOP

ID	Prüfpunkt	Soll 2026	Lizenz
		(Default) belassen. Inbound: optional, hoher Aufwand, DNSSEC nötig.	
AUTH-11	Microsoft Sender Requirements für Massenversand erfüllt	Für jede Domäne mit Versand an Consumer-Adressen: SPF + DKIM + DMARC mit Alignment	EOP

Enhanced Filtering

ID	Prüfpunkt	Soll 2026	Lizenz
EF-01	Enhanced Filtering for Connectors — Bedarf korrekt bewertet	Prüfkriterium: Zeigt der MX-Record direkt auf Exchange Online? Wenn ja: aus lassen. Wenn nein: ZWINGEND akt...	EOP
EF-02	Bei aktivem Enhanced Filtering: konkurrierende SCL-(-1)-Regeln entfernt	Keine Transportregel mit SCL -1 für Nachrichten über diesen Connector	EOP

Kennzeichnung externer E-Mails

ID	Prüfpunkt	Soll 2026	Lizenz
EXT-01	Natives External-Tag (Set-ExternalInOutlook)	\$true	Exchange Online (jeder Plan)
EXT-02	Banner-Variante entschieden und mit dem Kunden abgestimmt	Empfehlung 2026: (1) First Contact Safety Tip immer an, (2) natives External-Tag an, (3) Transportregel-Ban...	Exchange Online / EOP
EXT-03	Falls Transportregel-Banner: korrekt konfiguriert	FallbackAction Ignore (NIEMALS Wrap), Duplikatsvermeidung per Header-	Exchange Online

ID	Prüfpunkt	Soll 2026	Lizenz
		Marker, Hybrid-Ausnahmen per SenderIpR...	

Reporting & Alerting

ID	Prüfpunkt	Soll 2026	Lizenz
REP-01	Berichte im Defender-Portal eingerichtet bzw. Zeitplan aktiv	Threat protection status und Mailflow status summary als Zeitplan an die IT; Spoof detections regelmäßig si...	EOP (Basis) / MDO (erweitert)
REP-02	Alert Policies mit gepflegten Empfängern	Mindestens 'User restricted from sending email', 'Suspicious email sending patterns detected' und 'Suspicio...	EOP (E1/E3/E5)
REP-03	User Reported Settings / Meldeweg für Nutzer	Meldung an Microsoft aktiv oder an ein internes Postfach; Nutzer wissen, wie sie melden	EOP
REP-04	Message Trace: V2-Cmdlets in Skripten und Runbooks	Get-MessageTraceV2 / Get-MessageTraceData ilV2 verwenden	EOP

Hybrid & On-Premises

ID	Prüfpunkt	Soll 2026	Lizenz
HYB-01	Exchange-Server-Version im Support	Exchange Server SE. Exchange 2016/2019 sind seit 14.10.2025 out of support.	—
HYB-02	Dedizierte Exchange-Hybrid-App in Entra konfiguriert	Dedizierte App konfiguriert, Feature-Override aktiv, alter geteilter Service Principal	—

ID	Prüfpunkt	Soll 2026	Lizenz
		bereinigt	
HYB-03	Default Receive Connector eingeschränkt	Default-Frontend-Connector NICHT umbauen. Stattdessen dedizierter Relay-Connector mit RemoteIPRanges auf di...	—
HYB-04	Ausgehende Firewall-Regeln für SMTP/IMAP/POP	Unverändert übernehmen — mit dem Hinweis, dass es dafür keine Microsoft-Doku gibt, sondern gute Betriebspra...	—
HYB-05	SMTP AUTH tenantweit deaktiviert, Ausnahmen pro Postfach	Tenantweit deaktiviert; Ausnahmen einzeln, dokumentiert und befristet	EOP
HYB-06	POP3 und IMAP4 deaktiviert	Im Mailbox-Plan und für Bestandspostfächer deaktiviert	EOP
HYB-07	Nachrichtengrößen-Limits	Bewusst gesetzt und dokumentiert (EXO max. 150 MB)	EOP
HYB-08	TLS zu definierten Partnern erzwungen	Für definierte Partner: Outbound Connector mit TlsSettings DomainValidation und TlsDomain	EOP
HYB-09	Inbound-/ Outbound-Connectors auditiert	Jeder Connector hat einen bekannten Zweck; keine verwaisten oder zu weit gefassten Connectors	EOP

Betrieb & Voraussetzungen

ID	Prüfpunkt	Soll 2026	Lizenz
OPS-01	Rollen und Berechtigungen für Audit und Umsetzung geklärt	Audit: Global Reader + Security Reader. Umsetzung: Security Administrator + Exchange Administrator. Global ...	—
OPS-02	Exchange Online PowerShell V3 einsatzbereit (PS 5.1)	Modul ExchangeOnlineManagement aktuell, TLS 1.2 aktiv, .NET Framework 4.7.2+	—
OPS-03	Ausgangszustand vor Änderungen gesichert	Vollständiger Export aller Policy-Objekte vor der ersten Änderung	—
OPS-04	Änderungen dokumentiert und Nachkontrolle terminiert	Termin für Nachkontrolle nach 7-14 Tagen; False Positives auswerten	—

Microsoft Teams Protection

ID	Prüfpunkt	Soll 2026	Lizenz
TEAMS-01	ZAP für Teams-Nachrichten aktiv	ZapEnabled \$true, Quarantäne-Policies auf AdminOnlyAccessPolicy	MDO P1+ (ZAP und Admin-Quarantäne für Teams seit Januar 2026 auch in P1)

Anti-Spam outbound

ID	Prüfpunkt	Soll 2026	Lizenz
ASO-07	Remote Domain: automatische Weiterleitung	AutoForwardEnabled \$false in der Default-Remote-Domain	EOP
ASO-08	Versand aus der onmicrosoft.com-Domäne	Kein produktiver Versand aus der *.onmicrosoft.com-Domäne; alle	EOP

ID	Prüfpunkt	Soll 2026	Lizenz
		Dienstkonto und Geräte auf eine Custom-Dom...	

Hybrid & On-Premises

ID	Prüfpunkt	Soll 2026	Lizenz
HYB-10	Accepted-Domain-Typ und Directory Based Edge Blocking	Authoritative, sofern alle Empfänger in Exchange Online liegen	EOP

Wirksamkeitsnachweis

ID	Prüfpunkt	Soll 2026	Lizenz
VER-01	Malware- und Anhangsfilter nachgewiesen	EICAR-Testdatei von extern an ein Testpostfach; Ergebnis in Quarantäne bzw. NDR nachweisen	EOP
VER-02	Nachrichten-Header ausgewertet	Für je eine Test-Nachricht die Header-Felder dokumentiert	EOP
VER-03	Spoof- und Linkschutz nachgewiesen	Spoof-Test von einem externen Postfach mit gefälschter Absenderdomäne; Safe-Links-Testklick	EOP / MDO P1+

Governance & Datenschutz

ID	Prüfpunkt	Soll 2026	Lizenz
GOV-01	Datenschutz und Mitbestimmung geklärt	Einsicht der Administratoren in Quarantäne, Message Trace und Threat Explorer geregelt; ggf. Betriebsverein...	—

E-Mail-Authentifizierung

ID	Prüfpunkt	Soll 2026	Lizenz
AUTH-12	BIMI	Optional, erst nach DMARC p=quarantine oder p=reject	EOP

Defender P2 (falls lizenziert)

ID	Prüfpunkt	Soll 2026	Lizenz
P2-01	Automated Investigation and Response, Threat Explorer, Attack Simulation	Ausstehende AIR-Aktionen regelmäßig freigeben; Threat Explorer und Campaign Views im Betrieb nutzen	MDO P2 / M365 E5

Anhang E: Wo die Einstellung im Portal sitzt

Die häufigste Reibung im Kundentermin ist nicht die Frage, was zu tun ist, sondern wo es steht. Diese Tabelle gibt zu jedem Prüfpunkt den Klickpfad, den Direktlink auf die Portalseite und den Microsoft-Learn-Abschnitt, der die Einstellung beschreibt.

Der Pfad **Bedrohungsrichtlinien** liegt im Defender-Portal unter *E-Mail & Zusammenarbeit* > *Richtlinien & Regeln*. Wo kein Portalpfad steht, ist die Einstellung nicht über die Oberfläche erreichbar — das betrifft vor allem das öffentliche DNS und einige PowerShell-only-Schalter.

Dieselben Angaben stehen in der Checkliste (Spalten *Fundort*, *Portal öffnen*, *Microsoft Learn*) und im HTML-Report des Audit-Skripts, dort als anklickbare Links direkt am Befund.

Preset Security Policies

ID	Fundort	Direkt
PRE-01	Defender-Portal > Bedrohungsrichtlinien > Voreingestellte Sicherheitsrichtlinien (Preset security policies)	Portal · Learn
PRE-02	Defender-Portal > Bedrohungsrichtlinien > Voreingestellte Sicherheitsrichtlinien > Integrierter Schutz (Built-in protection) > "Ausschlüsse verwalten"	Portal · Learn
PRE-03	Kein eigener Portal-Screen. Präzedenz ablesen an der Spalte "Priorität" je Richtlinientyp (Antispam, Antiphishing, ...) plus der Preset-Seite	Portal · Learn
PRE-04	Defender-Portal > Bedrohungsrichtlinien > Konfigurationsanalyse (Configuration analyzer) > Reiter "Standardempfehlungen" / "Strenge Empfehlungen"	Portal · Learn
PRE-05	Defender-Portal > Bedrohungsrichtlinien > Antispam (Spalten Status / Priorität / Typ), analog Antiphishing, Antischadsoftware, Sichere Links, Sichere Anlagen	Portal · Learn

Anti-Spam inbound

ID	Fundort	Direkt
ASI-01	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > "Massen-E-Mail-Schwellenwert & Spameigenschaften" > Schieberegler "Massen-E-Mail-Schwellenwert"	Portal · Learn
ASI-02	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > "Aktionen" > Nachrichtenaktionen > Zeile "Spam"	Portal · Learn
ASI-03	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > "Aktionen" > Nachrichtenaktionen > Zeile "Spam mit hoher Sicherheit"	Portal · Learn
ASI-04	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > "Aktionen" > Nachrichtenaktionen > Zeile	Portal ·

ID	Fundort	Direkt
	“Phishing”	Learn
ASI-05	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > “Aktionen” > Nachrichtenaktionen > Zeile “Phishing mit hoher Sicherheit”	Portal · Learn
ASI-06	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > “Aktionen” > Nachrichtenaktionen > Zeile “Massenkonforme Ebene (BCL) erreicht oder ueberschritten”	Portal · Learn
ASI-07	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > “Aktionen” > Abschnitt “Sicherheitstipps” > Haken “Sicherheitstipps aktivieren”	Portal · Learn
ASI-08	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > “Aktionen” > “Automatische Bereinigung (ZAP) aktivieren” mit den zwei Unterhaken fuer Phishing und Spam	Portal · Learn
ASI-09	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > “Aktionen” > Feld “Spamnachrichten so viele Tage lang in Quarantäne aufbewahren” (1-30, Default 15)	Portal · Learn
ASI-10	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > “Zulassen- und Sperrliste” > “Absender verwalten” / “Domänen zulassen” (im Portal max. 30 Einträge)	Portal · Learn
ASI-11	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > “Massen-E-Mail-Schwellenwert & Spameigenschaften” > Spameigenschaften > “Enthält bestimmte Sprachen” / “Aus diesen Ländern” (gehört NICHT zum ASF)	Portal · Learn
ASI-12	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > “Aktionen” > “Organisationsinterne Nachrichten, fuer die Maßnahmen ergriffen werden sollen”	Portal · Learn

Advanced Spam Filter (ASF)

ID	Fundort	Direkt
ASF-01	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > “Massen-E-Mail-Schwellenwert & Spameigenschaften” > Spameigenschaften > Gruppe “Erhöhen der Spambewertung”	Portal · Learn
ASF-02	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > “Massen-E-Mail-Schwellenwert & Spameigenschaften” > Spameigenschaften > Gruppe “Als Spam markieren”	Portal · Learn
ASF-03	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > “Massen-E-Mail-Schwellenwert & Spameigenschaften” > Spameigenschaften > “SPF-Eintrag: Hard Fail”	Portal · Learn

ID	Fundort	Direkt
ASF-04	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > "Massen-E-Mail-Schwellenwert & Spameigenschaften" > Spameigenschaften > "Absender-ID-Filterung: Hard Fail" und "Backscatter"	Portal · Learn
ASF-05	Defender-Portal > Bedrohungsrichtlinien > Antispam > <Richtlinie> > "Massen-E-Mail-Schwellenwert & Spameigenschaften" > Spameigenschaften > "Testmodus" (gilt global fuer alle auf Test gesetzten ASF-Optionen)	Portal · Learn

Connection Filter

ID	Fundort	Direkt
CF-01	Defender-Portal > Bedrohungsrichtlinien > Antispam > in der Liste die Zeile "Verbindungsfilterrichtlinie (Standard)" ANKLICKEN > Flyout > "Verbindungsfilterrichtlinie bearbeiten" > "Nachrichten aus den folgenden IP-Adressen immer zulassen"	Portal · Learn
CF-02	Defender-Portal > Bedrohungsrichtlinien > Antispam > Zeile "Verbindungsfilterrichtlinie (Standard)" > "Verbindungsfilterrichtlinie bearbeiten" > "Nachrichten aus den folgenden IP-Adressen immer blockieren"	Portal · Learn
CF-03	Defender-Portal > Bedrohungsrichtlinien > Antispam > Zeile "Verbindungsfilterrichtlinie (Standard)" > "Verbindungsfilterrichtlinie bearbeiten" > Haken "Sichere Liste aktivieren"	Portal · Learn

Anti-Spam outbound

ID	Fundort	Direkt
ASO-01	Defender-Portal > Bedrohungsrichtlinien > Antispam > Liste auf "Ausgehende Antispamrichtlinie (Standard)" und eigene Richtlinien pruefen; neu ueber "+ Richtlinie erstellen > Ausgehend"	Portal · Learn
ASO-02	Defender-Portal > Bedrohungsrichtlinien > Antispam > <ausgehende Richtlinie> > "Schutzeinstellungen" > Nachrichtengrenzwerte (extern / intern / täglich)	Portal · Learn
ASO-03	Defender-Portal > Bedrohungsrichtlinien > Antispam > <ausgehende Richtlinie> > "Schutzeinstellungen" > "Einschränkung fuer Benutzer, die das Nachrichtenlimit erreichen"	Portal · Learn
ASO-04	Defender-Portal > Bedrohungsrichtlinien > Antispam > <ausgehende Richtlinie> > "Schutzeinstellungen" > Weiterleitungsregeln > "Automatische Weiterleitungsregeln"	Portal · Learn
ASO-05	Defender-Portal > Bedrohungsrichtlinien > Antispam > "Ausgehende Antispamrichtlinie (Standard)" >	Portal · Learn

ID	Fundort	Direkt
	“Schutzeinstellungen” > Benachrichtigungen (BCC-Kopie); gesperrte Absender unter Defender-Portal > Überprüfen > Eingeschränkte Benutzer	
ASO-06	Nicht konfigurierbar (mandantenweites Limit). Auswertung: Exchange Admin Center > Berichte > Nachrichtenfluss > “Tenant Outbound External Recipients”	Portal · Learn

Anti-Phishing / Spoof

ID	Fundort	Direkt
APH-01	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Phishingschwellenwert & Schutz” > Abschnitt “Spoofing” > “Spoofintelligenz aktivieren”	Portal · Learn
APH-02	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Aktionen” > “Wenn die Nachricht durch Spoofintelligenz als Spoofing erkannt wird”	Portal · Learn
APH-03	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Phishingschwellenwert & Schutz” > “DMARC-Eintragsrichtlinie berücksichtigen, wenn die Nachricht als Spoofing erkannt wird”	Portal · Learn
APH-04	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Aktionen” > “... und die DMARC-Richtlinie p=quarantine lautet”	Portal · Learn
APH-05	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Aktionen” > “... und die DMARC-Richtlinie p=reject lautet”	Portal · Learn
APH-06	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Aktionen” > Sicherheitstipps & Indikatoren > “(?) fuer nicht authentifizierte Absender anzeigen” und “Tag via anzeigen”	Portal · Learn
APH-07	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Aktionen” > Sicherheitstipps & Indikatoren > “Sicherheitstipp fuer ersten Kontakt anzeigen”	Portal · Learn
APH-08	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Phishingschwellenwert & Schutz” > “Schwellenwert fuer Phishing-E-Mails” (1-4, nur mit Defender-Lizenz sichtbar)	Portal · Learn

Impersonation (MDO)

ID	Fundort	Direkt
IMP-01	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Phishingschwellenwert & Schutz” > Identitätswechsel > “Zu schützende Domänen aktivieren” >	Portal · Learn

ID	Fundort	Direkt
	“Domänen einschließen, die ich besitze”	
IMP-02	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Phishingschwellenwert & Schutz” > Identitätswechsel > “Benutzerdefinierte Domänen einschließen” (max. 50)	Portal · Learn
IMP-03	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Phishingschwellenwert & Schutz” > Identitätswechsel > “Benutzern das Schützen ermöglichen” > “Geschützte Benutzer verwalten” (max. 350)	Portal · Learn
IMP-04	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Aktionen” > die drei Zeilen zu Benutzer-, Domänenidentitätswechsel und Postfachintelligenz (nicht “Keine Aktion anwenden”)	Portal · Learn
IMP-05	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Phishingschwellenwert & Schutz” > Identitätswechsel > “Postfachintelligenz aktivieren” und “Intelligenz fuer Identitätswechselschutz aktivieren”	Portal · Learn
IMP-06	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Aktionen” > Sicherheitstipps & Indikatoren > die drei Identitätswechsel-Tipps	Portal · Learn
IMP-07	Defender-Portal > Bedrohungsrichtlinien > Antiphishing > <Richtlinie> > “Phishingschwellenwert & Schutz” > Identitätswechsel > “Vertrauenswürdige Absender und Domänen hinzufuegen” (max. 1024)	Portal · Learn
IMP-08	Defender-Portal > Einstellungen > E-Mail & Zusammenarbeit > Schutz von Prioritätskonten (Priority account protection); die Konten selbst werden im Microsoft 365 Admin Center markiert	Portal · Learn

Tenant Allow/Block List

ID	Fundort	Direkt
TABL-01	Defender-Portal > Bedrohungsrichtlinien > Mandanten-Zulassungs-/Sperrlisten. Zulassungen entstehen bevorzugt ueber Übermittlungen (Submissions), nicht von Hand	Portal · Learn
TABL-02	Defender-Portal > Bedrohungsrichtlinien > Mandanten-Zulassungs-/Sperrlisten > Reiter “Domänen und E-Mail-Adressen” > Spalten “Aktion” und “Laeuft ab am”	Portal · Learn
TABL-03	Defender-Portal > Bedrohungsrichtlinien > Mandanten-Zulassungs-/Sperrlisten > Reiter “Gefälschte Absender”; ergaenzend die Spoofintelligenz-Erkenntnisse	Portal · Learn
TABL-04	Defender-Portal > Bedrohungsrichtlinien > Mandanten-Zulassungs-/Sperrlisten > Reiter “URLs”	Portal · Learn
TABL-	Defender-Portal > Bedrohungsrichtlinien > Mandanten-	Portal ·

ID	Fundort	Direkt
05	Zulassungs-/Sperrlisten > Reiter "Dateien" (nur SHA256, Zulassungen nur ueber Übermittlungen)	Learn
TABL-06	Defender-Portal > Bedrohungsrichtlinien > Mandanten-Zulassungs-/Sperrlisten > Reiter "IP-Adressen" (ausschließlich IPv6)	Portal · Learn

Anti-Malware

ID	Fundort	Direkt
AMW-01	Defender-Portal > Bedrohungsrichtlinien > Antischadsoftware > <Richtlinie> > "Schutzeinstellungen" > "Aktivieren Sie den allgemeinen Anlagenfilter" > "Dateitypen auswählen"	Portal · Learn
AMW-02	Defender-Portal > Bedrohungsrichtlinien > Antischadsoftware > <Richtlinie> > "Schutzeinstellungen" > "Automatische Null-Stunden-Bereinigung fuer Schadsoftware aktivieren"	Portal · Learn
AMW-03	Defender-Portal > Bedrohungsrichtlinien > Antischadsoftware > <Richtlinie> > "Schutzeinstellungen" > "Wenn diese Dateitypen gefunden werden" (NDR ablehnen vs. Quarantäne)	Portal · Learn
AMW-04	Defender-Portal > Bedrohungsrichtlinien > Antischadsoftware > <Richtlinie> > "Schutzeinstellungen" > "Quarantänerichtlinie" (Default AdminOnlyAccessPolicy)	Portal · Learn
AMW-05	Defender-Portal > Bedrohungsrichtlinien > Antischadsoftware > <Richtlinie> > "Schutzeinstellungen" > Benachrichtigungen > Administratorbenachrichtigungen	Portal · Learn

Safe Attachments (MDO)

ID	Fundort	Direkt
SA-01	Defender-Portal > Bedrohungsrichtlinien > Sichere Anlagen > <Richtlinie> > "Einstellungen" > "Safe Attachments-Antwort bei unbekannter Schadsoftware" = Blockieren	Portal · Learn
SA-02	Defender-Portal > Bedrohungsrichtlinien > Sichere Anlagen > <Richtlinie> > "Einstellungen" > "Umleiten von Nachrichten mit erkannten Anlagen" (wirkt laut Doku nur bei Aktion "Ueberwachen")	Portal · Learn
SA-03	Defender-Portal > Bedrohungsrichtlinien > Sichere Anlagen > Zahnrad "Globale Einstellungen" > "Defender for Office 365 fuer SharePoint, OneDrive und Microsoft Teams aktivieren". Download-Sperre zusaetzlich nur per SharePoint-PowerShell	Portal · Learn
SA-04	Defender-Portal > Bedrohungsrichtlinien > Sichere Anlagen > Zahnrad "Globale Einstellungen" > "Safe Documents fuer Office-Clients aktivieren" plus Durchklicken verbieten	Portal · Learn
SA-05	Defender-Portal > Bedrohungsrichtlinien > Sichere Anlagen > <Richtlinie> > "Einstellungen" > "Safe Attachments-Antwort" =	Portal · Learn

ID	Fundort	Direkt
	"Dynamische Übermittlung (Vorschau von Nachrichten)"	

Safe Links (MDO)

ID	Fundort	Direkt
SL-01	Defender-Portal > Bedrohungsrichtlinien > Sichere Links > <Richtlinie> > "URL- & Klickschutzeinstellungen" > Abschnitte "E-Mail", "Teams" und "Office 365-Apps" je auf Ein	Portal · Learn
SL-02	Defender-Portal > Bedrohungsrichtlinien > Sichere Links > <Richtlinie> > "URL- & Klickschutzeinstellungen" > E-Mail > "Sichere Links auf E-Mail-Nachrichten anwenden, die innerhalb der Organisation gesendet werden"	Portal · Learn
SL-03	Defender-Portal > Bedrohungsrichtlinien > Sichere Links > <Richtlinie> > "URL- & Klickschutzeinstellungen" > "URL-Überprüfung in Echtzeit ..." mit der Unteroption "Warten, bis die URL-Überprüfung abgeschlossen ist"	Portal · Learn
SL-04	Defender-Portal > Bedrohungsrichtlinien > Sichere Links > <Richtlinie> > "URL- & Klickschutzeinstellungen" > Klickschutzeinstellungen > "Benutzern das Durchklicken zur ursprünglichen URL erlauben" ausschalten	Portal · Learn
SL-05	Defender-Portal > Bedrohungsrichtlinien > Sichere Links > <Richtlinie> > "URL- & Klickschutzeinstellungen" > E-Mail > "URLs nicht umschreiben, Überprüfungen nur ueber die SafeLinks-API" muss AUS sein	Portal · Learn
SL-06	Defender-Portal > Bedrohungsrichtlinien > Sichere Links > <Richtlinie> > "URL- & Klickschutzeinstellungen" > "Die folgenden URLs in E-Mails nicht umschreiben" > "Nicht umzuschreibende URLs verwalten" (pro Richtlinie, nicht global)	Portal · Learn
SL-07	Defender-Portal > Bedrohungsrichtlinien > Sichere Links > <Richtlinie> > "URL- & Klickschutzeinstellungen" > "Organisationsbranding anzeigen" (Logo aus dem M365-Organisationsdesign) sowie > "Benachrichtigung" > eigener Text (max. 200 Zeichen)	Portal · Learn

Quarantäne-Policies

ID	Fundort	Direkt
QUA-01	Defender-Portal > Bedrohungsrichtlinien > Quarantänerichtlinie (definieren); zugewiesen wird sie je Verdict in Antispam > <Richtlinie> > "Aktionen", in Antiphishing > "Aktionen" sowie in Antischadsoftware und Sichere Anlagen	Portal · Learn
QUA-02	Defender-Portal > Bedrohungsrichtlinien > Quarantänerichtlinie > "Benutzerdefinierte Richtlinie hinzufuegen" > "Zugriff auf Empfängernachrichten" > "Spezifischen Zugriff festlegen"	Portal · Learn

ID	Fundort	Direkt
	(Erweitert)" > Quarantänebenachrichtigung aktivieren	
QUA-03	Defender-Portal > Bedrohungsrichtlinien > Quarantänerichtlinie > Zahnrad "Globale Einstellungen" > "Spambenachrichtigung fuer Endbenutzer senden alle" (4 Stunden / täglich / woechentlich)	Portal · Learn
QUA-04	Defender-Portal > Bedrohungsrichtlinien > Quarantänerichtlinie > Zahnrad "Globale Einstellungen" > Absenderadresse, Anzeigenname, Betreff, Haftungsausschluss und Firmenlogo	Portal · Learn

Advanced Delivery

ID	Fundort	Direkt
ADV-01	Defender-Portal > Bedrohungsrichtlinien > Erweiterte Zustellung (Advanced delivery) > Reiter "SecOps-Postfach" (nur echte Postfächer, keine Verteilergruppen)	Portal · Learn
ADV-02	Defender-Portal > Bedrohungsrichtlinien > Erweiterte Zustellung > Reiter "Phishingsimulation" (Domäne + Sende-IP; IPv6 nur per PowerShell)	Portal · Learn
ADV-03	Exchange Admin Center > Nachrichtenfluss > Regeln: jede Regel auf "Spamfilterung umgehen" (SCL -1) pruefen. Solche Bypaesse gehoeren in die Erweiterte Zustellung oder die TABL	Portal · Learn

E-Mail-Authentifizierung

ID	Fundort	Direkt
AUTH-01	Öffentliches DNS beim Domain-Hoster: TXT auf <domäne> mit v=spf1 include:spf.protection.outlook.com -all, je akzeptierter Domäne genau einer	Learn
AUTH-02	Öffentliches DNS: TXT auf <domäne>, Endqualifier -all statt ~all	Learn
AUTH-03	Öffentliches DNS: fuer geparkte Domänen TXT v=spf1 -all auf <domäne> plus TXT v=DMARC1; p=reject; auf _dmarc.<domäne>. Gilt auch fuer die onmicrosoft.com-Domäne	Learn
AUTH-04	Defender-Portal > Bedrohungsrichtlinien > E-Mail-Authentifizierungseinstellungen > DKIM > Domäne wählen, Umschalter aktivieren. Vorher die beiden CNAMEs selector1/2._domainkey.<domäne> ins öffentliche DNS	Portal · Learn
AUTH-05	Die Bitlänge steuert nur PowerShell: Rotate-DkimSigningConfig -KeySize 2048. Im Portal rotiert man ueber E-Mail-Authentifizierungseinstellungen > DKIM > Domänenzeile ANKLICKEN > Flyout > "DKIM-Schlüssel rotieren"	Portal · Learn
AUTH-06	Öffentliches DNS: TXT auf _dmarc.<domäne> mit v=DMARC1; p=...; rua=mailto:... Fuer die onmicrosoft.com-Domäne ueber Microsoft 365 Admin Center > Einstellungen > Domänen	Portal · Learn

ID	Fundort	Direkt
AUTH-07	Öffentliches DNS: rua=mailto: im TXT auf _dmarc.<domäne>, Ziel ein dediziertes Shared Mailbox, kein Benutzerpostfach	Learn
AUTH-08	Defender-Portal > Bedrohungsrichtlinien > E-Mail-Authentifizierungseinstellungen > ARC; alternativ Set-ArcConfig -ArcTrustedSealers	Portal · Learn
AUTH-09	Öffentliches DNS: TXT auf _mta-sts.<domäne> PLUS extern gehostete Policy-Datei unter https://mta-sts.<domäne>/.well-known/mta-sts.txt. Exchange Online hostet die Datei nicht. Ausgehend ist MTA-STS immer aktiv	Learn
AUTH-10	Ausgehend standardmaessig an. Eingehend per Exchange Online PowerShell: Enable-DnssecForVerifiedDomain, dann Enable-SmtpDaneInbound, danach den ausgegebenen MX-Wert beim Hoster setzen und die Delegation DNSSEC-signieren	Learn
AUTH-11	Kein Portal: SPF, DKIM und DMARC ausgerichtet auf die 5322.From-Domäne plus auffindbarer Abmeldemechanismus. Greift ab 5.000 Nachrichten/Tag an Microsoft-Consumer-Dienste, sonst NDR 550 5.7.515	Learn

Enhanced Filtering

ID	Fundort	Direkt
EF-01	Defender-Portal > Bedrohungsrichtlinien > Erweiterte Filterung (Enhanced filtering) > Eintrag des Inbound-Connectors > zu überspringende IPs bzw. "Letzte IP überspringen"	Portal · Learn
EF-02	Exchange Admin Center > Nachrichtenfluss > Regeln: SCL-(-1)-Regeln fuer Nachrichten ueber diesen Connector abschalten	Portal · Learn

Kennzeichnung externer E-Mails

ID	Fundort	Direkt
EXT-01	Kein Portal, nur Exchange Online PowerShell: Set-ExternallnOutlook -Enabled \$true, Ausnahmen ueber -AllowList (max. 200). Wirkung erst nach 24-48 Stunden	Learn
EXT-02	Entscheidung zwischen nativem Tag (PowerShell), First-Contact-Tipp (Antiphishing-Richtlinie) und Banner per Transportregel. Nicht mehrere gleichzeitig	Portal · Learn
EXT-03	Exchange Admin Center > Nachrichtenfluss > Regeln: Regel mit "Absender ausserhalb der Organisation" und Aktion "Haftungsausschluss voranstellen", Fallback-Aktion und Ausnahmen setzen	Portal · Learn

Reporting & Alerting

ID	Fundort	Direkt
REP-01	Defender-Portal > Berichte > E-Mail & Zusammenarbeit;	Portal ·

ID	Fundort	Direkt
	Zeitplan je Bericht ueber "Create schedule"	Learn
REP-02	Defender-Portal > Richtlinien & Regeln > Warnungsrichtlinie; Empfänger je Richtlinie im Feld "Email recipients"	Portal · Learn
REP-03	Defender-Portal > Einstellungen > E-Mail & Zusammenarbeit > Benutzerdefinierte Meldungen (User reported settings); alternativ *-ReportSubmissionPolicy in PowerShell	Portal · Learn
REP-04	Kein Portalpunkt, sondern Skripte: auf GetMessageTraceV2 / GetMessageTraceDetailV2 umstellen. Interaktiv fuehrt der Defender-Portal-Eintrag nur ins EAC	Portal · Learn

Hybrid & On-Premises

ID	Fundort	Direkt
HYB-01	Nur On-Premises: Exchange Management Shell (Get-ExchangeServer, ExSetup /Version) gegen die Supportability-Matrix. Exchange 2016 und 2019 sind seit 14.10.2025 out of support	Learn
HYB-02	On-Premises: Skript ConfigureExchangeHybridApplication.ps1 bzw. HCW. Kontrolle der Dienstprinzipal-Anmeldungen in Microsoft Entra ID > Überwachung > Anmeldeprotokolle	Portal · Learn
HYB-03	Nur On-Premises: "Default Frontend <Server>" nicht fuer anonymes Relay oeffnen, stattdessen dedizierter Receive-Connector mit RemoteIpRanges	Learn
HYB-04	Perimeter- und Host-Firewall: ausgehend SMTP 25/587 nur von den Transport-Servern, POP3 110/995 und IMAP4 143/993 nach aussen sperren	Learn
HYB-05	Exchange Admin Center > Einstellungen > E-Mail-Fluss > "SMTP AUTH-Protokoll fuer Ihre Organisation deaktivieren". Ausnahmen je Postfach ueber Set-CASMailbox	Portal · Learn
HYB-06	Exchange Admin Center > Empfänger > Postfächer > <Postfach> > "E-Mail-App-Einstellungen verwalten"; organisationsweit ueber Set-CASMailbox bzw. Set-CASMailboxPlan fuer neue Postfächer	Portal · Learn
HYB-07	Exchange Admin Center > Empfänger > Postfächer > <Postfach> > "Nachrichtengrößenbeschränkung verwalten"; die Dienstgrenzwerte sind harte Limits	Portal · Learn
HYB-08	Exchange Admin Center > Nachrichtenfluss > Connectors > ausgehender Connector: "Immer eine TLS-gesicherte Verbindung verwenden" plus Zertifikatsprüfung	Portal · Learn
HYB-09	Exchange Admin Center > Nachrichtenfluss > Connectors: alle ein- und ausgehenden Connectors inventarisieren (HCW vs. manuell, IP-Bereiche, Zertifikate)	Portal · Learn

Betrieb & Voraussetzungen

ID	Fundort	Direkt
OPS-01	Defender-Portal > Berechtigungen: Rollengruppen "E-Mail & Zusammenarbeit" bzw. Defender XDR Unified RBAC; dazu die Entra-Rollen	Portal · Learn
OPS-02	Kein Portal: Admin-Arbeitsplatz. Modul ExchangeOnlineManagement, Windows PowerShell 5.1 mit .NET 4.7.2+ oder PowerShell 7	Learn
OPS-03	Baseline per PowerShell exportieren; ergaenzend Konfigurationsanalyse > Reiter "Configuration drift analysis and history" (setzt Unified Auditing voraus)	Portal · Learn
OPS-04	Nachweis ueber Microsoft Purview > Audit (Unified Audit Log); Nachkontrolle als wiederkehrenden Termin setzen	Portal · Learn

Microsoft Teams Protection

ID	Fundort	Direkt
TEAMS-01	Defender-Portal > Einstellungen > E-Mail & Zusammenarbeit > Microsoft Teams-Schutz (NICHT mehr unter Bedrohungsrichtlinien) > ZAP fuer Teams, Quarantänerichtlinie, Ausnahmen	Portal · Learn

Anti-Spam outbound

ID	Fundort	Direkt
ASO-07	NICHT im Defender-Portal: Exchange Admin Center > Nachrichtenfluss > Remotedomänen > "Default" > Abschnitt "Automatische Antworten" (dort sitzt die Weiterleitungsoption)	Portal · Learn
ASO-08	Keine Einstellung, mandantenweite Drosselung. Pruefung: Exchange Admin Center > Nachrichtenfluss > Akzeptierte Domänen sowie Absenderdomänen in Connectors und Anwendungen	Portal · Learn

Hybrid & On-Premises

ID	Fundort	Direkt
HYB-10	Exchange Admin Center > Nachrichtenfluss > Akzeptierte Domänen: Typ "Autorisierend" schaltet DBEB ein, "Internes Relay" schaltet es ab	Portal · Learn

Wirksamkeitsnachweis

ID	Fundort	Direkt
VER-01	Defender-Portal > Überprüfen > Quarantäne, Filter Richtlinientyp = Antischadsoftware-Richtlinie	Portal · Learn
VER-02	Kein Portal: Outlook > Datei > Eigenschaften > Internetkopfzeilen (neues Outlook/OWA: Nachricht > ... >	Learn

ID	Fundort	Direkt
	Details anzeigen). Ausgewertet werden X-Forefront-Antispam-Report, X-Microsoft-Antispam und Authentication-Results	
VER-03	Defender-Portal > E-Mail & Zusammenarbeit > Explorer (P2) bzw. Echtzeiterkennungen (P1), Ansichten Phish und URL-Klicks	Portal · Learn

Governance & Datenschutz

ID	Fundort	Direkt
GOV-01	Kein Microsoft-Portalpunkt: organisatorisch - Datenschutz-Folgenabschätzung, Verfahrensverzeichnis und Mitbestimmung fuer Quarantäne-Einsicht und Explorer-Preview	Learn

E-Mail-Authentifizierung

ID	Fundort	Direkt
AUTH-12	Öffentliches DNS: TXT auf default._bimi.<domäne>. Voraussetzung ist DMARC p=quarantine oder p=reject. Exchange Online wertet BMI derzeit nicht aus	Learn

Defender P2 (falls lizenziert)

ID	Fundort	Direkt
P2-01	Defender-Portal > Untersuchungen (AIR, nur MDO Plan 2; setzt aktiviertes Audit-Logging voraus)	Portal · Learn

Was an diesen Links unsicher ist

Sämtliche Deep-Links ins Defender-Portal stammen aus der Microsoft-Dokumentation — Microsoft nennt sie in den Learn-Artikeln ausdrücklich. Alle Learn-Sprungmarken sind gegen die Quelldateien der MicrosoftDocs-Repositories geprüft, also nicht geraten.

Drei Einschränkungen gehören dazu:

- Für das **Exchange Admin Center** dokumentiert Microsoft nur wenige Direktlinks. Nicht belegt und aus der Praxis übernommen sind die Links von ASO-07, ASO-08, HYB-06, HYB-07, HYB-10. Führt einer ins Leere, steht der Klickpfad daneben.
- Die **Verbindungsfilterrichtlinie** hat keinen eigenen Link. Sie liegt als Zeile *in der Liste der Anti-Spam-Richtlinien* — man muss die Zeile anklicken, nicht die Checkbox, und dann im Flyout auf „Verbindungsfilterrichtlinie bearbeiten“. Das ist die Stelle, an der man beim ersten Mal zuverlässig vorbeiscrollt.
- Vier Prüfpunkte haben **keinen passgenauen Learn-Artikel**; der Link führt auf das Nächstliegende:

- **AUTH-11** — Learn deckt die High-Volume-Sender-Anforderungen nicht ab; belastbar sind nur der Support-Artikel zu NDR 550 5.7.515 und der MDO-Blogpost vom 30.04.2025.
- **AUTH-12** — Fuer BIMl gibt es keinen EOP/MDO-Artikel. Die verlinkte Seite gehoert zu Dynamics 365 und stellt fest, dass Exchange Online BIMl nicht auswertet.
- **GOV-01** — Mitbestimmung nach BetrVG ist bei Microsoft nicht dokumentiert; verlinkt ist der DSGVO-Artikel.
- **HYB-04** — Kein Firewall-Artikel bei Microsoft; verlinkt ist die Exchange-Portreferenz.

Anhang B: Was aus dem Ursprungsdokument korrigiert wurde

Diese Übersicht ist bewusst vollständig. Sie ist keine Kritik am Ursprungsdokument – die meisten Punkte sind schlicht Veränderungen bei Microsoft seit 2023. Sie dient dazu, dass niemand versehentlich eine überholte Angabe weiterträgt.

Sachliche Korrekturen

Angabe im Ursprungsdokument	Befund 2026	ID
„Stand auf AdminOnlyAccessWithNotifyPolicy – so gelassen!“	Eine Policy dieses Namens existiert nicht. Es gibt AdminOnlyAccessPolicy, DefaultFullAccessPolicy und DefaultFullAccessWithNotificationPolicy.	QUA-01
Phishing-Schwellwert: Empfehlung 2	MS Standard-Preset setzt 3, Strict 4. Stufe 2 liegt unter dem heutigen Normalmaß.	APH-08
Advanced Delivery / Phishing-Simulation „gehört zu MDO-E5“	Gilt laut Microsoft ab Plan 1. Verwechslung mit Attack Simulation Training (das ist P2/E5).	ADV-02
„Das ist doch nur der First Contact Safety Tip und keine Kennzeichnung als externe Mail“	Set-ExternalInOutlook ist ein eigenes Feature mit eigenem Auslöser. Beide sind verschieden und beide sinnvoll.	EXT-01
Feature-Liste: „Sender ID filtering hard fail“	Der PowerShell-Parameter heißt MarkAsSpamFromAddressAuthFail. Ein MarkAsSpamSenderIdHardFail gibt es nicht.	ASF-04
„Der Default Receive Connector muss eingeschränkt werden“	Absicht richtig, Weg falsch. Den Default-Frontend-Connector einzuschränken bricht den Internet-Mailfluss. Stattdessen dedizierter Relay-Connector.	HYB-03
Enhanced Filtering: „Im Normalfall nicht benötigt“	Nur richtig, wenn der MX direkt auf EXO zeigt. Bei vorgeschaltetem Gateway	EF-01

Angabe im Ursprungsdokument	Befund 2026	ID
	zwingend erforderlich.	
Outbound-Limit „max. 200 pro Tag“	Deutlich strenger als MS Strict (800). Ohne vorherige Messung riskant.	ASO-02
Outbound-Aktion „Send Admin-Alert“	Beide Presets setzen BlockUser. Ein Alert stoppt nichts.	ASO-03
Anti-Spam outbound: „eigene erstellen“	BccSuspiciousOutboundMail wirkt nur in der Default-Policy.	ASO-01

Bestätigte Punkte

Nicht weniger wichtig – diese Empfehlungen von 2023 sind unverändert richtig und jetzt belegt:

Angabe	Beleg
BCL 6 statt 7	Entspricht exakt dem MS Standard-Preset.
SPF-Hardfail als Spam-Feature ist überflüssig (als Frage formuliert)	Microsoft: „ <i>No. This ASF setting is no longer required.</i> “
DoNotRewriteUrls schützt nicht vor der Einstufung als schädlich, dafür braucht es die TABL	Microsoft: „ <i>aren't scanned or wrapped ... but might still be blocked at time of click.</i> “
Quarantäne-Benachrichtigung alle 4 Stunden ist konfigurierbar	Gültige Werte: 04:00:00, 1.00:00:00, 7.00:00:00.
Spoof-Freigaben nur, wenn nicht anders lösbar	Bestätigt und wichtiger denn je – Spoof-Allow-Einträge laufen nie ab.
IP Allow List: „wo benötigt, aber Vorsicht“	Microsoft listet sie als vorletzte von fünf Allow-Methoden.
Anti-Malware: Dateityp-Filter ein, ZAP ein, Admin-Quarantäne	Deckt sich mit allen Presets.
Impersonation: „Include domains I own“	Entspricht EnableOrganizationDomainsProtection \$true, in beiden Presets aktiv.
Safe Attachments: Aktion Block	In allen drei Presets so gesetzt.
Safe Links: kein Durchklicken, kein API-only, interne Absender einbeziehen	Entspricht Standard und Strict.
Ausgehende Firewall-Regeln für SMTP/IMAP/POP	Gute Betriebspraxis – ohne Microsoft-Beleg, aber sachlich tragfähig.
ARC ist mit Vorsicht zu behandeln	Jeder Trusted Sealer darf beliebige

Angabe	Beleg
	Authentifizierungsergebnisse bezeugen.

Lücken, die geschlossen wurden

Thema	Warum es dazugehört	ID
Automatische externe Weiterleitungen	Standard-Exfiltrationsweg nach Kontokompromittierung.	ASO-04
DMARC-Durchsetzung in der Anti-Phish-Policy	Neu seit 2023/2024, EOP-Feature.	APH-03
First Contact Safety Tip	Default ist <code>\$false</code> , beide Presets setzen <code>\$true</code> .	APH-07
Geschützte Benutzer (User Impersonation)	Im Screenshot auf „0 senders“. Verteidigung gegen CEO-Fraud.	IMP-03
Impersonation-Aktionen	Im Screenshot durchgehend „Don't apply any action“.	IMP-04
Priority Account Protection	Neu, P2-Feature. VIPs müssen doppelt erfasst werden.	IMP-08
Dedizierte Exchange-Hybrid-App	CVE-2025-53786, seit 31.10.2025 erzwungen.	HYB-02
Exchange 2016/2019 out of support	Seit 14.10.2025.	HYB-01
SMTP AUTH, POP3, IMAP4	Umgehen alle Kennzeichnungen und Warnhinweise.	HYB-05, HYB-06
Tenant External Recipient Rate Limit	Neu seit 2025, harte Grenze.	ASO-06
Microsoft Sender Requirements	Seit Mai 2025, macht DMARC zur Pflicht.	AUTH-11
Alert Policies	Ersatz für das abgekündigte <code>NotifyOutboundSpam</code> .	REP-02
Meldeweg für Nutzer	Feedback-Loop für die Filterqualität.	REP-03
Ungenutzte und geparkte Domänen	Bevorzugte Spoofing-Quelle gegen den eigenen Kunden.	AUTH-03
Filter-Bypässe im Bestand	Häufigster Grund, warum gehärtete Tenants	ADV-03

Thema	Warum es dazugehört	ID
	trotzdem Phishing durchlassen.	
Microsoft Teams Protection	ZAP und Admin-Quarantäne für Teams, seit 2026 auch in Plan 1.	TEAMS-01
Remote Domain AutoForwardEnabled	Zweiter, unabhängiger Weg für automatische externe Weiterleitungen.	ASO-07
Drosselung der onmicrosoft.com-Domäne	Betrifft Dienstkonten und Geräte ohne eigene Adresse.	ASO-08
Accepted-Domain-Typ und DBEB	InternalRelay verschenkt eine kostenlose Filterstufe am Netzwerkrand.	HYB-10
Wirksamkeitsnachweis	EICAR, Anhangsfilter, Spoof-Test, Header-Auswertung.	VER-01 bis VER-03
Datenschutz und Mitbestimmung	In Deutschland regelmäßig der Punkt, an dem ein Hardening hängen bleibt.	GOV-01
BIMI	Logische Fortsetzung von DMARC, häufige Anschlussfrage.	AUTH-12
Defender-P2-Betrieb	AIR-Aktionen, Threat Explorer, Campaign Views.	P2-01

Nicht belegbare Punkte

Ehrlichkeit gehört zur Methodik. Diese Angaben ließen sich in den zugelassenen Quellen nicht abschließend verifizieren und sind im Text entsprechend gekennzeichnet:

- Ein Abschaltdatum für Safe Attachments Replace und für die Safe-Links-Global-Block-List.
- Ein Nachfolgeparameter für das entfallene ActionOnError in der Safe-Attachments-Policy.
- Eine ausdrückliche Microsoft-Empfehlung für DKIM mit 2048 Bit – belegt ist nur, dass es unterstützt wird.
- Eine Microsoft-Position zu externen Bannern per Transportregel, in die eine oder andere Richtung.
- Die genaue Berechnungsformel des Tenant External Recipient Rate Limit.
- Eine offizielle Microsoft-Aussage zum Sperren von ausgehendem SMTP auf der Firewall.

- Ob die Clientabdeckung des nativen External-Tags klassisches und neues Outlook für Windows gleichermaßen umfasst.
- Der exakte Grenzwert der Drosselung für die `onmicrosoft.com`-Domäne (ASO-08).
- Ob Microsoft den Zielkonflikt zwischen Secure Score und den Preset-Werten bei `NotifyOutboundSpam` selbst benennt – die Abkündigung des Parameters ist belegt, die Gegenüberstellung nicht.
- Die aktuelle Durchsetzungsstufe der Sender Requirements: Ablehnung oder Zustellung in den Junk-Ordner (AUTH-11).
- Ob ein TABL-Allow-Eintrag eine DMARC-`p=reject`-Durchsetzung bei aktivem `HonorDmarcPolicy` übersteuert. Im Kundenprojekt zu testen, nicht anzunehmen.

Anhang C: Ablaufplan für einen Kundentermin

Ein Vorschlag für einen Tagesablauf, der sich in dieser Form abarbeiten lässt.

Vorbereitung (vor dem Termin)

- Zugänge klären: Global Reader und Security Reader reichen für den Lesemodus.
- ExchangeOnlineManagement-Modul auf dem eingesetzten Rechner aktuell.
- Checkliste kopieren und auf dem Deckblatt die Kundenangaben eintragen.
- MX-Record der Kundendomänen von außen prüfen – das entscheidet über EF-01 und über den halben Rest.

Vormittag: Aufnahme

Zeit	Schritt
30 min	Gespräch: Lizenzstand, Hybrid ja/nein, vorgeschaltete Systeme, bekannte Vorfälle, laufende Beschwerden über Fehlalarme
20 min	Invoke-EopAudit.ps1 laufen lassen, CSV und HTML erzeugen
60 min	Checkliste durchgehen, Ist-Werte übernehmen, Bewertungen setzen
20 min	Configuration Analyzer und Quarantäne ansehen

Nachmittag: Besprechung und Umsetzung

Zeit	Schritt
45 min	Ergebnis besprechen: erst die kritischen Punkte, dann die Abweichungen, die eine Kundenentscheidung brauchen
15 min	Invoke-EopHardening.ps1 ohne -Execute zeigen – was würde sich ändern
45 min	Nach Freigabe umsetzen
20 min	Nachlauf: Was wurde geändert, was ist offen, wann ist der Nachtermin

Die Punkte, die eine Kundenentscheidung brauchen

Diese lassen sich nicht vom Consultant allein entscheiden. Am besten vorbereitet ins Gespräch nehmen:

1. **Admin-Quarantäne oder Nutzer-Selbstbedienung** bei High confidence spam, Phishing, Spoof und Bulk (ASI-03 bis ASI-06, APH-02). Sicherheit gegen Administrationsaufwand.

2. **Outbound-Limits** (ASO-02). Gibt es legitimen Serienversand? Aus welchen Postfächern?
3. **Externe Kennzeichnung** (EXT-02). Welche Variante, und will der Kunde einen Banner im Nachrichtentext?
4. **Phishing-Schwellwert** (APH-08). Stufe 3 sofort oder gestuft über zwei Wochen?
5. **Geschützte Benutzer und Domänen** (IMP-02, IMP-03). Wer gehört auf die Listen? Diese Frage braucht die Fachbereiche.
6. **DMARC-Rollout** (AUTH-06). Wer versendet im Namen der Domäne? Wer koordiniert die DNS-Änderungen?

Was sich für ein Folgeprojekt anbietet

Punkte, die selten in einen Tagetermin passen und ein eigenes kleines Projekt rechtfertigen:

- DMARC-Einführung von $p=none$ bis $p=reject$, inklusive Reportauswertung
- DKIM-Rotation auf 2048 Bit für alle Domänen
- Aufnahme aller Versandquellen und Bereinigung der SPF-Records
- Ablösung von SMTP AUTH durch einen internen Relay-Connector
- Umstellung auf die dedizierte Exchange-Hybrid-App und Migration auf Exchange SE
- Einführung von Phishing-Simulationen über Advanced Delivery
- Teams Protection einrichten und den Meldeweg für Teams-Nachrichten aktivieren (TEAMS-01)
- BIMl nach abgeschlossener DMARC-Einführung (AUTH-12)
- Bei E5-Kunden: AIR-Betrieb, Threat Explorer und Attack Simulation Training einführen (P2-01)

Anhang D: Quellen

Alle Angaben in diesem Dokument stammen aus den folgenden Microsoft-Quellen, Stand August 2026.

Konzept- und Konfigurationsartikel

- Preset security policies — <https://learn.microsoft.com/en-us/defender-office-365/preset-security-policies>
- Recommendations for Microsoft 365 security settings — <https://learn.microsoft.com/en-us/defender-office-365/recommended-settings-for-eop-and-office365>
- Order and precedence of email protection — <https://learn.microsoft.com/en-us/defender-office-365/how-policies-and-protections-are-combined>
- Configuration analyzer for security policies — <https://learn.microsoft.com/en-us/defender-office-365/configuration-analyzer-for-security-policies>
- Configure anti-spam policies — <https://learn.microsoft.com/en-us/defender-office-365/anti-spam-policies-configure>
- ASF settings in anti-spam policies — <https://learn.microsoft.com/en-us/defender-office-365/anti-spam-policies-asf-settings-about>
- Bulk complaint level (BCL) — <https://learn.microsoft.com/en-us/defender-office-365/anti-spam-bulk-complaint-level-bcl-about>
- Spam confidence level (SCL) — <https://learn.microsoft.com/en-us/defender-office-365/anti-spam-spam-confidence-level-scl-about>
- Configure connection filtering — <https://learn.microsoft.com/en-us/defender-office-365/connection-filter-policies-configure>
- Configure outbound spam policies — <https://learn.microsoft.com/en-us/defender-office-365/outbound-spam-policies-configure>
- Troubleshoot outbound sending limits — <https://learn.microsoft.com/en-us/defender-office-365/outbound-spam-sending-limits-troubleshoot>
- Anti-phishing policies — <https://learn.microsoft.com/en-us/defender-office-365/anti-phishing-policies-about>
- Configure anti-phishing policies (EOP) — <https://learn.microsoft.com/en-us/defender-office-365/anti-phishing-policies-eop-configure>
- Configure anti-phishing policies (MDO) — <https://learn.microsoft.com/en-us/defender-office-365/anti-phishing-policies-mdo-configure>
- Anti-spoofing protection FAQ — <https://learn.microsoft.com/en-us/defender-office-365/anti-phishing-protection-spoofing-faq>
- Anti-malware protection — <https://learn.microsoft.com/en-us/defender-office-365/anti-malware-protection-about>

- Safe Attachments — <https://learn.microsoft.com/en-us/defender-office-365/safe-attachments-about>
- Safe Links — <https://learn.microsoft.com/en-us/defender-office-365/safe-links-about>
- Quarantine policies — <https://learn.microsoft.com/en-us/defender-office-365/quarantine-policies>
- Advanced delivery policy — <https://learn.microsoft.com/en-us/defender-office-365/advanced-delivery-policy-configure>
- Tenant Allow/Block List (URLs) — <https://learn.microsoft.com/en-us/defender-office-365/tenant-allow-block-list-urls-configure>
- Create safe sender lists — <https://learn.microsoft.com/en-us/defender-office-365/create-safe-sender-lists-in-office-365>
- Set up SPF — <https://learn.microsoft.com/en-us/defender-office-365/email-authentication-spf-configure>
- Set up DKIM — <https://learn.microsoft.com/en-us/defender-office-365/email-authentication-dkim-configure>
- Set up DMARC — <https://learn.microsoft.com/en-us/defender-office-365/email-authentication-dmarc-configure>
- Configure trusted ARC sealers — <https://learn.microsoft.com/en-us/defender-office-365/email-authentication-arc-configure>
- Enhanced Filtering for Connectors — <https://learn.microsoft.com/en-us/exchange/mail-flow-best-practices/use-connectors-to-configure-mail-flow/enhanced-filtering-for-connectors>
- Enhancing mail flow with MTA-STS — <https://learn.microsoft.com/en-us/purview/enhancing-mail-flow-with-mta-sts>
- How SMTP DANE works — <https://learn.microsoft.com/en-us/purview/how-smtp-dane-works>
- Mail flow rule conditions and exceptions — <https://learn.microsoft.com/en-us/exchange/security-and-compliance/mail-flow-rules/conditions-and-exceptions>
- Disclaimers, signatures, footers, headers — <https://learn.microsoft.com/en-us/exchange/security-and-compliance/mail-flow-rules/disclaimers-signatures-footers-or-headers>
- Email security reports — <https://learn.microsoft.com/en-us/defender-office-365/reports-email-security>
- Alert policies — <https://learn.microsoft.com/en-us/purview/alert-policies>
- Permissions in the Defender portal — <https://learn.microsoft.com/en-us/defender-office-365/mdo-portal-permissions>
- Exchange Online PowerShell V3 — <https://learn.microsoft.com/en-us/powershell/exchange/exchange-online-powershell-v2>
- App-only authentication — <https://learn.microsoft.com/en-us/powershell/exchange/app-only-auth-powershell-v2>

- Manage hybrid recipients with management tools — <https://learn.microsoft.com/en-us/exchange/manage-hybrid-exchange-recipients-with-management-tools>
- Hybrid Configuration Wizard FAQs — <https://learn.microsoft.com/en-us/exchange/hybrid-configuration-wizard-faqs>
- Exchange Online limits — <https://learn.microsoft.com/en-us/office365/servicedescriptions/exchange-online-service-description/exchange-online-limits>
- Manage accepted domains — <https://learn.microsoft.com/en-us/exchange/mail-flow-best-practices/manage-accepted-domains/manage-accepted-domains>
- Microsoft Teams protection — <https://learn.microsoft.com/en-us/defender-office-365/mdo-support-teams-about>
- Anti-spam message headers — <https://learn.microsoft.com/en-us/defender-office-365/message-headers-eop-mdo>

Cmdlet-Referenzen

Set-HostedContentFilterPolicy · Set-HostedConnectionFilterPolicy · Set-HostedOutboundSpamFilterPolicy · Set-AntiPhishPolicy · New-AntiPhishRule · Set-MalwareFilterPolicy · New-MalwareFilterRule · New-SafeAttachmentPolicy · Set-SafeAttachmentPolicy · New-SafeAttachmentRule · Set-SafeLinksPolicy · New-SafeLinksRule · Set-AtpPolicyForO365 · New-QuarantinePolicy · Set-QuarantinePolicy · New-TenantAllowBlockListItems · Get-TenantAllowBlockListItems · New-TenantAllowBlockListSpoofItems · Get-SpoofIntelligenceInsight · New-ExoPhishSimOverrideRule · New-SecOpsOverridePolicy · Get-EOPProtectionPolicyRule · New-EOPProtectionPolicyRule · Get-ATPBuiltInProtectionRule · Set-ATPBuiltInProtectionRule · Get-ConfigAnalyzerPolicyRecommendation · New-DkimSigningConfig · Set-DkimSigningConfig · Rotate-DkimSigningConfig · Get-ArcConfig · Set-ArcConfig · Set-InboundConnector · Set-OutboundConnector · New-TransportRule · Set-TransportRule · Set-ExternalInOutlook · Get-ExternalInOutlook · Get-MessageTraceV2 · Get-MessageTraceDetailV2 · Get-MailFlowStatusReport · Get-SpoofMailReport · New-ProtectionAlert · Set-ProtectionAlert · Set-ReportSubmissionPolicy · Set-EmailTenantSettings · Enable-SmtpDaneInbound · Get-SmtpDaneInboundStatus · Enable-DnssecForVerifiedDomain · Set-TeamsProtectionPolicy · Set-RemoteDomain · Set-AcceptedDomain · Connect-ExchangeOnline

Alle unter <https://learn.microsoft.com/en-us/powershell/module/exchangepowershell/>

Microsoft-Blogs

- Strengthening Email Ecosystem: Outlook's New Requirements for High-Volume Senders (April 2025)
- Announcing New DMARC Policy Handling Defaults for Enhanced Email Security (Juli 2023)
- Introducing Exchange Online Tenant Outbound Email Limits
- Exchange Online canceling the Mailbox External Recipient Rate Limit
- Exchange Server Subscription Edition (SE) is now available
- Announcing Exchange 2016 & 2019 Extended Security Update Program

Jeweils unter <https://techcommunity.microsoft.com/blog/exchange> beziehungsweise
<https://techcommunity.microsoft.com/blog/microsoftdefenderforoffice365blog>